

Sample Engagement Security Report

End-to-end analysis of attack paths, privilege escalations, and compliance gaps identified during the engagement.

REPORT DATE	August 05, 2026
REPORT TYPE	Active Directory Security Assessment
PROFILE	Full
DOMAINS	1 assessed

DOC · SAMPLE ENGAGEMENT · ADSCAN

OVERALL POSTURE **CRITICAL**

9

CRITICAL

6

HIGH

4

MEDIUM

30

ATTACK PATHS

Your AD posture is **critical**. 19 paths to full domain compromise require immediate executive attention.

100% of the maximum exposure score

0% 25% 50% 75% 100%

EXPOSURE TO DOMAIN COMPROMISE

A severity scale, not a headcount: how much of the worst-case exposure to full domain compromise this environment carries, given the routes found and how far each was proven. The account figure below counts people and is measured separately.

19 ROUTES TO FULL DOMAIN COMPROMISE

1 VALIDATED END-TO-END
13 PARTIALLY VALIDATED
5 IDENTIFIED BY CONFIGURATION ANALYSIS

POSTURE SCORE 2/100 · CRITICAL

6 of 6 ordinary (non-administrative) domain users have a validated path to full domain compromise

100% OF YOUR NON-ADMINISTRATIVE ACCOUNTS · 1 OF THESE ROUTES WAS EXECUTED END TO END DURING THE ASSESSMENT

A FURTHER 3 OF THE 9 ACCOUNTS ASSESSED (33%) ALREADY HOLD TIER 0 PRIVILEGE BY GROUP MEMBERSHIP AND ARE EXCLUDED FROM THE FIGURE ABOVE.

9 domain users hold a validated path in total: 6 ordinary (non-administrative) + 3 already-privileged (Tier 0, the compromise target itself).

COMPROMISE REACH · THE TIER EACH ROUTE CAN TAKE OVER

19

FULL DOMAIN COMPROMISE

Routes proving total control of the domain.

3

TIER 0 FOOTHOLD

Access to a Tier 0 host. Post-exploitation required.

2

TIER 0 GROUP TAKEOVER

Escalates toward, but does not yet prove, domain takeover.

9

CRITICAL FINDINGS

Issues requiring action within the next 7 days.

SEVERITY DISTRIBUTION

22 findings

● Critical 9 ● High 6 ● Medium 4 ● Low 3

“

BOTTOM LINE

Score sits in the critical band (2/100), driven by 19 paths to full domain compromise, which demand immediate executive attention regardless of severity counts. Cut every path by closing the underlying findings that drive them — 9 critical and 6 high. Start with the choke-points highlighted in section 06. Each one breaks multiple paths at once.



Contents

Executive findings, technical evidence, compliance mapping, and the prioritised remediation roadmap for this engagement.

01	Executive Summary	
1.1	Overall Risk Posture	
1.2	Critical Findings	
1.3	Compliance Snapshot	
·	How We Tier Privilege & Reach	
02	Attack Path Analysis	
03	Technical Findings	
04	MITRE ATT&CK Coverage	
05	DORA Compliance Mapping	
06	Attack Path Remediation Priorities	
07	Privilege Blast Radius	
08	Remediation Roadmap	
09	Environment Modifications & Cleanup	

01

Executive Summary

High-level assessment overview for senior leadership.



OVERALL RISK POSTURE

Critical risk: immediate executive attention required

9

CRITICAL

6

HIGH

4

MEDIUM

3

LOW

30

ATTACK PATHS

19 to full domain compromise

1 exploited

13 partially validated

10 theoretical

2 not assessed

4 hardening observed

SEVERITY DISTRIBUTION



● Critical (9) ● High (6) ● Medium (4) ● Low (3)

An automated Active Directory security assessment was conducted across 1 Active Directory domain. A total of 22 security findings were detected. **15 high-priority findings (9 critical, 6 high)** were identified that represent an immediate threat to business operations and regulatory standing.

During the assessment, **1 attack path** to full domain compromise was validated end-to-end by executing every step against the live environment. This confirms that a threat actor with standard internal network access could achieve complete control over the Active Directory environment without requiring advanced capabilities. Of the remaining routes to full domain compromise, **13** were **partially validated**: at least one step of each chain executed successfully against the live environment, though the chains were not run end-to-end. The other **5** were identified through configuration analysis and not executed. Immediate containment action is required.

The highest-priority issues requiring management attention are [ADCS ESC1 - Misconfigured Certificate Template, noPac/sAMAccountName Spoofing \(CVE-2021-42278 + CVE-2021-42287\)](#), and [ADCS ESC9 - No Security Extension on Certificate Template](#). Full technical detail and step-by-step remediation guidance are provided in the Technical Findings section of this report.

The identified gaps have direct implications for compliance with DORA (Digital Operational Resilience Act). Regulatory frameworks in scope require effective identity and access controls. The Active Directory

weaknesses documented here represent evidence of control failure that auditors and regulators would classify as significant non-conformities.

Immediate executive escalation is required. The security team should initiate emergency remediation within **30 days**. Board-level oversight of the remediation programme is recommended.

Assessment scope: Every figure in this report is derived from 1 enumerated Active Directory domain: `essos.local`.

Engagement integrity: ADscan made 2 changes to Active Directory during this assessment to demonstrate exploitability.

Action required: 2 changes could not be reverted automatically and require manual cleanup. See section 09 (Environment Modifications & Cleanup) for the exact objects and remediation commands.

Compliance Snapshot

At-a-glance regulatory posture across assessed frameworks. Full control-level detail in dedicated sections.



Critical Findings

Top critical and high-severity issues driving the risk posture. Full details in Technical Findings.

CRITICAL · 9.9 ADCS ESC1 - Misconfigured Certificate Template ADCS ESC1 occurs when a certificate template is configured to allow requesters to specify a Subject Alternative Name (SAN) in their certificate request, combined with an... ADSCAN ANALYSIS ESC1 abuse confirmed: certificate enrollment with attacker-supplied SAN succeeded Domain: <code>essos.local</code> CWE: <code>CWE-269</code>	CRITICAL · 9.8 noPac/sAMAccountName Spoofing (CVE-2021-42278 + CVE-2021-42287) NoPac chains two Active Directory vulnerabilities to achieve domain compromise from any standard domain user account. CVE-2021-42278 permits creating machine accounts with a... Domain: <code>essos.local</code> CWE: <code>CWE-290</code>	CRITICAL · 9.0 ADCS ESC9 - No Security Extension on Certificate Template ADCS ESC9 exploits the <code>CT_FLAG_NO_SECURITY_EXTENSION</code> flag on a certificate template. When this flag is set, the <code>szOID_NTDS_CA_SECURITY_EXT</code> extension — which embeds the... ADSCAN ANALYSIS ESC9 template lacks security extension on Tier-0-relevant authentication path Domain: <code>essos.local</code> CWE: <code>CWE-269</code>
---	--	--

TO

How We Tier Privilege & Reach

Two distinct questions answered with one vocabulary: the Tier a principal or asset *holds*, and the Tier it can *take over* through a validated attack path.

AXIS 1 • PRIVILEGE TIER

What an account or asset **is granted**

A static property from group membership, following the Microsoft Tiered Administration Model. Tier 0 is a containment boundary: any Tier 0 principal, if compromised, can take over the forest.

AXIS 2 • COMPROMISE REACH

What it can **take over** via a proven path

The effective result we demonstrate from the attack graph, expressed as the highest Tier a principal can reach. The gap between a low Tier held and a high Tier reached is the headline risk.

Tier 0: Domain Control

Identity control plane. Compromise is immediate, one-step ownership of the domain.

MEMBERS Domain Admins, Enterprise Admins, BUILTIN\Administrators, Domain Controllers, Schema Admins, krbtgt, the built-in Administrator (RID 500); Domain Controller computers.

Tier 0: Escalation-capable

Inside the Tier 0 boundary: not immediate domain ownership, but owns the forest through one known escalation technique (e.g. Backup Operators reading NTDS.dit).

MEMBERS Backup Operators, Account Operators, Server Operators, Print Operators, DnsAdmins, Cert Publishers, Key Admins, Group Policy Creator Owners, the read-only Domain Controller groups, and the Exchange privileged groups.

Tier 1: Server / Application Admin

Server and application plane. Controls business workloads and their data, but not the identity control plane.

MEMBERS Member servers and the accounts that administer them.

Tier 2: Standard

Standard user plane. No granted privilege over servers or the domain by membership alone.

MEMBERS Standard users and workstations.

COMPROMISE REACH • THE FOUR CLASSES

FULL DOMAIN COMPROMISE

Validated path to full domain compromise (control of a Tier 0 asset)

The path's final step takes control of a Tier 0 asset (a Domain Admin, a Domain Controller, or the domain object itself), so the domain is fully compromised.

TIER 0 Foothold**Foothold on a Tier 0 asset (control pending validation)**

The path's final step lands an interactive session on a Tier 0 machine (for example remote access to a Domain Controller). Full control of that machine is the next step and is pending validation.

TIER 0 GROUP TAKEOVER**Control of a Tier 0 escalation group (one technique from domain)**

The path's final step takes control of a Tier 0 escalation group (such as Backup Operators or DnsAdmins). Membership in that group reaches the domain through one further known technique.

STEPPING-STONE TO TIER 0**Validated path that advances toward Tier 0**

The path's final step lands on a waypoint below Tier 0 that meaningfully advances toward domain compromise without yet reaching a Tier 0 asset.

READING THE COMPROMISE REACH VIEW

Throughout this report, the **Tier 0 Exposure** rollup counts the accounts and assets with a validated path to a Tier 0 target. A *Validated path to full domain compromise (control of a Tier 0 asset)* proves total control of the domain; *Foothold on a Tier 0 asset (control pending validation)* means the route lands on a Tier 0 host where takeover is the next step but not yet proven. Prioritisation follows how **direct** the route is: a path to Domain Admin outranks a path to an escalation-capable group, even though both targets sit inside the Tier 0 boundary.

02 Attack Path Analysis

End-to-end attack chains identified in the Active Directory environment.

Attack path classification. **EXPLOITED** Successfully validated end-to-end during active testing. **PARTIALLY VALIDATED** A segment of the chain was executed successfully (at least one step proven), but it was not run end-to-end: the exploitation is proven, the initial access unconfirmed. Stronger than Attempted. **ATTEMPTED** Probed but not fully completed. **THEORETICAL** Mapped from configuration analysis; not actively exploited. **NOT ASSESSED** No reachable surface for ADscan to test this avenue during the engagement, so its exposure is unknown rather than mapped. **HARDENING OBSERVED** Your own configuration closes this avenue, observed directly. A positive finding, not exposure.

How these counts reconcile. The chips beside each domain below cover every card in that domain and add up to its total. The status says how far execution got; **TO FULL DOMAIN COMPROMISE** says how many of those routes END in control of the domain — that is the count page 2 leads with (19). The remaining **EXPLOITED**, **PARTIALLY VALIDATED**, **ATTEMPTED** and **THEORETICAL** cards stop at a Tier 0 foothold or an escalation group and are counted separately on page 2. **NOT ASSESSED** and **HARDENING OBSERVED** cards are shown for completeness and carry no exposure, so they sit outside every one of those figures.

essos.local

1 EXPLOITED

13 PARTIALLY VALIDATED

10 THEORETICAL

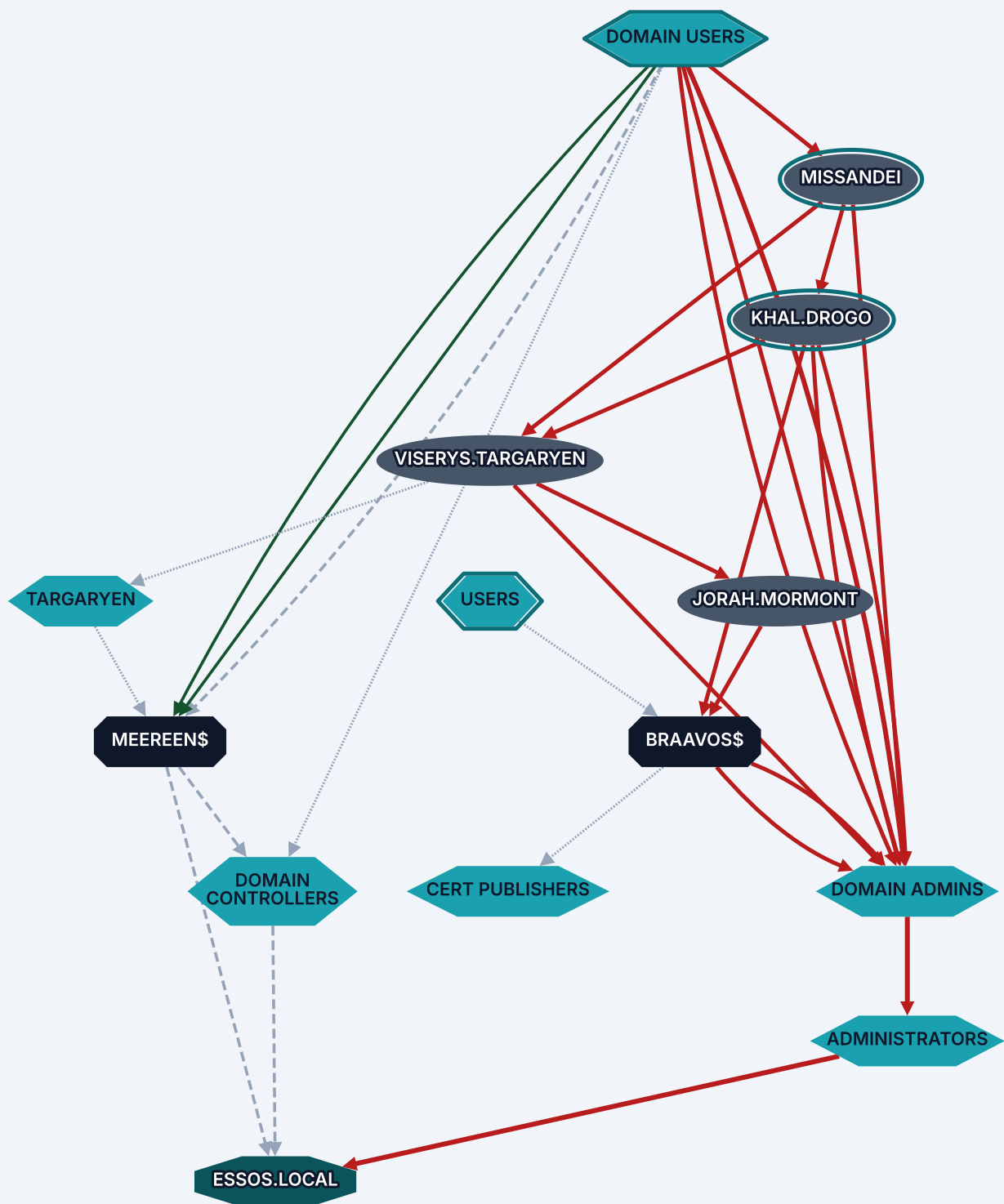
2 NOT ASSESSED

4 HARDENING OBSERVED

30 PATHS

19 TO FULL DOMAIN COMPROMISE

– Attack surface map · essos.local · all 30 routes, collapsed onto shared nodes



HOW TO READ THIS MAP

- User account
- ◆ Group — privilege held by membership
- Computer or machine account
- Domain
- ◻ Ringed — where the route starts
- Validated — executed end to end
- - - - - Not assessed
- Identified by configuration analysis
- Closed by configuration already in place

TECHNIQUES BEHIND THESE ROUTES

The routes below are built from 15 recurring techniques. Each is explained here once, worked through on the first place it appears, together with the change that closes it wherever it appears. Every route then names its own principals and targets step by step and refers back here for the mechanism. The list is ordered by how many steps depend on each technique, so fixing the one at the top removes the most routes.

REPLICATE DIRECTORY SECRETS (DCSYNC) 21 STEPS

ADMINISTRATORS@ESSOS.LOCAL holds the Replicating Directory Changes and Replicating Directory Changes All extended rights on the domain, meaning it can pull password hashes for any account via the DRSUAPI protocol (DCSync). Extracting the krbtgt hash yields persistent golden-ticket capability and full domain compromise.

REMEDiation

- Identify all principals with Replicating Directory Changes All permission using LDAP ACL enumeration and remove unnecessary grants
- Restrict replication rights to Domain Controllers and authorised sync accounts only (e.g., Azure AD Connect, specific backup solutions)
- Enable audit logging for directory service replication events (Event ID 4662) and alert on replication requests from non-DC hosts
- Rotate the KRBtgt password twice to invalidate any Golden Tickets that may have been issued before remediation

GROUP MEMBERSHIP (MEMBEROF) 20 STEPS

DOMAIN ADMINS@ESSOS.LOCAL is a direct or nested member of ADMINISTRATORS@ESSOS.LOCAL. All privileges held by ADMINISTRATORS@ESSOS.LOCAL, including any onward attack-path edges, are inherited by DOMAIN ADMINS@ESSOS.LOCAL.

FULL CONTROL OF THE TARGET OBJECT (GENERICALL) 18 STEPS

GenericAll grants user MISSANDEI@ESSOS.LOCAL full read and write control over user KHAL.DROGO@ESSOS.LOCAL. This allows the source to reset the target's password, add Shadow Credentials (msDS-KeyCredentialLink), set a Service Principal Name to enable Kerberoasting, or write a logon script, any of which results in complete compromise of KHAL.DROGO@ESSOS.LOCAL.

REMEDiation

- Grant back only the rights the delegation actually needs, never full control. GenericAll carries password reset, key-credential write, servicePrincipalName write and script-path write in one ACE, so any one of them left in place restores the takeover — which is why narrowing it is the fix and auditing it is not. Use the Delegation of Control wizard, or a scoped ACE such as `dscls "<targetDN>" /G "<DOMAIN>\<helpdeskGroup>:CA;Reset Password"` when password reset is genuinely required.
- Confirm no other principal holds equivalent control over the same object: `(Get-Acl "AD:\<targetDN>").Access | Where-Object { \$\_.ActiveDirectoryRights -match 'GenericAll|WriteDACL|WriteOwner' -and \$\_.AccessControlType -eq 'Allow' }`. Anything returned other than Domain Admins, Enterprise Admins or SYSTEM is the same finding under a different principal.
- Audit the change: Event ID 5136 records the modified access control list on the object, and Event ID 4662 records the object access itself. Both require DS Access auditing to be enabled on the container.

MODIFY THE TARGET OBJECT (GENERICWRITE) 16 STEPS

GenericWrite gives user VISERY.S.TARGARYEN@ESSOS.LOCAL the ability to modify most attributes of user JORAH.MORMONT@ESSOS.LOCAL. Typical abuse paths include writing msDS-KeyCredentialLink (Shadow Credentials) to obtain a PKINIT certificate, setting a servicePrincipalName to enable Kerberoasting, or modifying scriptPath / msDS-AllowedToActOnBehalfOfOtherIdentity. Any of these leads to full compromise of JORAH.MORMONT@ESSOS.LOCAL.

REMEDiation

- Grant back only the specific attributes the delegation needs, rather than write access to the object. GenericWrite is a takeover because three of the attributes it covers each hand over the account on their own — msDS-KeyCredentialLink (a certificate the account can then authenticate with), servicePrincipalName (which exposes the account's password hash to offline cracking), and msDS-AllowedToActOnBehalfOfOtherIdentity (which lets another host impersonate any user to this one). A scoped grant such as `dscls "<targetDN>" /G "<DOMAIN>\<group>:WP;description"` gives the delegation its attribute and none of those.
- Sweep for the same exposure elsewhere: `Get-ADObject -LDAPFilter '(msDS-KeyCredentialLink=\*)' -Properties msDS-KeyCredentialLink | Select-Object DistinguishedName` lists every object carrying a key credential, which on a domain that does not use Windows Hello for Business should be close to empty.
- Audit the change: Event ID 5136 records the modified access control list and any subsequent write to msDS-KeyCredentialLink or servicePrincipalName on the object. It requires DS Access auditing to be enabled on the container.

PRE-AUTHENTICATION-LESS CREDENTIAL THEFT (ASREPROASTING) 13 STEPS

ASREPROasting targets accounts, in this path MISSANDEI@ESSOS.LOCAL, that have Kerberos pre-authentication disabled (DONT_REQ_PREAUTH flag). Any unauthenticated attacker (including DOMAIN USERS@ESSOS.LOCAL) can request an AS-REP message encrypted with the account's password-derived key and crack it offline. Successful cracking yields full credentials for MISSANDEI@ESSOS.LOCAL.

REMEDiation

- Enable Kerberos pre-authentication for MISSANDEI@ESSOS.LOCAL (clear DONT_REQ_PREAUTH in userAccountControl).
- Enforce strong passwords on accounts that must keep pre-auth disabled.
- Monitor Event ID 4768 with pre-authentication type 0 for anomalous requests.

EXTRACT LSA SECRETS (DUMPLSA) 12 STEPS

DumpLSA: With local administrator or SYSTEM access, an attacker could extract credential material from the host's protected credential stores, which would expose reusable secrets for BRAAVOS\$@ESSOS.LOCAL if this step were executed. This step was identified through configuration analysis and was not carried out during the assessment.

READ THE LOCAL ADMINISTRATOR PASSWORD (READLAPSPASSWORD) 10 STEPS

The ReadLAPSPassword edge means JORAH.MORMONT@ESSOS.LOCAL has the Control Access right on the ms-Mcs-AdmPwd (or ms-LAPS-Password) attribute of BRAAVOS\$@ESSOS.LOCAL. JORAH.MORMONT@ESSOS.LOCAL simply queries the attribute via LDAP to retrieve the local Administrator password in cleartext and pivots to BRAAVOS\$@ESSOS.LOCAL.

REMEDIATION

- Remove the Control Access ACE on ms-Mcs-AdmPwd / ms-LAPS-Password from JORAH.MORMONT@ESSOS.LOCAL on BRAAVOS\$@ESSOS.LOCAL.
- Audit LDAP reads of ms-LAPS-Password via Event ID 4662 with the LAPS GUID.

CERTIFICATE AUTHORITY ADMINISTRATION ABUSE (ADCS ESC7) 5 STEPS

This step indicates BRAAVOS\$@ESSOS.LOCAL can perform 'ADCS ESC7' against DOMAIN ADMIN\$@ESSOS.LOCAL, enabling further escalation.

REMEDIATION

- Restrict Manage CA and Manage Certificates permissions to only authorised PKI administrators
- Enforce separation of duties: the same account should not hold both Manage CA and Manage Certificates permissions
- Regularly audit CA permission assignments using certutil -cainfo or the CA management MMC

CERTIFICATE INFRASTRUCTURE TAKEOVER (ADCS ESC5) 5 STEPS

AD CS ESC5 (Vulnerable PKI Object Access Control): BRAAVOS\$@ESSOS.LOCAL holds write or control rights over a certification-authority object beyond the certificate templates — the CA computer object, the Enrollment Services container, or the NTAuthCertificates store on DOMAIN ADMIN\$@ESSOS.LOCAL. That control lets an attacker take over the CA itself and extract its private key, then forge authentication certificates offline for any domain identity with arbitrary validity periods. A forged certificate is never submitted to the CA, so it has no request ID, is absent from the CA database, and survives domain-wide password resets — it continues to work until the CA certificate itself is revoked and removed from the NTAuth store. Every certificate ever issued by that CA must then be considered compromised, and full remediation requires deploying a new CA with its key protected in a hardware security module and re-enrolling all affected certificates — a full PKI rebuild.

REMEDIATION

- Audit ACLs on the CA computer object, Certification Authority object, and the NTAuthCertificates container in AD
- Restrict write access to CA infrastructure objects to only PKI administrators and Enterprise Admins
- Conduct a full PKI health review to identify additional CA-level exposure

CERTIFICATE MAPPING ABUSE (ADCS ESC9) 4 STEPS

ADCS ESC9: A certificate template accessible to MISSANDEI@ESSOS.LOCAL is configured with CT_FLAG_NO_SECURITY_EXTENSION, omitting the szOID_NTDS_CA_SECURITY_EXT SID binding from issued certificates. Without this extension, certificate-to-account mapping relies on UPN matching rather than cryptographic SID identity. MISSANDEI@ESSOS.LOCAL can temporarily modify a controlled account's UPN to match a privileged user's UPN, enroll for a certificate during that window, restore the original UPN, and then authenticate as the privileged user using the issued certificate. This bypasses KB5014754 strong mapping protections when the security extension is absent from the template.

REMEDIATION

- Remove the CT_FLAG_NO_SECURITY_EXTENSION flag from affected templates
- Enforce strong certificate mapping by applying KB5014754 and configuring the CertificateMappingMethods registry key
- Restrict write access to user UPN attributes to authorised administrators only

CREDENTIAL RELAY TO DELEGATION (NTLMV1 RELAY → RBCD) 2 STEPS

NTLMv1 Relay → RBCD: DOMAIN USERS@ESSOS.LOCAL coerces MEEREEN\$@ESSOS.LOCAL to authenticate, relays that NTLMv1 authentication to a domain controller, writes resource-based constrained delegation, and obtains local administrator access on MEEREEN\$@ESSOS.LOCAL via S4U. A successful relay grants local administrator access on the target host. Attack surface reduced: single DC — self-relay reflection-mitigated. ADscan observed this avenue is closed by your environment's configuration and it is not presently exploitable.

REMEDIATION

- Disable NTLMv1 (LmCompatibilityLevel >= 3) across the estate via GPO
- Enforce LDAP signing and channel binding on Domain Controllers
- Remove or harden authentication-coercion vectors (PrinterBug, PetitPotam, DFSCoerce)
- Restrict ms-DS-MachineAccountQuota to remove the attacker's delegate creation path

CREDENTIAL RELAY TO SHADOW CREDENTIALS (NTLMV1 RELAY → SHADOW CREDENTIALS) 2 STEPS

NTLMv1 Relay → Shadow Credentials: DOMAIN USERS@ESSOS.LOCAL coerces MEEREEN\$@ESSOS.LOCAL, relays its NTLMv1 authentication to a domain controller, writes a key credential, and recovers the MEEREEN\$@ESSOS.LOCAL machine account NT hash via PKINIT. A successful relay yields the target computer account's own credential. Attack surface reduced: single DC — self-relay reflection-mitigated. ADscan observed this avenue is closed by your environment's configuration and it is not presently exploitable.

REMEDIATION

- Disable NTLMv1 (LmCompatibilityLevel >= 3) across the estate via GPO
- Enforce LDAP signing and channel binding on Domain Controllers
- Harden ADCS/PKINIT enrollment and audit msDS-KeyCredentialLink writes
- Remove or harden authentication-coercion vectors

LOCAL ADMINISTRATOR ACCESS (ADMINTO) 2 STEPS

AdminTo: KHAL.DROGO@ESSOS.LOCAL has local administrator access on BRAAVOS\$@ESSOS.LOCAL. Local administrator rights allow an attacker to: execute code remotely via SMB/PsExec/WMI/WinRM; dump credential material from LSASS memory (recovering domain credentials of any logged-on user); extract secrets from LSA and DPAPI stores; and pivot further using recovered credentials. In environments without LAPS, shared local admin passwords make this a one-to-many pivot across all machines with the same credential.

OFFLINE NTLMV1 CREDENTIAL RECOVERY (NTLMV1 OFFLINE CRACK) 2 STEPS

NTLMv1 Offline Crack: DOMAIN USERS@ESSOS.LOCAL coerces MEEREEN\$@ESSOS.LOCAL, captures its NTLMv1 response, and recovers the MEEREEN\$@ESSOS.LOCAL machine account NT hash offline via precomputed DES rainbow tables (NetNTLMv1's DES-based response over a known challenge is fully reversible this way, not a brute-force crack). The most universal NTLMv1 avenue — independent of relay viability, LDAP signing, channel binding, ADCS, or DC count. A successful offline crack yields the machine account's credential. This step was identified from the environment's configuration and was not exercised during this engagement.

REMEDIATION

- Disable NTLMv1 (LmCompatibilityLevel >= 3) across the estate via GPO
- Remove or harden authentication-coercion vectors (PrinterBug, PetitPotam, DFSCoerce)
- Note that LDAP signing / channel binding do NOT mitigate the offline crack — only NTLMv1 removal does
- Monitor for NTLMv1 authentication (Event ID 4624, package NTLM V1) and coercion-induced auth (4768/4769)

REMOTE DESKTOP ACCESS (CANRDP) 2 STEPS

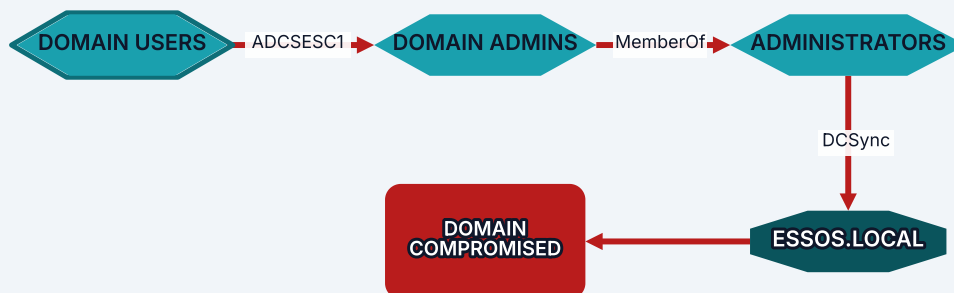
CanRDP: TARGARYEN@ESSOS.LOCAL can initiate an RDP session on MEEREEN\$@ESSOS.LOCAL. Remote Desktop access provides an interactive graphical session on the target machine. An attacker with RDP access can: extract credentials from memory (especially if a privileged user is already logged on); install persistence mechanisms; pivot to other network segments accessible from MEEREEN\$@ESSOS.LOCAL; or abuse services running in the session. RDP sessions generate logon event 4624 (type 10) and may be detectable via session recording if configured.

DOMAIN USERS → DOMAIN COMPROMISED

FULL DOMAIN COMPROMISE

EXPLOITED

Starting from DOMAIN USERS@ESSOS.LOCAL, an attacker can reach ESSOS.LOCAL in 3 steps. The path chains ADCS ESC1, MemberOf, and DCSync. This attack path was successfully exploited during active testing.



◆ Group — privilege held by membership
 ◆ Domain
 ■ Outcome — full domain compromise
 ■ Outcome — Tier 0 reached, control not proven
■ Outcome — advances toward Tier 0, does not reach it
■ Outcome — closed by configuration already in place
 Ringed — where the route starts
 Named inside a box — a step performed on that object, not a move to another
— Validated — executed end to end

The same shapes and lines are used on every route diagram and on the attack surface map.

STEP-BY-STEP BREAKDOWN

1. CERTIFICATE TEMPLATE PRIVILEGE ESCALATION (ADCS ESC1) CONFIRMED

ADCS ESC1: the certificate template ESC1 allows group DOMAIN USERS@ESSOS.LOCAL to request certificates where the subject alternative name (SAN) is supplied by the requester. By specifying a privileged user (e.g. Domain Admin) in the SAN, the attacker obtains a certificate that authenticates as that user via PKINIT, fully compromising DOMAIN ADMINS@ESSOS.LOCAL.

REMEDIATION

- Disable 'Enrollee supplies subject' on template ESC1, or require manager approval for enrollment.
- Restrict enrollment permissions on ESC1 to authorized identities only.
- Apply the KB5014754 enforcement mode on the CA to block weak SAN mapping.

2. GROUP MEMBERSHIP (MEMBEROF) STRUCTURAL

DOMAIN ADMINS@ESSOS.LOCAL is a direct or nested member of ADMINISTRATORS@ESSOS.LOCAL. All privileges held by ADMINISTRATORS@ESSOS.LOCAL, including any onward attack-path edges, are inherited by DOMAIN ADMINS@ESSOS.LOCAL.

REMEDIATION

- No change is required at this step: DOMAIN ADMINS@ESSOS.LOCAL is part of the domain's Tier 0 control plane, so this relationship is how Active Directory is built rather than a misconfiguration. When this step sits inside a longer chain, the exposure belongs to the earlier step that lets a lower-privileged principal take control of DOMAIN ADMINS@ESSOS.LOCAL. Remediate there.

3. REPLICATE DIRECTORY SECRETS (DCSYNC) CONFIRMED

ADMINISTRATORS@ESSOS.LOCAL holds the Replicating Directory Changes and Replicating Directory Changes All extended rights on the domain, meaning it can pull password hashes for any account via the DRSUAPI protocol (DCSync). Extracting the krbtgt hash yields persistent golden-ticket capability and full domain compromise.

REMEDIATION

- No change is required at this step: ADMINISTRATORS@ESSOS.LOCAL is part of the domain's Tier 0 control plane, so this relationship is how Active Directory is built rather than a misconfiguration. When this step sits inside a longer chain, the exposure belongs to the earlier step that lets a lower-privileged principal take control of ADMINISTRATORS@ESSOS.LOCAL. Remediate there.

○ DOMAIN COMPROMISED

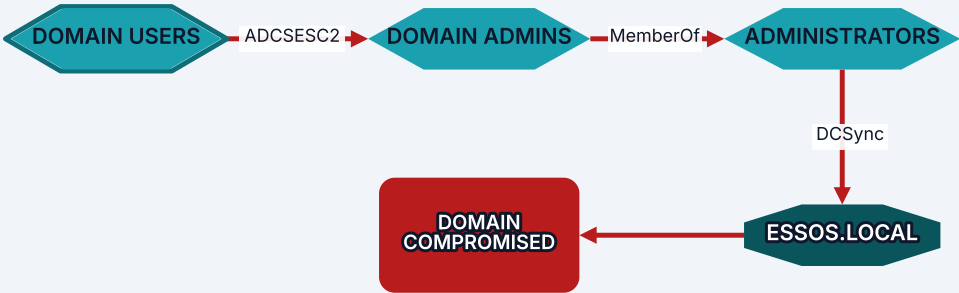
TERMINUS: THIS PATH ENDS IN FULL DOMAIN COMPROMISE.

DOMAIN USERS → DOMAIN COMPROMISED

FULL DOMAIN COMPROMISE

PARTIALLY VALIDATED

Starting from DOMAIN USERS@ESSOS.LOCAL, an attacker can reach ESSOS.LOCAL in 3 steps. The path chains ADCS ESC2, MemberOf, and DCSync. This attack path had part of its chain validated by live execution, but was not run end-to-end.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. CERTIFICATE SERVICES PRIVILEGE ESCALATION (ADCS ESC2) THEORETICAL

ADCS ESC2: DOMAIN USERS@ESSOS.LOCAL can enroll in a certificate template configured with the Any Purpose ECU or with no ECU restrictions at all. A certificate with Any Purpose ECU is valid for all operations including client authentication, code signing, and server authentication. While the issued certificate carries the enrolling user's own identity, it can be used as an enrollment agent certificate to request certificates on behalf of other users (chaining into ESC3-style abuse), bypassing template ECU restrictions that would normally prevent impersonation. Combined with a permissive enrollment agent configuration, this provides a path to full domain identity impersonation.

REMEDIATION

- Remove the Any Purpose ECU from affected templates and restrict to only the specific EKUs required for the intended use case
- Add explicit EKUs that limit certificate usage scope
- Restrict enrollment permissions to only the principals that legitimately need this certificate type

2. GROUP MEMBERSHIP (MEMBEROF) STRUCTURAL

Group membership: DOMAIN ADMIN@ESSOS.LOCAL is a member of ADMINISTRATORS@ESSOS.LOCAL and inherits its privileges.

How this technique works: Group Membership (MemberOf), in Techniques behind these routes.

3. REPLICATE DIRECTORY SECRETS (DCSYNC) CONFIRMED

DCSync: ADMINISTRATORS@ESSOS.LOCAL can replicate secrets from the domain and extract the krbtgt hash.

How this technique works: Replicate Directory Secrets (DCSync), in Techniques behind these routes.

○ DOMAIN COMPROMISED

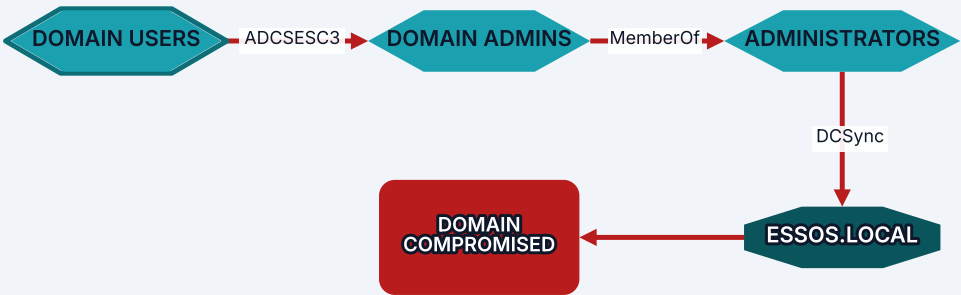
TERMINUS: THIS PATH ENDS IN FULL DOMAIN COMPROMISE.

DOMAIN USERS → DOMAIN COMPROMISED

FULL DOMAIN COMPROMISE

PARTIALLY VALIDATED

Starting from DOMAIN USERS@ESSOS.LOCAL, an attacker can reach ESSOS.LOCAL in 3 steps. The path chains ADCS ESC3, MemberOf, and DCSync. This attack path had part of its chain validated by live execution, but was not run end-to-end.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. CERTIFICATE REQUEST-AGENT ESCALATION (ADCS ESC3) THEORETICAL

ADCS ESC3: DOMAIN USERS@ESSOS.LOCAL holds enrollment rights on a template with the Certificate Request Agent EKU, enabling on-behalf-of certificate requests. Using the obtained enrollment agent certificate, DOMAIN USERS@ESSOS.LOCAL can request certificates from a second template on behalf of any domain user — including Domain Administrators — without knowing their credentials. This two-stage abuse chain (obtain agent cert, then request on-behalf-of cert) enables complete identity impersonation. Both certificate requests appear legitimate in CA audit logs, making this a stealthy path to domain-level authentication bypass.

REMEDIATION

- Restrict the enrollment agent template to only authorised Certificate Managers and enrollment agent accounts
- Configure Enrollment Agent Restrictions on the CA to limit which templates and subjects enrollment agents can request on behalf of others
- Audit all principals with enrollment rights on templates with the Certificate Request Agent EKU

2. GROUP MEMBERSHIP (MEMBEROF) STRUCTURAL

Group membership: DOMAIN ADMIN@ESSOS.LOCAL is a member of ADMINISTRATORS@ESSOS.LOCAL and inherits its privileges.

How this technique works: Group Membership (MemberOf), in Techniques behind these routes.

3. REPLICATE DIRECTORY SECRETS (DCSYNC) CONFIRMED

DCSync: ADMINISTRATORS@ESSOS.LOCAL can replicate secrets from the domain and extract the krbtgt hash.

How this technique works: Replicate Directory Secrets (DCSync), in Techniques behind these routes.

○ DOMAIN COMPROMISED

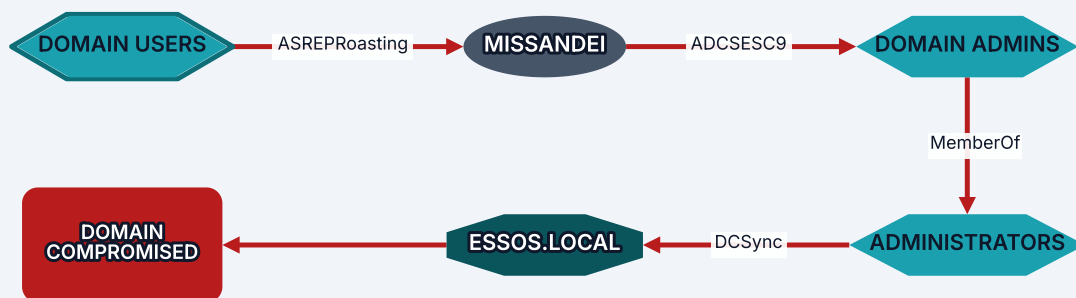
TERMINUS: THIS PATH ENDS IN FULL DOMAIN COMPROMISE.

DOMAIN USERS → DOMAIN COMPROMISED

FULL DOMAIN COMPROMISE

PARTIALLY VALIDATED

Starting from DOMAIN USERS@ESSOS.LOCAL, an attacker can reach ESSOS.LOCAL in 4 steps. The path chains ASREPRoasting, ADCSESC9, MemberOf, and DCSync. This attack path had part of its chain validated by live execution, but was not run end-to-end.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. PRE-AUTHENTICATION-LESS CREDENTIAL THEFT (ASREPROASTING) THEORETICAL

ASREPRoasting targets accounts, in this path MISSANDEI@ESSOS.LOCAL, that have Kerberos pre-authentication disabled (DONT_REQ_PREAUTH flag). Any unauthenticated attacker (including DOMAIN USERS@ESSOS.LOCAL) can request an AS-REP message encrypted with the account's password-derived key and crack it offline. Successful cracking yields full credentials for MISSANDEI@ESSOS.LOCAL.

2. CERTIFICATE MAPPING ABUSE (ADCS ESC9) THEORETICAL

ADCS ESC9: A certificate template accessible to MISSANDEI@ESSOS.LOCAL is configured with CT_FLAG_NO_SECURITY_EXTENSION, omitting the szOID_NTDS_CA_SECURITY_EXT SID binding from issued certificates. Without this extension, certificate-to-account mapping relies on UPN matching rather than cryptographic SID identity. MISSANDEI@ESSOS.LOCAL can temporarily modify a controlled account's UPN to match a privileged user's UPN, enroll for a certificate during that window, restore the original UPN, and then authenticate as the privileged user using the issued certificate. This bypasses KB5014754 strong mapping protections when the security extension is absent from the template.

3. GROUP MEMBERSHIP (MEMBEROF) STRUCTURAL

Group membership: DOMAIN ADMINs@ESSOS.LOCAL is a member of ADMINISTRATORS@ESSOS.LOCAL and inherits its privileges.

How this technique works: Group Membership (MemberOf), in Techniques behind these routes.

4. REPLICATE DIRECTORY SECRETS (DCSYNC) CONFIRMED

DCSync: ADMINISTRATORS@ESSOS.LOCAL can replicate secrets from the domain and extract the krbtgt hash.

How this technique works: Replicate Directory Secrets (DCSync), in Techniques behind these routes.

○ DOMAIN COMPROMISED

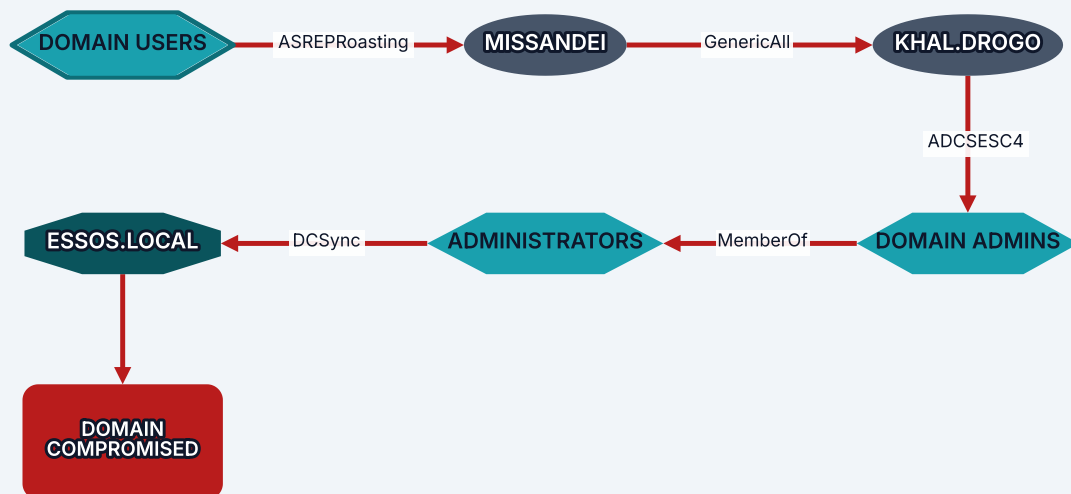
TERMINUS: THIS PATH ENDS IN FULL DOMAIN COMPROMISE.

DOMAIN USERS → DOMAIN COMPROMISED

FULL DOMAIN COMPROMISE

PARTIALLY VALIDATED

Starting from DOMAIN USERS@ESSOS.LOCAL, an attacker can reach ESSOS.LOCAL in 5 steps. The path chains ASREPRoasting, GenericAll, ADCSESC4, MemberOf, and DCSync. This attack path had part of its chain validated by live execution, but was not run end-to-end.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. PRE-AUTHENTICATION-LESS CREDENTIAL THEFT (ASREPROASTING) THEORETICAL

ASREPRoasting: MISSANDEI@ESSOS.LOCAL has pre-authentication disabled, so DOMAIN USERS@ESSOS.LOCAL can request an AS-REP and crack it offline.

How this technique works: Pre-Authentication-less Credential Theft (ASREPRoasting), in Techniques behind these routes.

2. FULL CONTROL OF THE TARGET OBJECT (GENERICALL) THEORETICAL

GenericAll grants user MISSANDEI@ESSOS.LOCAL full read and write control over user KHAL.DROGO@ESSOS.LOCAL. This allows the source to reset the target's password, add Shadow Credentials (msDS-KeyCredentialLink), set a Service Principal Name to enable Kerberoasting, or write a logon script, any of which results in complete compromise of KHAL.DROGO@ESSOS.LOCAL.

REMEDIATION

- Remove the GenericAll ACE that MISSANDEI@ESSOS.LOCAL holds over KHAL.DROGO@ESSOS.LOCAL. Resolve the object's distinguished name with ``Get-ADObject -LDAPFilter '(sAMAccountName=<target>)'``, list what MISSANDEI@ESSOS.LOCAL currently holds on it with ``(Get-Acl "AD:\<targetDN>").Access | Where-Object IdentityReference -like '*<principal>*'``, then delete those entries with ``dscls "<targetDN>" /R "<DOMAIN>\<principal>"``. Before: the entry reads `ActiveDirectoryRights=GenericAll, AccessControlType=Allow`. After: the same query returns nothing for that principal.
- Add KHAL.DROGO@ESSOS.LOCAL to Protected Users, and keep Tier 0 accounts out of the organisational units that ordinary delegation applies to, so a future broad grant cannot reach them by inheritance.

3. CERTIFICATE TEMPLATE TAKEOVER (ADCS ESC4) THEORETICAL

ADCS ESC4: KHAL.DROGO@ESSOS.LOCAL has write access (GenericWrite, WriteDACL, WriteOwner, or Owns) to the certificate template object DOMAIN ADMIN@ESSOS.LOCAL in Active Directory. This allows KHAL.DROGO@ESSOS.LOCAL to temporarily modify the template configuration to introduce ESC1-class vulnerabilities — enabling SAN specification, removing EKU restrictions, or disabling manager approval — request a certificate impersonating a Domain Administrator, then revert the changes. The exploitation window is brief and may not trigger template misconfiguration monitoring, making this a stealthy path to domain compromise that leaves no persistent evidence.

REMEDIATION

- Audit ACLs on all certificate template objects in the Configuration naming context and remove unnecessary write permissions from non-admin principals
- Ensure only Enterprise Admins, Domain Admins, and PKI administrators hold write permissions on template objects
- Enable auditing on template object modifications to detect unauthorised changes

4. GROUP MEMBERSHIP (MEMBEROF) STRUCTURAL

Group membership: DOMAIN ADMIN@ESSOS.LOCAL is a member of ADMINISTRATORS@ESSOS.LOCAL and inherits its privileges.

How this technique works: Group Membership (MemberOf), in Techniques behind these routes.

5. REPLICATE DIRECTORY SECRETS (DCSYNC) CONFIRMED

DCSync: ADMINISTRATORS@ESSOS.LOCAL can replicate secrets from the domain and extract the krbtgt hash.

How this technique works: Replicate Directory Secrets (DCSync), in Techniques behind these routes.

○ DOMAIN COMPROMISED

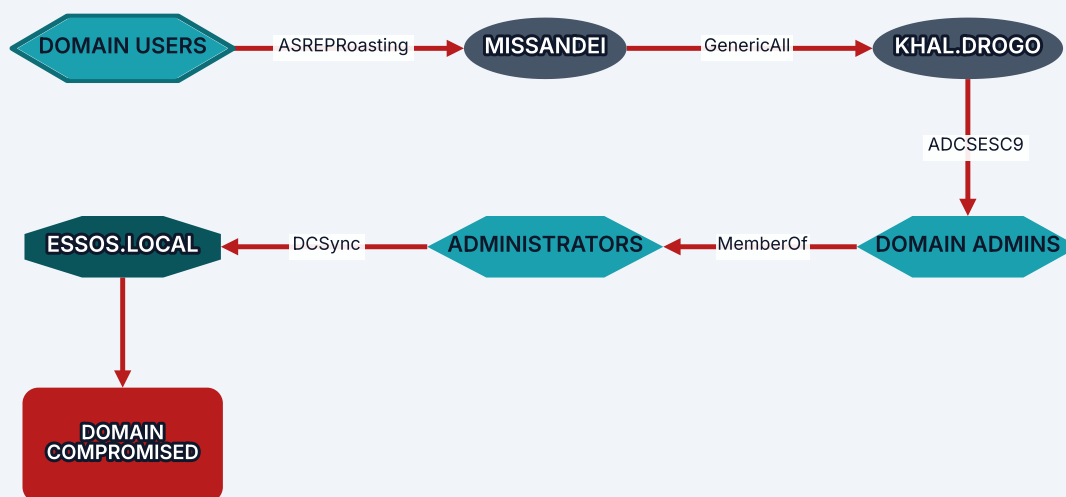
TERMINUS: THIS PATH ENDS IN FULL DOMAIN COMPROMISE.

DOMAIN USERS → DOMAIN COMPROMISED

FULL DOMAIN COMPROMISE

PARTIALLY VALIDATED

Starting from DOMAIN USERS@ESSOS.LOCAL, an attacker can reach ESSOS.LOCAL in 5 steps. The path chains ASREProasting, GenericAll, ADCS ESC9, MemberOf, and DCSync. This attack path had part of its chain validated by live execution, but was not run end-to-end.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. PRE-AUTHENTICATION-LESS CREDENTIAL THEFT (ASREPROASTING)

THEORETICAL

ASREPROasting: MISSANDEI@ESSOS.LOCAL has pre-authentication disabled, so DOMAIN USERS@ESSOS.LOCAL can request an AS-REP and crack it offline.

How this technique works: Pre-Authentication-less Credential Theft (ASREPROasting), in Techniques behind these routes.

2. FULL CONTROL OF THE TARGET OBJECT (GENERICALL)

THEORETICAL

GenericAll: user MISSANDEI@ESSOS.LOCAL has full control over user KHAL.DROGO@ESSOS.LOCAL.

How this technique works: Full Control of the Target Object (GenericAll), in Techniques behind these routes.

3. CERTIFICATE MAPPING ABUSE (ADCS ESC9)

THEORETICAL

ADCS ESC9: A certificate template accessible to KHAL.DROGO@ESSOS.LOCAL is configured with CT_FLAG_NO_SECURITY_EXTENSION, omitting the szOID_NTDS_CA_SECURITY_EXT SID binding from issued certificates.

How this technique works: Certificate Mapping Abuse (ADCS ESC9), in Techniques behind these routes.

4. GROUP MEMBERSHIP (MEMBEROF)

STRUCTURAL

Group membership: DOMAIN ADMINS@ESSOS.LOCAL is a member of ADMINISTRATORS@ESSOS.LOCAL and inherits its privileges.

How this technique works: Group Membership (MemberOf), in Techniques behind these routes.

5. REPLICATE DIRECTORY SECRETS (DCSYNC)

CONFIRMED

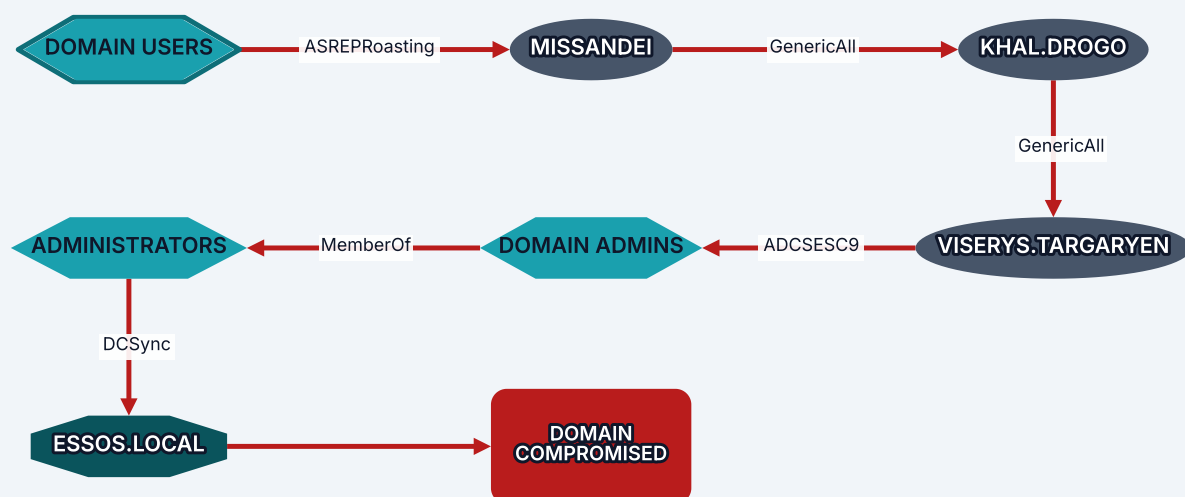
DCSync: ADMINISTRATORS@ESSOS.LOCAL can replicate secrets from the domain and extract the krbtgt hash.

How this technique works: Replicate Directory Secrets (DCSync), in Techniques behind these routes.

○ DOMAIN COMPROMISED

TERMINUS: THIS PATH ENDS IN FULL DOMAIN COMPROMISE.

Starting from DOMAIN USERS@ESSOS.LOCAL, an attacker can reach ESSOS.LOCAL in 6 steps. The path chains ASREPRoasting, GenericAll, ADCS ESC9, MemberOf, and DCSync. This attack path had part of its chain validated by live execution, but was not run end-to-end.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. PRE-AUTHENTICATION-LESS CREDENTIAL THEFT (ASREPROASTING)

THEORETICAL

ASREPRoasting: MISSANDEI@ESSOS.LOCAL has pre-authentication disabled, so DOMAIN USERS@ESSOS.LOCAL can request an AS-REP and crack it offline.

How this technique works: Pre-Authentication-less Credential Theft (ASREPRoasting), in Techniques behind these routes.

2. FULL CONTROL OF THE TARGET OBJECT (GENERICALL)

THEORETICAL

GenericAll: user MISSANDEI@ESSOS.LOCAL has full control over user KHAL.DROGO@ESSOS.LOCAL.

How this technique works: Full Control of the Target Object (GenericAll), in Techniques behind these routes.

3. FULL CONTROL OF THE TARGET OBJECT (GENERICALL)

THEORETICAL

GenericAll: user KHAL.DROGO@ESSOS.LOCAL has full control over user VISERY.S.TARGARYEN@ESSOS.LOCAL.

REMEDIATION

- Remove the GenericAll ACE that KHAL.DROGO@ESSOS.LOCAL holds over VISERY.S.TARGARYEN@ESSOS.LOCAL. Resolve the object's distinguished name with 'Get-ADObject -LDAPFilter '(sAMAccountName=<target>)', list what KHAL.DROGO@ESSOS.LOCAL currently holds on it with '(Get-Acl "AD:\<targetDN>").Access | Where-Object IdentityReference -like '*<principal>*"', then delete those entries with 'dscls "<targetDN>" /R "<DOMAIN>\<principal>"'. Before: the entry reads ActiveDirectoryRights=GenericAll, AccessControlType=Allow. After: the same query returns nothing for that principal.
- Add VISERY.S.TARGARYEN@ESSOS.LOCAL to Protected Users, and keep Tier 0 accounts out of the organisational units that ordinary delegation applies to, so a future broad grant cannot reach them by inheritance.

How this technique works: Full Control of the Target Object (GenericAll), in Techniques behind these routes.

4. CERTIFICATE MAPPING ABUSE (ADCS ESC9)

THEORETICAL

ADCS ESC9: A certificate template accessible to VISERY.S.TARGARYEN@ESSOS.LOCAL is configured with CT_FLAG_NO_SECURITY_EXTENSION, omitting the sZOID_NTDS_CA_SECURITY_EXT SID binding from issued certificates.

How this technique works: Certificate Mapping Abuse (ADCS ESC9), in Techniques behind these routes.

5. GROUP MEMBERSHIP (MEMBEROF) STRUCTURAL

Group membership: DOMAIN ADMINS@ESSOS.LOCAL is a member of ADMINISTRATORS@ESSOS.LOCAL and inherits its privileges.

How this technique works: Group Membership (MemberOf), in Techniques behind these routes.

6. REPLICATE DIRECTORY SECRETS (DCSYNC) CONFIRMED

DCSync: ADMINISTRATORS@ESSOS.LOCAL can replicate secrets from the domain and extract the krbtgt hash.

How this technique works: Replicate Directory Secrets (DCSync), in Techniques behind these routes.

○ DOMAIN COMPROMISED

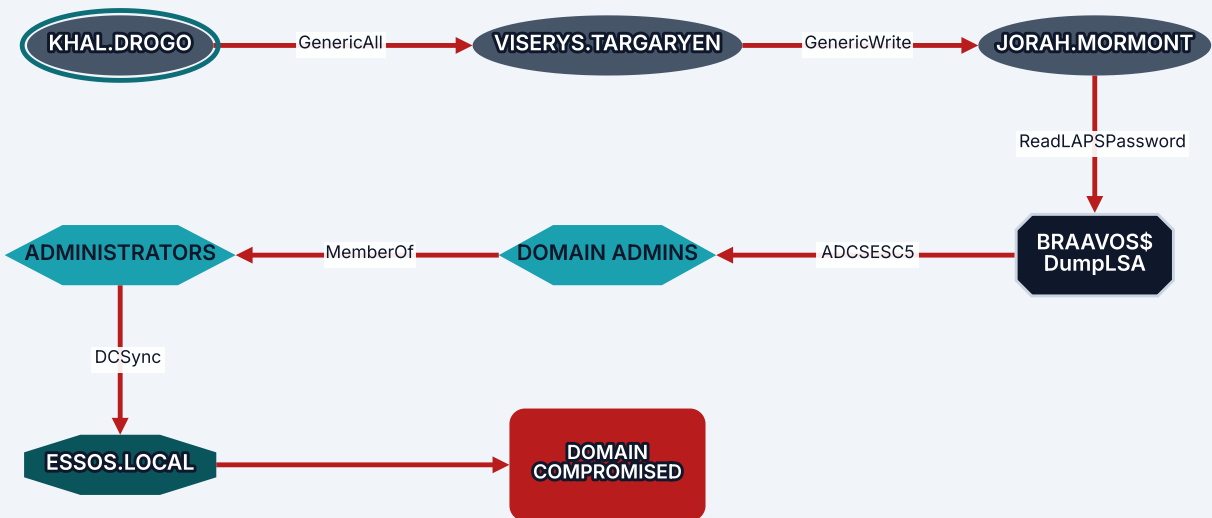
TERMINUS: THIS PATH ENDS IN FULL DOMAIN COMPROMISE.

KHAL.DROGO → DOMAIN COMPROMISED

FULL DOMAIN COMPROMISE

PARTIALLY VALIDATED

Starting from KHAL.DROGO@ESSOS.LOCAL, an attacker can reach ESSOS.LOCAL in 7 steps. The path chains GenericAll, GenericWrite, ReadLAPSPassword, DumpLSA, ADCS ESC5, MemberOf, and DCSync. This attack path had part of its chain validated by live execution, but was not run end-to-end.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. FULL CONTROL OF THE TARGET OBJECT (GENERICALL) THEORETICAL

GenericAll: user KHAL.DROGO@ESSOS.LOCAL has full control over user VISERY.S.TARGARYEN@ESSOS.LOCAL.

How this technique works: Full Control of the Target Object (GenericAll), in Techniques behind these routes.

2. MODIFY THE TARGET OBJECT (GENERICWRITE) THEORETICAL

GenericWrite gives user VISERY.S.TARGARYEN@ESSOS.LOCAL the ability to modify most attributes of user JORAH.MORMONT@ESSOS.LOCAL. Typical abuse paths include writing msDS-KeyCredentialLink (Shadow Credentials) to obtain a PKINIT certificate, setting a servicePrincipalName to enable Kerberoasting, or modifying scriptPath / msDS-AllowedToActOnBehalfOfOtherIdentity. Any of these leads to full compromise of JORAH.MORMONT@ESSOS.LOCAL.

REMEDIATION

- Remove the GenericWrite ACE that VISERY.S.TARGARYEN@ESSOS.LOCAL holds on JORAH.MORMONT@ESSOS.LOCAL. Resolve the object's distinguished name with 'Get-ADObject -LDAPFilter '(sAMAccountName=<target>)', list what VISERY.S.TARGARYEN@ESSOS.LOCAL currently holds on it with '(Get-Acl "AD:\<targetDN>").Access | Where-Object IdentityReference -like '*<principal>*', then delete those entries with 'dsacls "<targetDN>" /R "<DOMAIN>\<principal>". Before: the entry reads ActiveDirectoryRights=GenericWrite (or WriteProperty covering every attribute). After: the same query returns nothing for that principal.
- Clear anything already written through the ACE before removing it, or the takeover survives the fix. Check the three attributes on JORAH.MORMONT@ESSOS.LOCAL: 'Get-ADObject "<targetDN>" -Properties msDS-KeyCredentialLink, servicePrincipalName, msDS-AllowedToActOnBehalfOfOtherIdentity'. A key credential nobody deliberately enrolled, an unexpected service principal name, or a populated delegation attribute should be cleared with 'Set-ADObject "<targetDN>" -Clear <attribute>'.

3. READ THE LOCAL ADMINISTRATOR PASSWORD (READLAPSPASSWORD) THEORETICAL

The ReadLAPSPassword edge means JORAH.MORMONT@ESSOS.LOCAL has the Control Access right on the ms-Mcs-AdmPwd (or ms-LAPS-Password) attribute of BRAAVOS\$@ESSOS.LOCAL. JORAH.MORMONT@ESSOS.LOCAL simply queries the attribute via LDAP to retrieve the local Administrator password in cleartext and pivots to BRAAVOS\$@ESSOS.LOCAL.

4. EXTRACT LSA SECRETS (DUMPLSA) THEORETICAL

DumpLSA: With local administrator or SYSTEM access, an attacker could extract credential material from the host's protected credential stores, which would expose reusable secrets for BRAAVOS\$@ESSOS.LOCAL if this step were executed. This step was identified through configuration analysis and was not carried out during the assessment.

5. CERTIFICATE INFRASTRUCTURE TAKEOVER (ADCS ESC5) THEORETICAL

AD CS ESC5 (Vulnerable PKI Object Access Control): BRAAVOS\$@ESSOS.LOCAL holds write or control rights over a certification-authority object beyond the certificate templates — the CA computer object, the Enrollment Services container, or the NTAUTHCertificates store on DOMAIN ADMIN.S@ESSOS.LOCAL. That control lets an attacker take over the CA itself and extract its private key, then forge authentication certificates offline for any domain identity with arbitrary validity periods. A forged certificate is never submitted to the CA, so it has no request ID, is absent from the CA database, and survives domain-wide password resets — it continues to work until the CA certificate itself is revoked and removed from the NTAUTH store. Every certificate ever issued by that CA must then be considered compromised, and full remediation requires deploying a new CA with its key protected in a hardware security module and re-enrolling all affected certificates — a full PKI rebuild.

6. GROUP MEMBERSHIP (MEMBEROF) STRUCTURAL

Group membership: DOMAIN ADMIN.S@ESSOS.LOCAL is a member of ADMINISTRATORS@ESSOS.LOCAL and inherits its privileges.

How this technique works: Group Membership (MemberOf), in Techniques behind these routes.

7. REPLICATE DIRECTORY SECRETS (DCSYNC) CONFIRMED

DCSync: ADMINISTRATORS@ESSOS.LOCAL can replicate secrets from the domain and extract the krbtgt hash.

How this technique works: Replicate Directory Secrets (DCSync), in Techniques behind these routes.

○ DOMAIN COMPROMISED

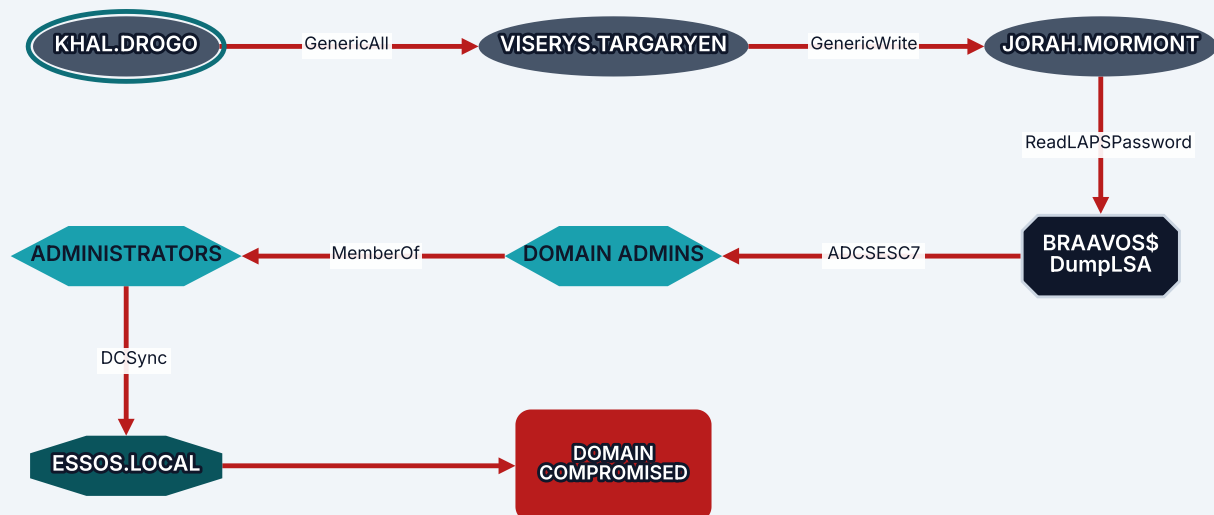
TERMINUS: THIS PATH ENDS IN FULL DOMAIN COMPROMISE.

KHAL.DROGO → DOMAIN COMPROMISED

FULL DOMAIN COMPROMISE

PARTIALLY VALIDATED

Starting from KHAL.DROGO@ESSOS.LOCAL, an attacker can reach ESSOS.LOCAL in 7 steps. The path chains GenericAll, GenericWrite, ReadLAPSPassword, DumpLSA, ADCS ESC7, MemberOf, and DCSync. This attack path had part of its chain validated by live execution, but was not run end-to-end.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. FULL CONTROL OF THE TARGET OBJECT (GENERICALL)

THEORETICAL

GenericAll: user KHAL.DROGO@ESSOS.LOCAL has full control over user VISERY.S.TARGARYEN@ESSOS.LOCAL.

How this technique works: Full Control of the Target Object (GenericAll), in Techniques behind these routes.

2. MODIFY THE TARGET OBJECT (GENERICWRITE)

THEORETICAL

GenericWrite: VISERY.S.TARGARYEN@ESSOS.LOCAL can modify most attributes of JORAH.MORMONT@ESSOS.LOCAL, enabling takeover via Shadow Credentials or SPN.

How this technique works: Modify the Target Object (GenericWrite), in Techniques behind these routes.

3. READ THE LOCAL ADMINISTRATOR PASSWORD (READLAPSPASSWORD)

THEORETICAL

ReadLAPSPassword: JORAH.MORMONT@ESSOS.LOCAL can read the local administrator password of BRAAVOS\$@ESSOS.LOCAL from AD.

How this technique works: Read the Local Administrator Password (ReadLAPSPassword), in Techniques behind these routes.

4. EXTRACT LSA SECRETS (DUMPLSA)

THEORETICAL

DumpLSA: With local administrator or SYSTEM access, an attacker could extract credential material from the host's protected credential stores, which would expose reusable secrets for BRAAVOS\$@ESSOS.LOCAL if this step were executed.

How this technique works: Extract LSA Secrets (DumpLSA), in Techniques behind these routes.

5. CERTIFICATE AUTHORITY ADMINISTRATION ABUSE (ADCS ESC7)

THEORETICAL

This step indicates BRAAVOS\$@ESSOS.LOCAL can perform 'ADCS ESC7' against DOMAIN ADMIN.S@ESSOS.LOCAL, enabling further escalation.

6. GROUP MEMBERSHIP (MEMBEROF)

STRUCTURAL

Group membership: DOMAIN ADMIN.S@ESSOS.LOCAL is a member of ADMINISTRATORS@ESSOS.LOCAL and inherits its privileges.

How this technique works: Group Membership (MemberOf), in Techniques behind these routes.

7. REPLICATE DIRECTORY SECRETS (DCSYNC) CONFIRMED

DCSync: ADMINISTRATORS@ESSOS.LOCAL can replicate secrets from the domain and extract the krbtgt hash.
How this technique works: Replicate Directory Secrets (DCSync), in Techniques behind these routes.

○ DOMAIN COMPROMISED

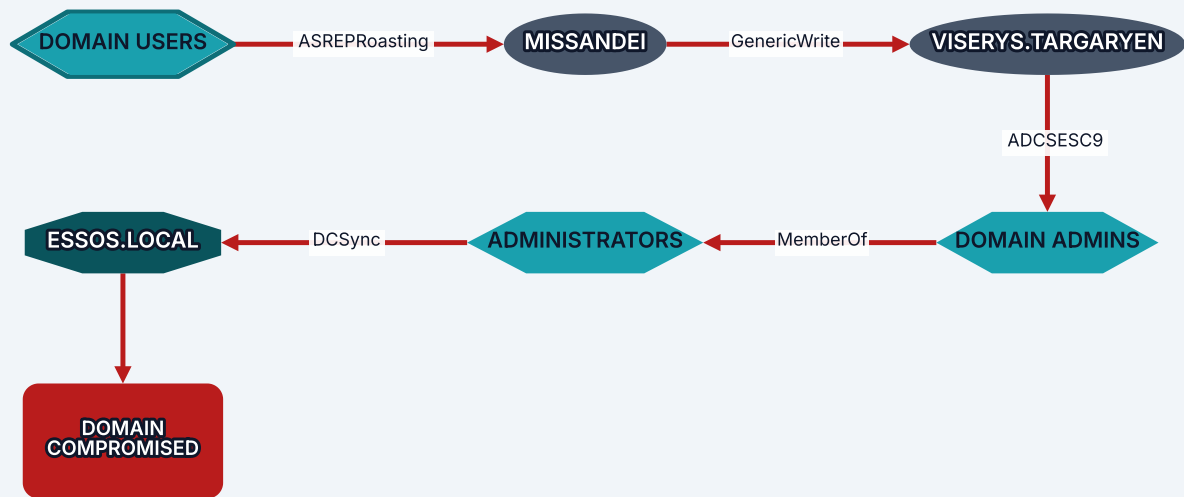
TERMINUS: THIS PATH ENDS IN FULL DOMAIN COMPROMISE.

DOMAIN USERS → DOMAIN COMPROMISED

FULL DOMAIN COMPROMISE

PARTIALLY VALIDATED

Starting from DOMAIN USERS@ESSOS.LOCAL, an attacker can reach ESSOS.LOCAL in 5 steps. The path chains ASREPRoasting, GenericWrite, ADCS ESC9, MemberOf, and DCSync. This attack path had part of its chain validated by live execution, but was not run end-to-end.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. PRE-AUTHENTICATION-LESS CREDENTIAL THEFT (ASREPROASTING) THEORETICAL

ASREPRoasting: MISSANDEI@ESSOS.LOCAL has pre-authentication disabled, so DOMAIN USERS@ESSOS.LOCAL can request an AS-REP and crack it offline.
How this technique works: Pre-Authentication-less Credential Theft (ASREPRoasting), in Techniques behind these routes.

2. MODIFY THE TARGET OBJECT (GENERICWRITE) THEORETICAL

GenericWrite: MISSANDEI@ESSOS.LOCAL can modify most attributes of VISERY.S.TARGARYEN@ESSOS.LOCAL, enabling takeover via Shadow Credentials or SPN.

REMIEDIATION

- Remove the GenericWrite ACE that MISSANDEI@ESSOS.LOCAL holds on VISERY.S.TARGARYEN@ESSOS.LOCAL. Resolve the object's distinguished name with `Get-ADObject -LDAPFilter '(sAMAccountName=<target>)'`, list what MISSANDEI@ESSOS.LOCAL currently holds on it with `(Get-Acl "AD:\<targetDN>").Access | Where-Object IdentityReference -like '\*<principal>\*'`, then delete those entries with `dscls "<targetDN>" /R "<DOMAIN>\<principal>"`. Before: the entry reads ActiveDirectoryRights=GenericWrite (or WriteProperty covering every attribute). After: the same query returns nothing for that principal.
- Clear anything already written through the ACE before removing it, or the takeover survives the fix. Check the three attributes on VISERY.S.TARGARYEN@ESSOS.LOCAL: `Get-ADObject "<targetDN>" -Properties msDS-KeyCredentialLink, servicePrincipalName, msDS-AllowedToActOnBehalfOfOtherIdentity`. A key credential nobody deliberately enrolled, an unexpected service principal name, or a populated delegation attribute should be cleared with `Set-ADObject "<targetDN>" -Clear <attribute>`.

How this technique works: Modify the Target Object (GenericWrite), in Techniques behind these routes.

3. CERTIFICATE MAPPING ABUSE (ADCS ESC9) THEORETICAL

ADCS ESC9: A certificate template accessible to VISERY.S.TARGARYEN@ESSOS.LOCAL is configured with CT_FLAG_NO_SECURITY_EXTENSION, omitting the szOID_NTDS_CA_SECURITY_EXT SID binding from issued certificates.

How this technique works: Certificate Mapping Abuse (ADCS ESC9), in Techniques behind these routes.

4. GROUP MEMBERSHIP (MEMBEROF) STRUCTURAL

Group membership: DOMAIN ADMIN.S@ESSOS.LOCAL is a member of ADMINISTRATORS@ESSOS.LOCAL and inherits its privileges.

How this technique works: Group Membership (MemberOf), in Techniques behind these routes.

5. REPLICATE DIRECTORY SECRETS (DCSYNC) CONFIRMED

DCSync: ADMINISTRATORS@ESSOS.LOCAL can replicate secrets from the domain and extract the krbtgt hash.

How this technique works: Replicate Directory Secrets (DCSync), in Techniques behind these routes.

○ DOMAIN COMPROMISED

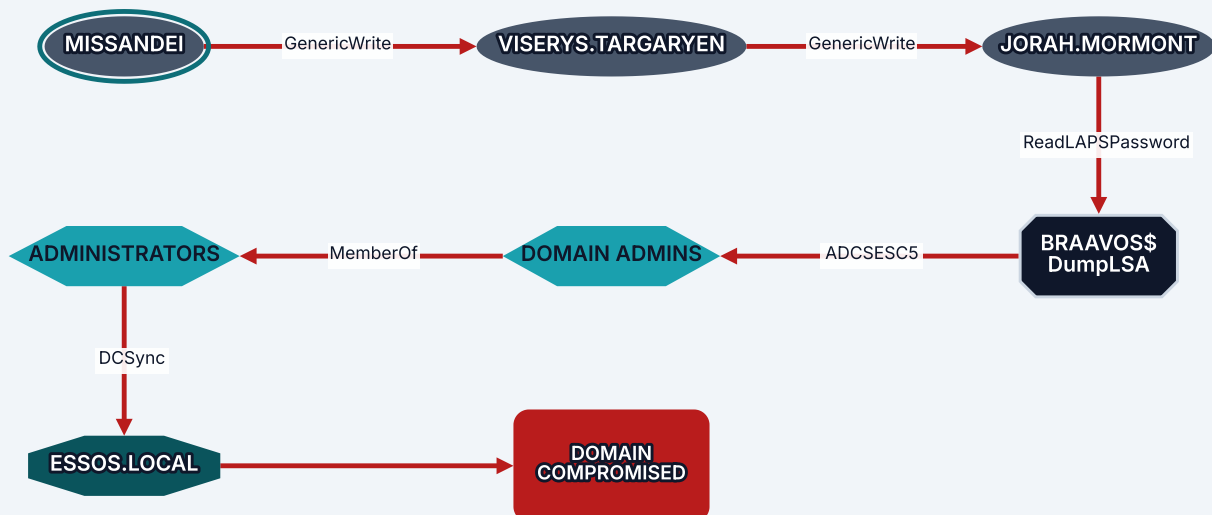
TERMINUS: THIS PATH ENDS IN FULL DOMAIN COMPROMISE.

MISSANDEI → DOMAIN COMPROMISED

FULL DOMAIN COMPROMISE

PARTIALLY VALIDATED

Starting from MISSANDEI@ESSOS.LOCAL, an attacker can reach ESSOS.LOCAL in 7 steps. The path chains GenericWrite, ReadLAPSPassword, DumpLSA, ADCS ESC5, MemberOf, and DCSync. This attack path had part of its chain validated by live execution, but was not run end-to-end.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. MODIFY THE TARGET OBJECT (GENERICWRITE) THEORETICAL

GenericWrite: MISSANDEI@ESSOS.LOCAL can modify most attributes of VISERY.S.TARGARYEN@ESSOS.LOCAL, enabling takeover via Shadow Credentials or SPN.

How this technique works: Modify the Target Object (GenericWrite), in Techniques behind these routes.

2. MODIFY THE TARGET OBJECT (GENERICWRITE) THEORETICAL

GenericWrite: VISERY.S.TARGARYEN@ESSOS.LOCAL can modify most attributes of JORAH.MORMONT@ESSOS.LOCAL, enabling takeover via Shadow Credentials or SPN.

How this technique works: Modify the Target Object (GenericWrite), in Techniques behind these routes.

3. READ THE LOCAL ADMINISTRATOR PASSWORD (READLAPSPASSWORD) THEORETICAL

ReadLAPSPassword: JORAH.MORMONT@ESSOS.LOCAL can read the local administrator password of BRAAVOS\$@ESSOS.LOCAL from AD.

How this technique works: Read the Local Administrator Password (ReadLAPSPassword), in Techniques behind these routes.

4. EXTRACT LSA SECRETS (DUMPLSA) THEORETICAL

DumpLSA: With local administrator or SYSTEM access, an attacker could extract credential material from the host's protected credential stores, which would expose reusable secrets for BRAAVOS\$@ESSOS.LOCAL if this step were executed.

How this technique works: Extract LSA Secrets (DumpLSA), in Techniques behind these routes.

5. CERTIFICATE INFRASTRUCTURE TAKEOVER (ADCS ESC5) THEORETICAL

AD CS ESC5 (Vulnerable PKI Object Access Control): BRAAVOS\$@ESSOS.LOCAL holds write or control rights over a certification-authority object beyond the certificate templates — the CA computer object, the Enrollment Services container, or the NTAUTHCertificates store on DOMAIN ADMINS@ESSOS.LOCAL.

How this technique works: Certificate Infrastructure Takeover (ADCS ESC5), in Techniques behind these routes.

6. GROUP MEMBERSHIP (MEMBEROF) STRUCTURAL

Group membership: DOMAIN ADMINS@ESSOS.LOCAL is a member of ADMINISTRATORS@ESSOS.LOCAL and inherits its privileges.

How this technique works: Group Membership (MemberOf), in Techniques behind these routes.

7. REPLICATE DIRECTORY SECRETS (DCSYNC) CONFIRMED

DCSync: ADMINISTRATORS@ESSOS.LOCAL can replicate secrets from the domain and extract the krbtgt hash.
How this technique works: Replicate Directory Secrets (DCSync), in Techniques behind these routes.

○ DOMAIN COMPROMISED

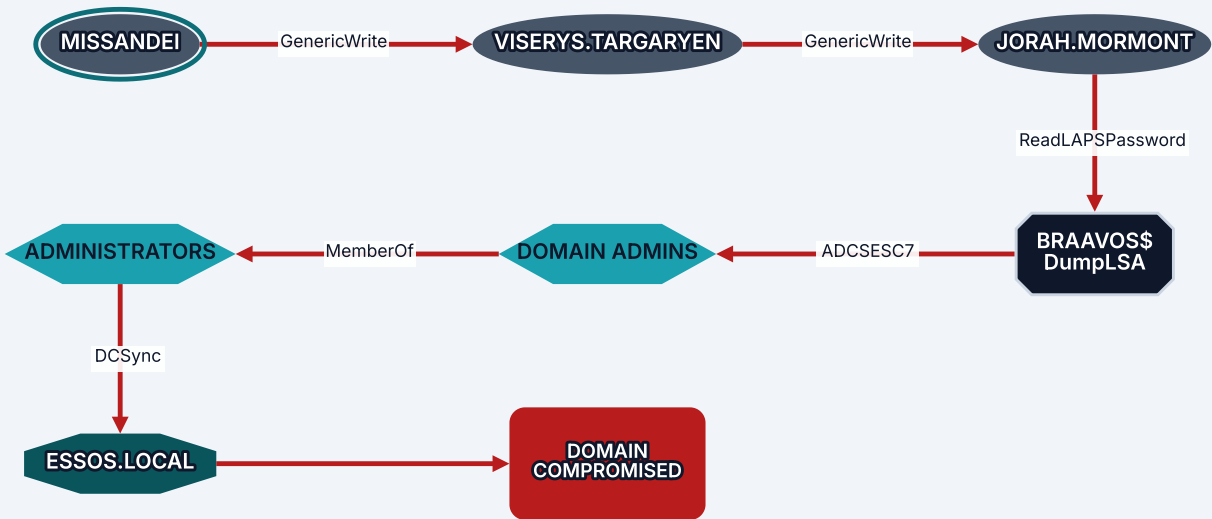
TERMINUS: THIS PATH ENDS IN FULL DOMAIN COMPROMISE.

MISSANDEI → DOMAIN COMPROMISED

FULL DOMAIN COMPROMISE

PARTIALLY VALIDATED

Starting from MISSANDEI@ESSOS.LOCAL, an attacker can reach ESSOS.LOCAL in 7 steps. The path chains GenericWrite, ReadLAPSPassword, DumpLSA, ADCS ESC7, MemberOf, and DCSync. This attack path had part of its chain validated by live execution, but was not run end-to-end.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. MODIFY THE TARGET OBJECT (GENERICWRITE) THEORETICAL

GenericWrite: MISSANDEI@ESSOS.LOCAL can modify most attributes of VISERYSTARGARYEN@ESSOS.LOCAL, enabling takeover via Shadow Credentials or SPN.

How this technique works: Modify the Target Object (GenericWrite), in Techniques behind these routes.

2. MODIFY THE TARGET OBJECT (GENERICWRITE) THEORETICAL

GenericWrite: VISERYSTARGARYEN@ESSOS.LOCAL can modify most attributes of JORAHMORMONT@ESSOS.LOCAL, enabling takeover via Shadow Credentials or SPN.

How this technique works: Modify the Target Object (GenericWrite), in Techniques behind these routes.

3. READ THE LOCAL ADMINISTRATOR PASSWORD (READLAPSPASSWORD) THEORETICAL

ReadLAPSPassword: JORAHMORMONT@ESSOS.LOCAL can read the local administrator password of BRAAVOSS@ESSOS.LOCAL from AD.

How this technique works: Read the Local Administrator Password (ReadLAPSPassword), in Techniques behind these routes.

4. EXTRACT LSA SECRETS (DUMPLSA) THEORETICAL

DumpLSA: With local administrator or SYSTEM access, an attacker could extract credential material from the host's protected credential stores, which would expose reusable secrets for BRAAVOS\$@ESSOS.LOCAL if this step were executed.

How this technique works: Extract LSA Secrets (DumpLSA), in Techniques behind these routes.

5. CERTIFICATE AUTHORITY ADMINISTRATION ABUSE (ADCS ESC7) THEORETICAL

This step indicates BRAAVOS\$@ESSOS.LOCAL can perform 'ADCS ESC7' against DOMAIN ADMIN\$@ESSOS.LOCAL, enabling further escalation.

How this technique works: Certificate Authority Administration Abuse (ADCS ESC7), in Techniques behind these routes.

6. GROUP MEMBERSHIP (MEMBEROF) STRUCTURAL

Group membership: DOMAIN ADMIN\$@ESSOS.LOCAL is a member of ADMINISTRATORS@ESSOS.LOCAL and inherits its privileges.

How this technique works: Group Membership (MemberOf), in Techniques behind these routes.

7. REPLICATE DIRECTORY SECRETS (DCSYNC) CONFIRMED

DCSync: ADMINISTRATORS@ESSOS.LOCAL can replicate secrets from the domain and extract the krbtgt hash.

How this technique works: Replicate Directory Secrets (DCSync), in Techniques behind these routes.

○ DOMAIN COMPROMISED

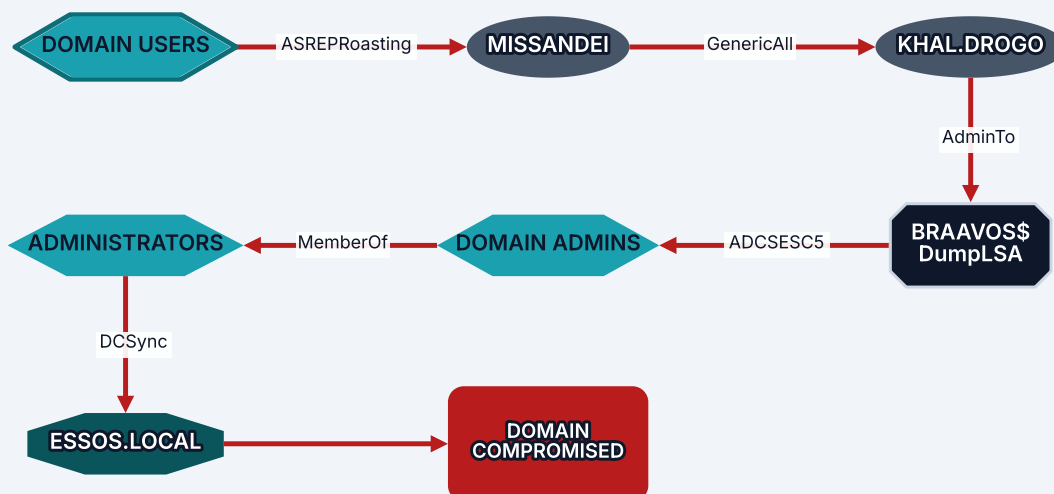
TERMINUS: THIS PATH ENDS IN FULL DOMAIN COMPROMISE.

DOMAIN USERS → DOMAIN COMPROMISED

FULL DOMAIN COMPROMISE

PARTIALLY VALIDATED

Starting from DOMAIN USERS@ESSOS.LOCAL, an attacker can reach ESSOS.LOCAL in 7 steps. The path chains ASREPRoasting, GenericAll, AdminTo, DumpLSA, ADCS ESC5, MemberOf, and DCSync. This attack path had part of its chain validated by live execution, but was not run end-to-end.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. PRE-AUTHENTICATION-LESS CREDENTIAL THEFT (ASREPROASTING)

THEORETICAL

ASREPRoasting: MISSANDEI@ESSOS.LOCAL has pre-authentication disabled, so DOMAIN USERS@ESSOS.LOCAL can request an AS-REP and crack it offline.

How this technique works: Pre-Authentication-less Credential Theft (ASREPRoasting), in Techniques behind these routes.

2. FULL CONTROL OF THE TARGET OBJECT (GENERICALL)

THEORETICAL

GenericAll: user MISSANDEI@ESSOS.LOCAL has full control over user KHAL.DROGO@ESSOS.LOCAL.

How this technique works: Full Control of the Target Object (GenericAll), in Techniques behind these routes.

3. LOCAL ADMINISTRATOR ACCESS (ADMINTO)

THEORETICAL

AdminTo: KHAL.DROGO@ESSOS.LOCAL has local administrator access on BRAAVOS\$@ESSOS.LOCAL. Local administrator rights allow an attacker to: execute code remotely via SMB/PsExec/WMI/WinRM; dump credential material from LSASS memory (recovering domain credentials of any logged-on user); extract secrets from LSA and DPAPI stores; and pivot further using recovered credentials. In environments without LAPS, shared local admin passwords make this a one-to-many pivot across all machines with the same credential.

4. EXTRACT LSA SECRETS (DUMPLSA)

THEORETICAL

DumpLSA: With local administrator or SYSTEM access, an attacker could extract credential material from the host's protected credential stores, which would expose reusable secrets for BRAAVOS\$@ESSOS.LOCAL if this step were executed.

How this technique works: Extract LSA Secrets (DumpLSA), in Techniques behind these routes.

5. CERTIFICATE INFRASTRUCTURE TAKEOVER (ADCS ESC5)

THEORETICAL

AD CS ESC5 (Vulnerable PKI Object Access Control): BRAAVOS\$@ESSOS.LOCAL holds write or control rights over a certification-authority object beyond the certificate templates — the CA computer object, the Enrollment Services container, or the NTAuthCertificates store on DOMAIN ADMINS@ESSOS.LOCAL.

How this technique works: Certificate Infrastructure Takeover (ADCS ESC5), in Techniques behind these routes.

6. GROUP MEMBERSHIP (MEMBEROF)

STRUCTURAL

Group membership: DOMAIN ADMINS@ESSOS.LOCAL is a member of ADMINISTRATORS@ESSOS.LOCAL and inherits its privileges.

How this technique works: Group Membership (MemberOf), in Techniques behind these routes.

7. REPLICATE DIRECTORY SECRETS (DCSYNC)

CONFIRMED

DCSync: ADMINISTRATORS@ESSOS.LOCAL can replicate secrets from the domain and extract the krbtgt hash.

How this technique works: Replicate Directory Secrets (DCSync), in Techniques behind these routes.

○ DOMAIN COMPROMISED

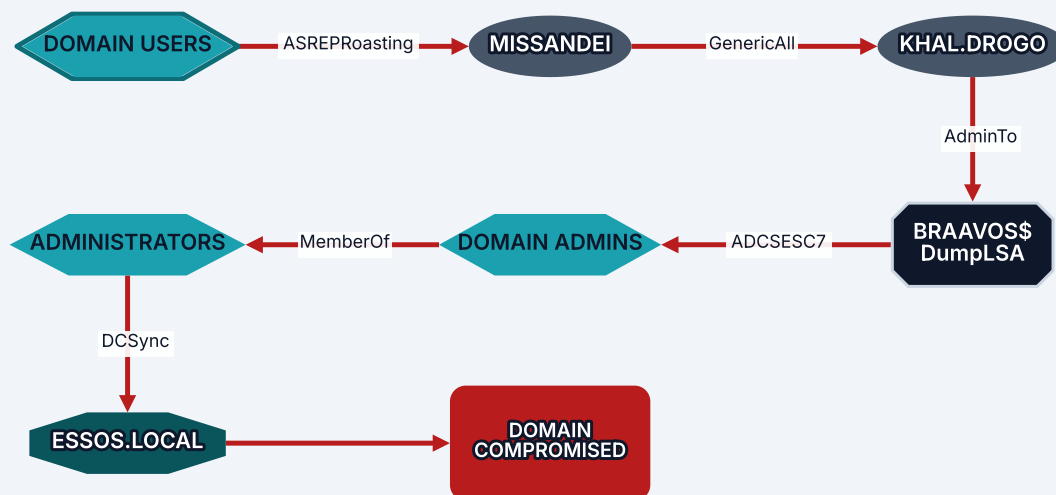
TERMINUS: THIS PATH ENDS IN FULL DOMAIN COMPROMISE.

DOMAIN USERS → DOMAIN COMPROMISED

FULL DOMAIN COMPROMISE

PARTIALLY VALIDATED

Starting from DOMAIN USERS@ESSOS.LOCAL, an attacker can reach ESSOS.LOCAL in 7 steps. The path chains ASREPRoasting, GenericAll, AdminTo, DumpLSA, ADCS ESC7, MemberOf, and DCSync. This attack path had part of its chain validated by live execution, but was not run end-to-end.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. PRE-AUTHENTICATION-LESS CREDENTIAL THEFT (ASREPROASTING)

THEORETICAL

ASREPROasting: MISSANDEI@ESSOS.LOCAL has pre-authentication disabled, so DOMAIN USERS@ESSOS.LOCAL can request an AS-REP and crack it offline.

How this technique works: Pre-Authentication-less Credential Theft (ASREPROasting), in Techniques behind these routes.

2. FULL CONTROL OF THE TARGET OBJECT (GENERICALL)

THEORETICAL

GenericAll: user MISSANDEI@ESSOS.LOCAL has full control over user KHAL.DROGO@ESSOS.LOCAL.

How this technique works: Full Control of the Target Object (GenericAll), in Techniques behind these routes.

3. LOCAL ADMINISTRATOR ACCESS (ADMINTO)

THEORETICAL

AdminTo: KHAL.DROGO@ESSOS.LOCAL has local administrator access on BRAAVOS\$@ESSOS.LOCAL.

How this technique works: Local Administrator Access (AdminTo), in Techniques behind these routes.

4. EXTRACT LSA SECRETS (DUMPLSA)

THEORETICAL

DumpLSA: With local administrator or SYSTEM access, an attacker could extract credential material from the host's protected credential stores, which would expose reusable secrets for BRAAVOS\$@ESSOS.LOCAL if this step were executed.

How this technique works: Extract LSA Secrets (DumpLSA), in Techniques behind these routes.

5. CERTIFICATE AUTHORITY ADMINISTRATION ABUSE (ADCS ESC7)

THEORETICAL

This step indicates BRAAVOS\$@ESSOS.LOCAL can perform 'ADCS ESC7' against DOMAIN ADMINS@ESSOS.LOCAL, enabling further escalation.

How this technique works: Certificate Authority Administration Abuse (ADCS ESC7), in Techniques behind these routes.

6. GROUP MEMBERSHIP (MEMBEROF)

STRUCTURAL

Group membership: DOMAIN ADMINS@ESSOS.LOCAL is a member of ADMINISTRATORS@ESSOS.LOCAL and inherits its privileges.

How this technique works: Group Membership (MemberOf), in Techniques behind these routes.

7. REPLICATE DIRECTORY SECRETS (DCSYNC) CONFIRMED

DCSync: ADMINISTRATORS@ESSOS.LOCAL can replicate secrets from the domain and extract the krbtgt hash.

How this technique works: Replicate Directory Secrets (DCSync), in Techniques behind these routes.

○ DOMAIN COMPROMISED

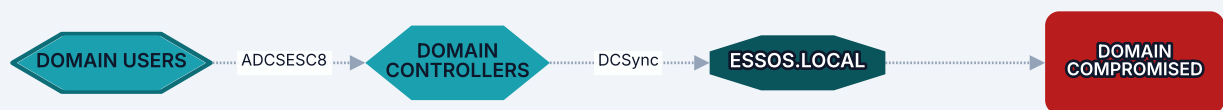
TERMINUS: THIS PATH ENDS IN FULL DOMAIN COMPROMISE.

DOMAIN USERS → DOMAIN COMPROMISED

FULL DOMAIN COMPROMISE

THEORETICAL

Starting from DOMAIN USERS@ESSOS.LOCAL, an attacker can reach ESSOS.LOCAL in 2 steps. The path chains ADCS ESC8 and DCSync. This attack path is a theoretical route derived from configuration analysis.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. CERTIFICATE ENROLLMENT RELAY (ADCS ESC8) THEORETICAL

ADCS ESC8: The Certificate Authority web enrollment endpoint (certsrv) accepts NTLM authentication over HTTP on DOMAIN CONTROLLERS@ESSOS.LOCAL, making it vulnerable to NTLM relay attacks. An attacker who coerces outbound NTLM authentication from a Domain Controller — via PetitPotam, PrinterBug, or DFSCoerce — relays the DC machine account credential to this endpoint and requests a Domain Controller certificate. The resulting DC certificate is used in a Pass-the-Certificate attack to obtain a Kerberos TGT as the DC machine account, enabling full DCSync and domain credential extraction. No initial elevated privileges are required — any domain account can trigger this chain.

REMEDIATION

- Enable Extended Protection for Authentication (EPA) on the Certificate Enrollment web service to prevent NTLM relay
- Require HTTPS with certificate-based mutual authentication for web enrollment endpoints
- Disable HTTP-based web enrollment if it is not operationally required and use alternative enrollment mechanisms
- Mitigate coercion attack vectors: apply PetitPotam patches, disable Print Spooler on DCs, and block RPC coercion paths

2. REPLICATE DIRECTORY SECRETS (DCSYNC) THEORETICAL

DCSync: DOMAIN CONTROLLERS@ESSOS.LOCAL can replicate secrets from the domain and extract the krbtgt hash.

REMEDIATION

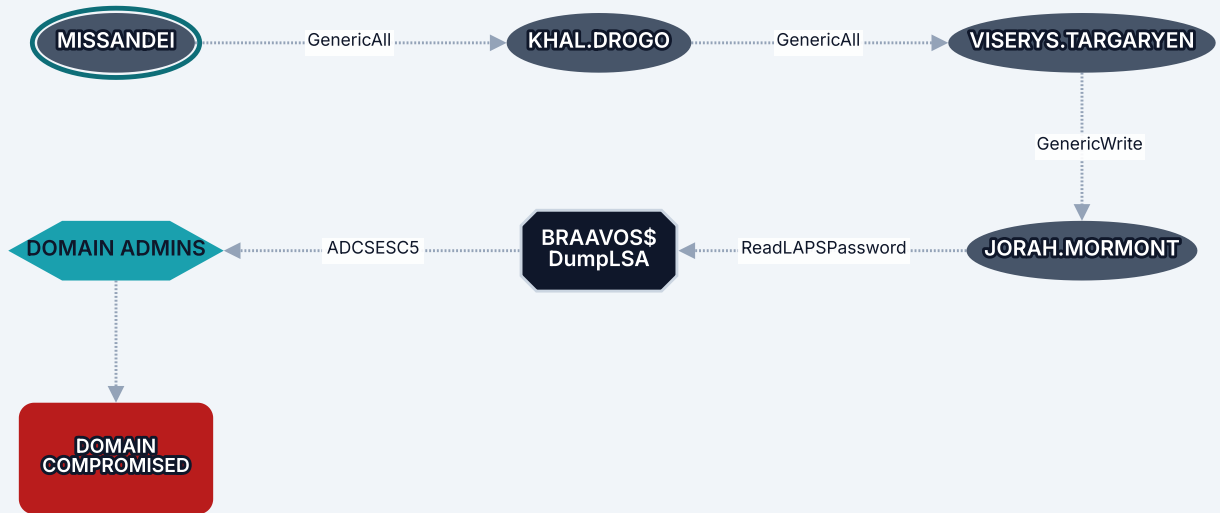
- No change is required at this step: DOMAIN CONTROLLERS@ESSOS.LOCAL is part of the domain's Tier 0 control plane, so this relationship is how Active Directory is built rather than a misconfiguration. When this step sits inside a longer chain, the exposure belongs to the earlier step that lets a lower-privileged principal take control of DOMAIN CONTROLLERS@ESSOS.LOCAL. Remediate there.

How this technique works: Replicate Directory Secrets (DCSync), in Techniques behind these routes.

○ DOMAIN COMPROMISED

TERMINUS: THIS PATH ENDS IN FULL DOMAIN COMPROMISE.

Starting from MISSANDEI@ESSOS.LOCAL, an attacker can reach DOMAIN ADMINS@ESSOS.LOCAL in 6 steps. The path chains GenericAll, GenericWrite, ReadLAPSPassword, DumpLSA, and ADCS ESC5. This attack path is a theoretical route derived from configuration analysis.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

- 1. FULL CONTROL OF THE TARGET OBJECT (GENERICALL)** THEORETICAL
GenericAll: user MISSANDEI@ESSOS.LOCAL has full control over user KHAL.DROGO@ESSOS.LOCAL.
How this technique works: Full Control of the Target Object (GenericAll), in Techniques behind these routes.
- 2. FULL CONTROL OF THE TARGET OBJECT (GENERICALL)** THEORETICAL
GenericAll: user KHAL.DROGO@ESSOS.LOCAL has full control over user VISERY.S.TARGARYEN@ESSOS.LOCAL.
How this technique works: Full Control of the Target Object (GenericAll), in Techniques behind these routes.
- 3. MODIFY THE TARGET OBJECT (GENERICWRITE)** THEORETICAL
GenericWrite: VISERY.S.TARGARYEN@ESSOS.LOCAL can modify most attributes of JORAH.MORMONT@ESSOS.LOCAL, enabling takeover via Shadow Credentials or SPN.
How this technique works: Modify the Target Object (GenericWrite), in Techniques behind these routes.
- 4. READ THE LOCAL ADMINISTRATOR PASSWORD (READLAPSPASSWORD)** THEORETICAL
ReadLAPSPassword: JORAH.MORMONT@ESSOS.LOCAL can read the local administrator password of BRAAVOS\$@ESSOS.LOCAL from AD.
How this technique works: Read the Local Administrator Password (ReadLAPSPassword), in Techniques behind these routes.
- 5. EXTRACT LSA SECRETS (DUMPLSA)** THEORETICAL
DumpLSA: With local administrator or SYSTEM access, an attacker could extract credential material from the host's protected credential stores, which would expose reusable secrets for BRAAVOS\$@ESSOS.LOCAL if this step were executed.
How this technique works: Extract LSA Secrets (DumpLSA), in Techniques behind these routes.

6. CERTIFICATE INFRASTRUCTURE TAKEOVER (ADCS ESC5) THEORETICAL

AD CS ESC5 (Vulnerable PKI Object Access Control): BRAAVOSS@ESSOS.LOCAL holds write or control rights over a certification-authority object beyond the certificate templates — the CA computer object, the Enrollment Services container, or the NTAUTHCertificates store on DOMAIN ADMIN@ESSOS.LOCAL.

How this technique works: Certificate Infrastructure Takeover (ADCS ESC5), in Techniques behind these routes.

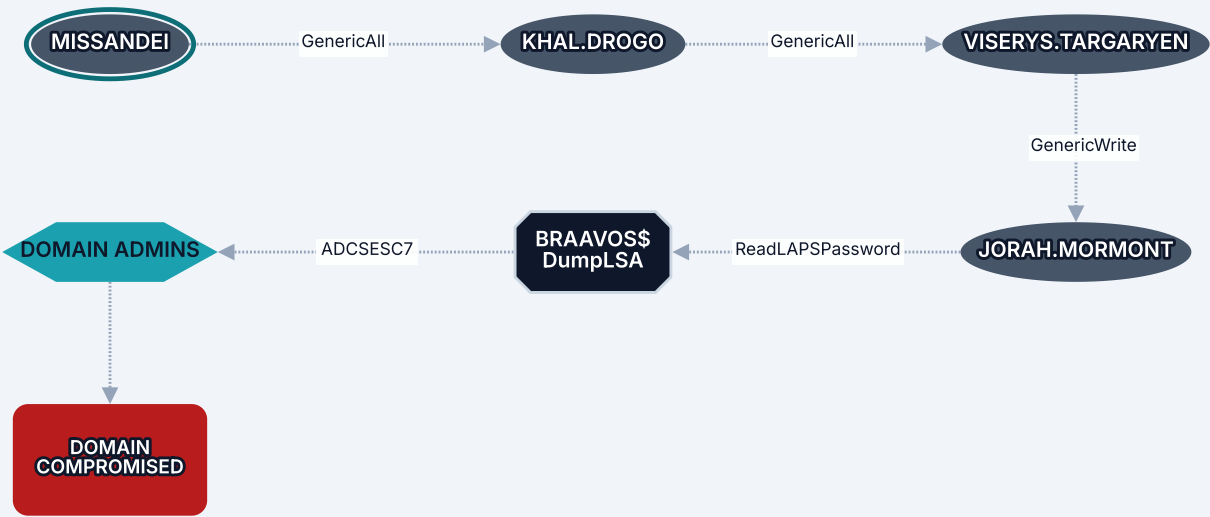
○ DOMAIN COMPROMISED

TERMINUS: THIS PATH ENDS IN FULL DOMAIN COMPROMISE.

MISSANDEI → DOMAIN COMPROMISED

FULL DOMAIN COMPROMISE THEORETICAL

Starting from MISSANDEI@ESSOS.LOCAL, an attacker can reach DOMAIN ADMIN@ESSOS.LOCAL in 6 steps. The path chains GenericAll, GenericWrite, ReadLAPSPassword, DumpLSA, and ADCS ESC7. This attack path is a theoretical route derived from configuration analysis.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. FULL CONTROL OF THE TARGET OBJECT (GENERICALL) THEORETICAL

GenericAll: user MISSANDEI@ESSOS.LOCAL has full control over user KHAL.DROGO@ESSOS.LOCAL.

How this technique works: Full Control of the Target Object (GenericAll), in Techniques behind these routes.

2. FULL CONTROL OF THE TARGET OBJECT (GENERICALL) THEORETICAL

GenericAll: user KHAL.DROGO@ESSOS.LOCAL has full control over user VISERY.S.TARGARYEN@ESSOS.LOCAL.

How this technique works: Full Control of the Target Object (GenericAll), in Techniques behind these routes.

3. MODIFY THE TARGET OBJECT (GENERICWRITE) THEORETICAL

GenericWrite: VISERY.S.TARGARYEN@ESSOS.LOCAL can modify most attributes of JORAH.MORMONT@ESSOS.LOCAL, enabling takeover via Shadow Credentials or SPN.

How this technique works: Modify the Target Object (GenericWrite), in Techniques behind these routes.

4. READ THE LOCAL ADMINISTRATOR PASSWORD (READLAPSPASSWORD) THEORETICAL

ReadLAPSPassword: JORAH.MORMONT@ESSOS.LOCAL can read the local administrator password of BRAAVOS\$@ESSOS.LOCAL from AD.

How this technique works: Read the Local Administrator Password (ReadLAPSPassword), in Techniques behind these routes.

5. EXTRACT LSA SECRETS (DUMPLSA) THEORETICAL

DumpLSA: With local administrator or SYSTEM access, an attacker could extract credential material from the host's protected credential stores, which would expose reusable secrets for BRAAVOS\$@ESSOS.LOCAL if this step were executed.

How this technique works: Extract LSA Secrets (DumpLSA), in Techniques behind these routes.

6. CERTIFICATE AUTHORITY ADMINISTRATION ABUSE (ADCS ESC7) THEORETICAL

This step indicates BRAAVOS\$@ESSOS.LOCAL can perform 'ADCS ESC7' against DOMAIN ADMIN\$@ESSOS.LOCAL, enabling further escalation.

How this technique works: Certificate Authority Administration Abuse (ADCS ESC7), in Techniques behind these routes.

○ DOMAIN COMPROMISED

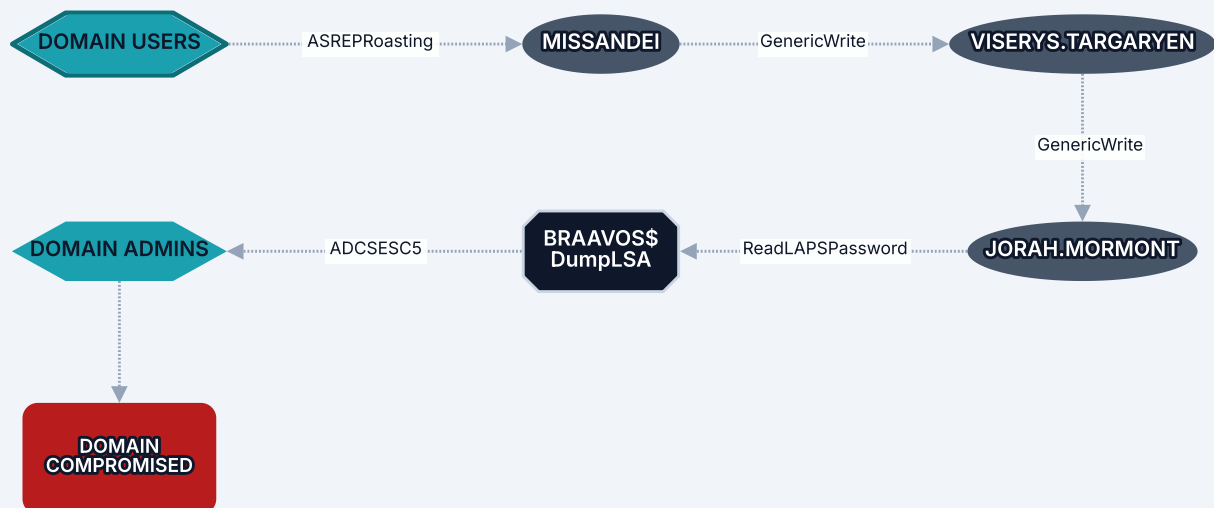
TERMINUS: THIS PATH ENDS IN FULL DOMAIN COMPROMISE.

DOMAIN USERS → DOMAIN COMPROMISED

FULL DOMAIN COMPROMISE

THEORETICAL

Starting from DOMAIN USERS@ESSOS.LOCAL, an attacker can reach DOMAIN ADMIN\$@ESSOS.LOCAL in 6 steps. The path chains ASREPROasting, GenericWrite, ReadLAPSPassword, DumpLSA, and ADCS ESC5. This attack path is a theoretical route derived from configuration analysis.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. PRE-AUTHENTICATION-LESS CREDENTIAL THEFT (ASREPROASTING) THEORETICAL

ASREPROasting: MISSANDEI@ESSOS.LOCAL has pre-authentication disabled, so DOMAIN USERS@ESSOS.LOCAL can request an AS-REP and crack it offline.

How this technique works: Pre-Authentication-less Credential Theft (ASREPROasting), in Techniques behind these routes.

2. MODIFY THE TARGET OBJECT (GENERICWRITE) THEORETICAL

GenericWrite: MISSANDEI@ESSOS.LOCAL can modify most attributes of VISERY.S.TARGARYEN@ESSOS.LOCAL, enabling takeover via Shadow Credentials or SPN.

How this technique works: Modify the Target Object (GenericWrite), in Techniques behind these routes.

3. MODIFY THE TARGET OBJECT (GENERICWRITE) THEORETICAL

GenericWrite: VISERY.S.TARGARYEN@ESSOS.LOCAL can modify most attributes of JORAH.MORMONT@ESSOS.LOCAL, enabling takeover via Shadow Credentials or SPN.

How this technique works: Modify the Target Object (GenericWrite), in Techniques behind these routes.

4. READ THE LOCAL ADMINISTRATOR PASSWORD (READLAPSPASSWORD) THEORETICAL

ReadLAPSPassword: JORAH.MORMONT@ESSOS.LOCAL can read the local administrator password of BRAAVOS\$@ESSOS.LOCAL from AD.

How this technique works: Read the Local Administrator Password (ReadLAPSPassword), in Techniques behind these routes.

5. EXTRACT LSA SECRETS (DUMPLSA) THEORETICAL

DumpLSA: With local administrator or SYSTEM access, an attacker could extract credential material from the host's protected credential stores, which would expose reusable secrets for BRAAVOS\$@ESSOS.LOCAL if this step were executed.

How this technique works: Extract LSA Secrets (DumpLSA), in Techniques behind these routes.

6. CERTIFICATE INFRASTRUCTURE TAKEOVER (ADCS ESC5) THEORETICAL

AD CS ESC5 (Vulnerable PKI Object Access Control): BRAAVOS\$@ESSOS.LOCAL holds write or control rights over a certification-authority object beyond the certificate templates — the CA computer object, the Enrollment Services container, or the NTAUTHCertificates store on DOMAIN ADMIN\$@ESSOS.LOCAL.

How this technique works: Certificate Infrastructure Takeover (ADCS ESC5), in Techniques behind these routes.

○ DOMAIN COMPROMISED

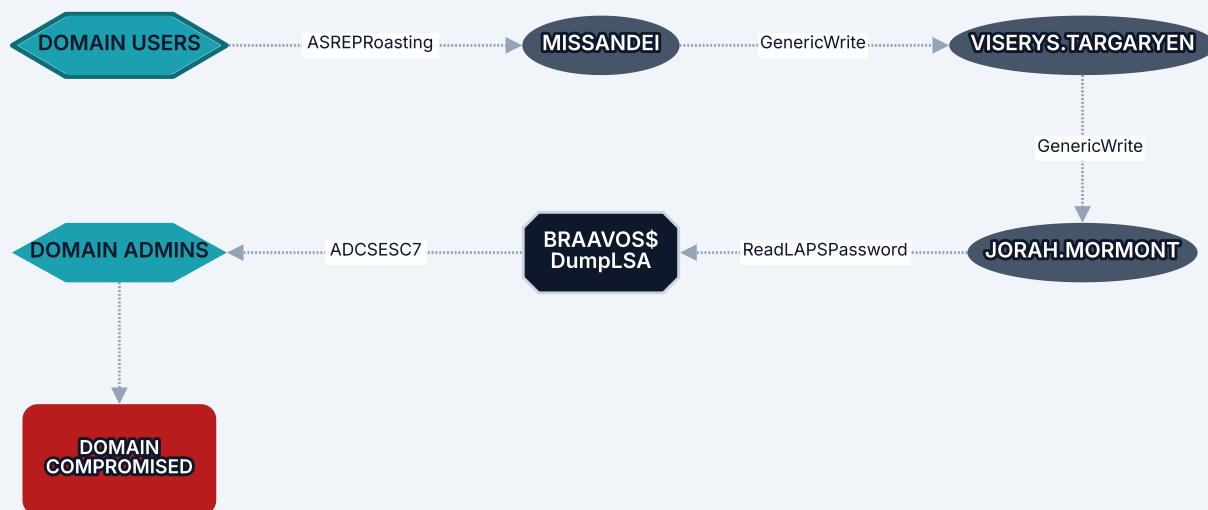
TERMINUS: THIS PATH ENDS IN FULL DOMAIN COMPROMISE.

DOMAIN USERS → DOMAIN COMPROMISED

FULL DOMAIN COMPROMISE

THEORETICAL

Starting from DOMAIN USERS@ESSOS.LOCAL, an attacker can reach DOMAIN ADMIN\$@ESSOS.LOCAL in 6 steps. The path chains ASREPROasting, GenericWrite, ReadLAPSPassword, DumpLSA, and ADCS ESC7. This attack path is a theoretical route derived from configuration analysis.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. PRE-AUTHENTICATION-LESS CREDENTIAL THEFT (ASREPROASTING)

THEORETICAL

ASREPROasting: MISSANDEI@ESSOS.LOCAL has pre-authentication disabled, so DOMAIN USERS@ESSOS.LOCAL can request an AS-REP and crack it offline.

How this technique works: Pre-Authentication-less Credential Theft (ASREPROasting), in Techniques behind these routes.

2. MODIFY THE TARGET OBJECT (GENERICWRITE)

THEORETICAL

GenericWrite: MISSANDEI@ESSOS.LOCAL can modify most attributes of VISERY.S.TARGARYEN@ESSOS.LOCAL, enabling takeover via Shadow Credentials or SPN.

How this technique works: Modify the Target Object (GenericWrite), in Techniques behind these routes.

3. MODIFY THE TARGET OBJECT (GENERICWRITE)

THEORETICAL

GenericWrite: VISERY.S.TARGARYEN@ESSOS.LOCAL can modify most attributes of JORAH.MORMONT@ESSOS.LOCAL, enabling takeover via Shadow Credentials or SPN.

How this technique works: Modify the Target Object (GenericWrite), in Techniques behind these routes.

4. READ THE LOCAL ADMINISTRATOR PASSWORD (READLAPSPASSWORD)

THEORETICAL

ReadLAPSPassword: JORAH.MORMONT@ESSOS.LOCAL can read the local administrator password of BRAAVOS\$@ESSOS.LOCAL from AD.

How this technique works: Read the Local Administrator Password (ReadLAPSPassword), in Techniques behind these routes.

5. EXTRACT LSA SECRETS (DUMPLSA)

THEORETICAL

DumpLSA: With local administrator or SYSTEM access, an attacker could extract credential material from the host's protected credential stores, which would expose reusable secrets for BRAAVOS\$@ESSOS.LOCAL if this step were executed.

How this technique works: Extract LSA Secrets (DumpLSA), in Techniques behind these routes.

6. CERTIFICATE AUTHORITY ADMINISTRATION ABUSE (ADCS ESC7) THEORETICAL

This step indicates BRAAVOS\$@ESSOS.LOCAL can perform 'ADCS ESC7' against DOMAIN ADMIN\$@ESSOS.LOCAL, enabling further escalation.

How this technique works: Certificate Authority Administration Abuse (ADCS ESC7), in Techniques behind these routes.

○ DOMAIN COMPROMISED

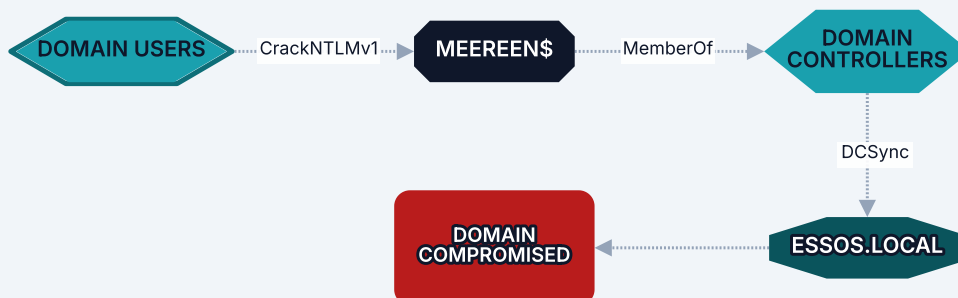
TERMINUS: THIS PATH ENDS IN FULL DOMAIN COMPROMISE.

DOMAIN USERS → DOMAIN COMPROMISED

FULL DOMAIN COMPROMISE

NOT ASSESSED

Starting from DOMAIN USERS@ESSOS.LOCAL, an attacker can reach ESSOS.LOCAL in 3 steps. The path chains NTLMv1 Offline Crack, MemberOf, and DCSync. This attack path was not assessed in this engagement: no reachable surface was available to test the avenue.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. OFFLINE NTLMV1 CREDENTIAL RECOVERY (NTLMV1 OFFLINE CRACK)

NTLMv1 Offline Crack: DOMAIN USERS@ESSOS.LOCAL coerces MEEREEN\$@ESSOS.LOCAL, captures its NTLMv1 response, and recovers the MEEREEN\$@ESSOS.LOCAL machine account NT hash offline via precomputed DES rainbow tables (NetNTLMv1's DES-based response over a known challenge is fully reversible this way, not a brute-force crack). The most universal NTLMv1 avenue — independent of relay viability, LDAP signing, channel binding, ADCS, or DC count. A successful offline crack yields the machine account's credential. This step was identified from the environment's configuration and was not exercised during this engagement.

2. GROUP MEMBERSHIP (MEMBEROF) STRUCTURAL

Group membership: MEEREEN\$@ESSOS.LOCAL is a member of DOMAIN CONTROLLERS@ESSOS.LOCAL and inherits its privileges.

REMEDIATION

- No change is required at this step: MEEREEN\$@ESSOS.LOCAL is part of the domain's Tier 0 control plane, so this relationship is how Active Directory is built rather than a misconfiguration. When this step sits inside a longer chain, the exposure belongs to the earlier step that lets a lower-privileged principal take control of MEEREEN\$@ESSOS.LOCAL. Remediate there.

How this technique works: Group Membership (MemberOf), in Techniques behind these routes.

3. REPLICATE DIRECTORY SECRETS (DCSYNC) THEORETICAL

DCSync: DOMAIN CONTROLLERS@ESSOS.LOCAL can replicate secrets from the domain and extract the krbtgt hash.
How this technique works: Replicate Directory Secrets (DCSync), in Techniques behind these routes.

○ DOMAIN COMPROMISED
TERMINUS: THIS PATH ENDS IN FULL DOMAIN COMPROMISE.

DOMAIN USERS → DOMAIN COMPROMISED

FULL DOMAIN COMPROMISE NOT ASSESSED

Starting from DOMAIN USERS@ESSOS.LOCAL, an attacker can reach ESSOS.LOCAL in 2 steps. The path chains NTLMv1 Offline Crack and DCSync. This attack path was not assessed in this engagement: no reachable surface was available to test the avenue.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. OFFLINE NTLMV1 CREDENTIAL RECOVERY (NTLMV1 OFFLINE CRACK)

NTLMv1 Offline Crack: DOMAIN USERS@ESSOS.LOCAL coerces MEEREEN\$@ESSOS.LOCAL, captures its NTLMv1 response, and recovers the MEEREEN\$@ESSOS.LOCAL machine account NT hash offline via precomputed DES rainbow tables (NetNTLMv1's DES-based response over a known challenge is fully reversible this way, not a brute-force crack).
How this technique works: Offline NTLMv1 Credential Recovery (NTLMv1 Offline Crack), in Techniques behind these routes.

2. REPLICATE DIRECTORY SECRETS (DCSYNC) THEORETICAL

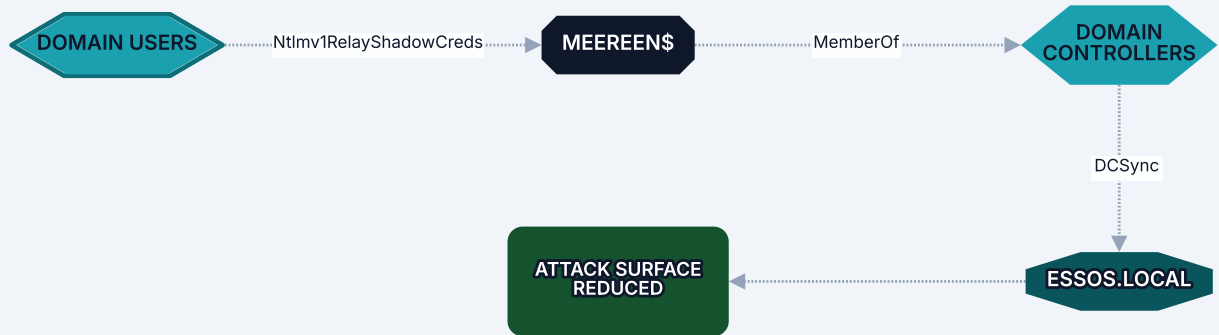
DCSync: MEEREEN\$@ESSOS.LOCAL can replicate secrets from the domain and extract the krbtgt hash.
How this technique works: Replicate Directory Secrets (DCSync), in Techniques behind these routes.

○ DOMAIN COMPROMISED
TERMINUS: THIS PATH ENDS IN FULL DOMAIN COMPROMISE.

DOMAIN USERS → ATTACK SURFACE REDUCED

HARDENING OBSERVED

Starting from DOMAIN USERS@ESSOS.LOCAL, an attacker can reach ESSOS.LOCAL in 3 steps. The path chains NTLMv1 Relay → Shadow Credentials, MemberOf, and DCSync. This attack path targets an avenue your environment's configuration already closes.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. CREDENTIAL RELAY TO SHADOW CREDENTIALS (NTLMV1 RELAY → SHADOW CREDENTIALS) THEORETICAL

NTLMv1 Relay → Shadow Credentials: DOMAIN USERS@ESSOS.LOCAL coerces MEEREEN\$@ESSOS.LOCAL, relays its NTLMv1 authentication to a domain controller, writes a key credential, and recovers the MEEREEN\$@ESSOS.LOCAL machine account NT hash via PKINIT. A successful relay yields the target computer account's own credential. Attack surface reduced: single DC — self-relay reflection-mitigated. ADscan observed this avenue is closed by your environment's configuration and it is not presently exploitable.

2. GROUP MEMBERSHIP (MEMBEROF) STRUCTURAL

Group membership: MEEREEN\$@ESSOS.LOCAL is a member of DOMAIN CONTROLLERS@ESSOS.LOCAL and inherits its privileges.

3. REPLICATE DIRECTORY SECRETS (DCSYNC) THEORETICAL

DCSync: DOMAIN CONTROLLERS@ESSOS.LOCAL can replicate secrets from the domain and extract the krbtgt hash.

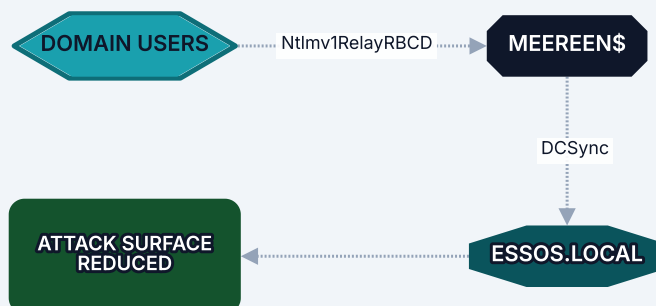
○ ATTACK SURFACE REDUCED

TERMINUS: YOUR CONFIGURATION CLOSES THIS ROUTE. NO ACTION REQUIRED HERE.

DOMAIN USERS → ATTACK SURFACE REDUCED

HARDENING OBSERVED

Starting from DOMAIN USERS@ESSOS.LOCAL, an attacker can reach ESSOS.LOCAL in 2 steps. The path chains NTLMv1 Relay → RBCD and DCSync. This attack path targets an avenue your environment's configuration already closes.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. CREDENTIAL RELAY TO DELEGATION (NTLMV1 RELAY → RBCD) THEORETICAL

NTLMv1 Relay → RBCD: DOMAIN USERS@ESSOS.LOCAL coerces MEEREEN\$@ESSOS.LOCAL to authenticate, relays that NTLMv1 authentication to a domain controller, writes resource-based constrained delegation, and obtains local administrator access on MEEREEN\$@ESSOS.LOCAL via S4U. A successful relay grants local administrator access on the target host. Attack surface reduced: single DC — self-relay reflection-mitigated. ADscan observed this avenue is closed by your environment's configuration and it is not presently exploitable.

2. REPLICATE DIRECTORY SECRETS (DCSYNC) THEORETICAL

DCSync: MEEREEN\$@ESSOS.LOCAL can replicate secrets from the domain and extract the krbtgt hash.

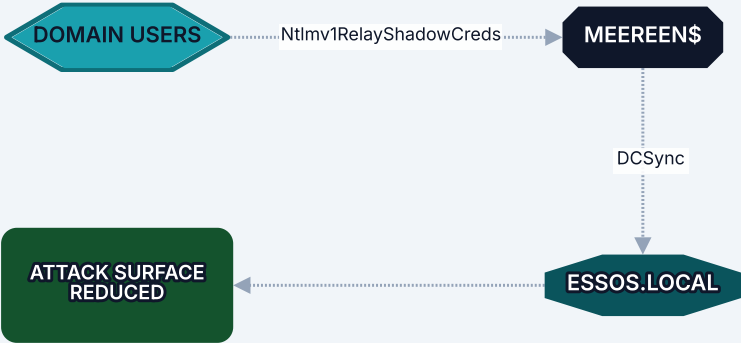
○ ATTACK SURFACE REDUCED

TERMINUS: YOUR CONFIGURATION CLOSES THIS ROUTE. NO ACTION REQUIRED HERE.

DOMAIN USERS → ATTACK SURFACE REDUCED

HARDENING OBSERVED

Starting from DOMAIN USERS@ESSOS.LOCAL, an attacker can reach ESSOS.LOCAL in 2 steps. The path chains NTLMv1 Relay → Shadow Credentials and DCSync. This attack path targets an avenue your environment's configuration already closes.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. CREDENTIAL RELAY TO SHADOW CREDENTIALS (NTLMV1 RELAY → SHADOW CREDENTIALS) THEORETICAL

NTLMv1 Relay → Shadow Credentials: DOMAIN USERS@ESSOS.LOCAL coerces MEEREEN\$@ESSOS.LOCAL, relays its NTLMv1 authentication to a domain controller, writes a key credential, and recovers the MEEREEN\$@ESSOS.LOCAL machine account NT hash via PKINIT.

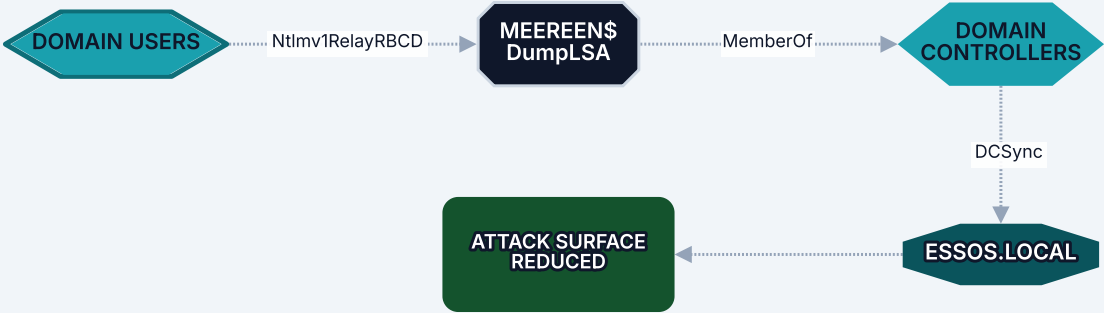
2. REPLICATE DIRECTORY SECRETS (DCSYNC) THEORETICAL

DCSync: MEEREEN\$@ESSOS.LOCAL can replicate secrets from the domain and extract the krbtgt hash.

○ ATTACK SURFACE REDUCED

TERMINUS: YOUR CONFIGURATION CLOSES THIS ROUTE. NO ACTION REQUIRED HERE.

Starting from DOMAIN USERS@ESSOS.LOCAL, an attacker can reach ESSOS.LOCAL in 4 steps. The path chains NTLMv1 Relay → RBCD, DumpLSA, MemberOf, and DCSync. This attack path targets an avenue your environment's configuration already closes.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. CREDENTIAL RELAY TO DELEGATION (NTLMV1 RELAY → RBCD)

THEORETICAL

NTLMv1 Relay → RBCD: DOMAIN USERS@ESSOS.LOCAL coerces MEEREEN\$@ESSOS.LOCAL to authenticate, relays that NTLMv1 authentication to a domain controller, writes resource-based constrained delegation, and obtains local administrator access on MEEREEN\$@ESSOS.LOCAL via S4U.
2. EXTRACT LSA SECRETS (DUMPLSA)

THEORETICAL

DumpLSA: With local administrator or SYSTEM access, an attacker could extract credential material from the host's protected credential stores, which would expose reusable secrets for MEEREEN\$@ESSOS.LOCAL if this step were executed.
3. GROUP MEMBERSHIP (MEMBEROF)

STRUCTURAL

Group membership: MEEREEN\$@ESSOS.LOCAL is a member of DOMAIN CONTROLLERS@ESSOS.LOCAL and inherits its privileges.
4. REPLICATE DIRECTORY SECRETS (DCSYNC)

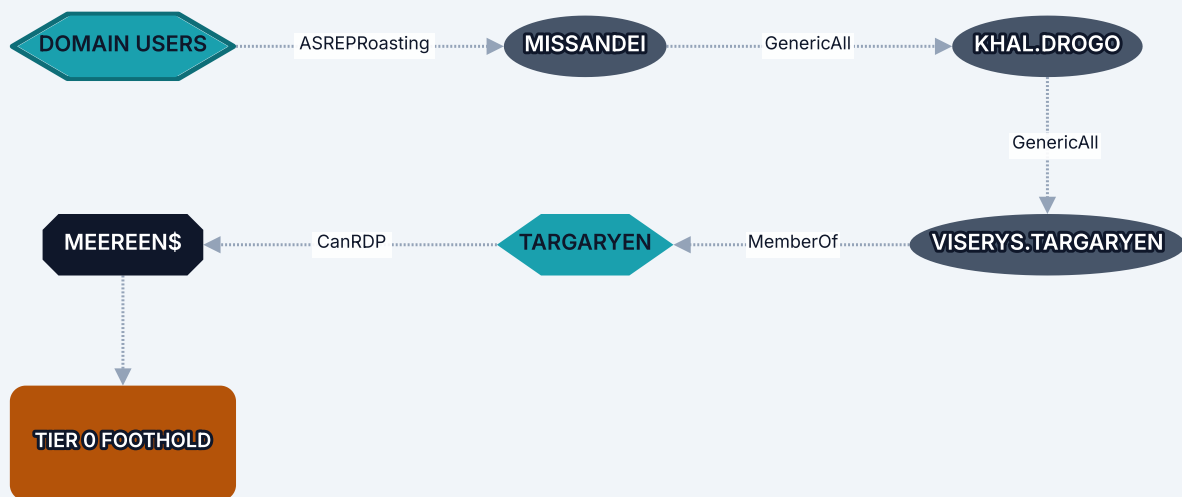
THEORETICAL

DCSync: DOMAIN CONTROLLERS@ESSOS.LOCAL can replicate secrets from the domain and extract the krbtgt hash.

○ ATTACK SURFACE REDUCED

TERMINUS: YOUR CONFIGURATION CLOSES THIS ROUTE. NO ACTION REQUIRED HERE.

Starting from DOMAIN USERS@ESSOS.LOCAL, an attacker can reach MEEREEN\$@ESSOS.LOCAL in 5 steps. The path chains ASREProasting, GenericAll, MemberOf, and CanRDP. This attack path is a theoretical route derived from configuration analysis.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. PRE-AUTHENTICATION-LESS CREDENTIAL THEFT (ASREPROASTING)

THEORETICAL

ASREPROasting: MISSANDEI@ESSOS.LOCAL has pre-authentication disabled, so DOMAIN USERS@ESSOS.LOCAL can request an AS-REP and crack it offline.

How this technique works: Pre-Authentication-less Credential Theft (ASREPROasting), in Techniques behind these routes.

2. FULL CONTROL OF THE TARGET OBJECT (GENERICALL)

THEORETICAL

GenericAll: user MISSANDEI@ESSOS.LOCAL has full control over user KHAL.DROGO@ESSOS.LOCAL.

How this technique works: Full Control of the Target Object (GenericAll), in Techniques behind these routes.

3. FULL CONTROL OF THE TARGET OBJECT (GENERICALL)

THEORETICAL

GenericAll: user KHAL.DROGO@ESSOS.LOCAL has full control over user VISERY.S.TARGARYEN@ESSOS.LOCAL.

How this technique works: Full Control of the Target Object (GenericAll), in Techniques behind these routes.

4. GROUP MEMBERSHIP (MEMBEROF)

STRUCTURAL

Group membership: VISERY.S.TARGARYEN@ESSOS.LOCAL is a member of TARGARYEN@ESSOS.LOCAL and inherits its privileges.

REMEDIATION

- Remove VISERY.S.TARGARYEN@ESSOS.LOCAL from TARGARYEN@ESSOS.LOCAL if the membership is not strictly required.
- Audit group membership periodically and enforce tiering boundaries.

How this technique works: Group Membership (MemberOf), in Techniques behind these routes.

5. REMOTE DESKTOP ACCESS (CANRDP)

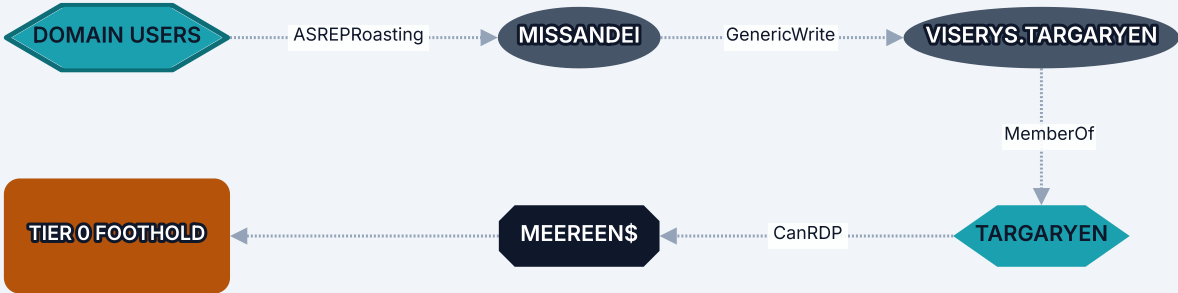
THEORETICAL

CanRDP: TARGARYEN@ESSOS.LOCAL can initiate an RDP session on MEEREEN\$@ESSOS.LOCAL. Remote Desktop access provides an interactive graphical session on the target machine. An attacker with RDP access can: extract credentials from memory (especially if a privileged user is already logged on); install persistence mechanisms; pivot to other network segments accessible from MEEREEN\$@ESSOS.LOCAL; or abuse services running in the session. RDP sessions generate logon event 4624 (type 10) and may be detectable via session recording if configured.

○ TIER 0 FOO THOLD

TERMINUS: ACCESS TO A TIER-0 HOST; TAKEOVER NOT YET PROVEN.

Starting from DOMAIN USERS@ESSOS.LOCAL, an attacker can reach MEEREEN\$@ESSOS.LOCAL in 4 steps. The path chains ASREPRoasting, GenericWrite, MemberOf, and CanRDP. This attack path is a theoretical route derived from configuration analysis.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. PRE-AUTHENTICATION-LESS CREDENTIAL THEFT (ASREPROASTING)

THEORETICAL

ASREPRoasting: MISSANDEI@ESSOS.LOCAL has pre-authentication disabled, so DOMAIN USERS@ESSOS.LOCAL can request an AS-REP and crack it offline.

How this technique works: Pre-Authentication-less Credential Theft (ASREPRoasting), in Techniques behind these routes.

2. MODIFY THE TARGET OBJECT (GENERICWRITE)

THEORETICAL

GenericWrite: MISSANDEI@ESSOS.LOCAL can modify most attributes of VISERY.S.TARGARYEN@ESSOS.LOCAL, enabling takeover via Shadow Credentials or SPN.

How this technique works: Modify the Target Object (GenericWrite), in Techniques behind these routes.

3. GROUP MEMBERSHIP (MEMBEROF)

STRUCTURAL

Group membership: VISERY.S.TARGARYEN@ESSOS.LOCAL is a member of TARGARYEN@ESSOS.LOCAL and inherits its privileges.

How this technique works: Group Membership (MemberOf), in Techniques behind these routes.

4. REMOTE DESKTOP ACCESS (CANRDP)

THEORETICAL

CanRDP: TARGARYEN@ESSOS.LOCAL can initiate an RDP session on MEEREEN\$@ESSOS.LOCAL.

How this technique works: Remote Desktop Access (CanRDP), in Techniques behind these routes.

○ TIER 0 FOOTHOLD

TERMINUS: ACCESS TO A TIER-0 HOST; TAKEOVER NOT YET PROVEN.

Starting from USERS@ESSOS.LOCAL, an attacker can reach BRAAVOS\$@ESSOS.LOCAL in 1 step. The path abuses SQLAccess. This attack path is a theoretical route derived from configuration analysis.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. DATABASE SESSION ACCESS (SQLACCESS) THEORETICAL

This step indicates USERS@ESSOS.LOCAL can perform 'SQLAccess' against BRAAVOS\$@ESSOS.LOCAL, enabling further escalation.

○ TIER 0 FOOTHOLD

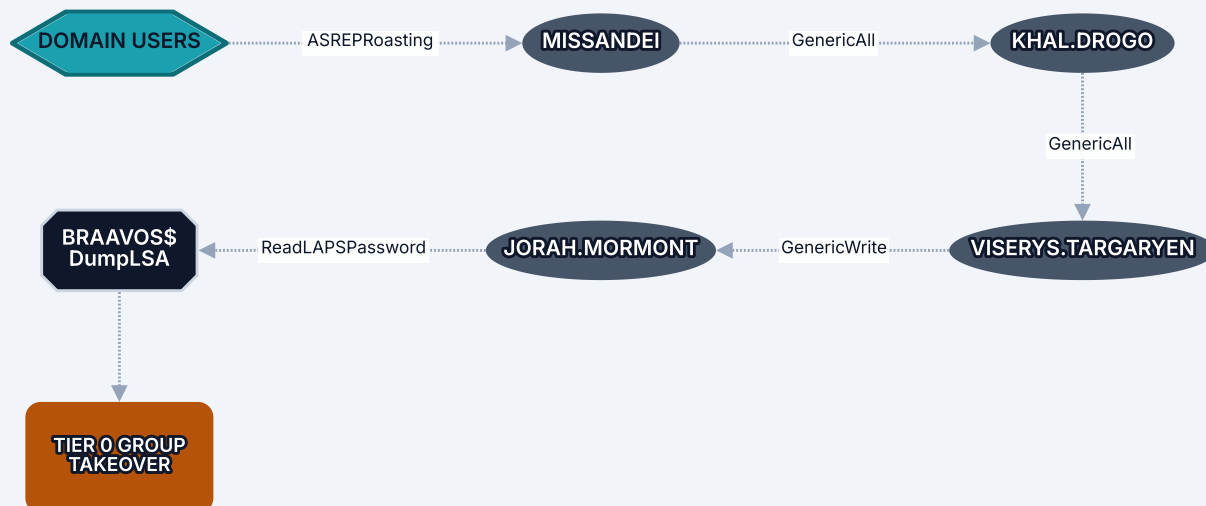
TERMINUS: ACCESS TO A TIER-0 HOST; TAKEOVER NOT YET PROVEN.

DOMAIN USERS → TIER 0 GROUP TAKEOVER

TIER 0 GROUP TAKEOVER

THEORETICAL

Starting from DOMAIN USERS@ESSOS.LOCAL, an attacker can reach BRAAVOS\$@ESSOS.LOCAL in 6 steps. The path chains ASREProasting, GenericAll, GenericWrite, ReadLAPSPassword, and DumpLSA. This attack path is a theoretical route derived from configuration analysis.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. PRE-AUTHENTICATION-LESS CREDENTIAL THEFT (ASREPROASTING) THEORETICAL

ASREProasting: MISSANDEI@ESSOS.LOCAL has pre-authentication disabled, so DOMAIN USERS@ESSOS.LOCAL can request an AS-REP and crack it offline.

How this technique works: Pre-Authentication-less Credential Theft (ASREProasting), in Techniques behind these routes.

2. FULL CONTROL OF THE TARGET OBJECT (GENERICALL) THEORETICAL

GenericAll: user MISSANDEI@ESSOS.LOCAL has full control over user KHAL.DROGO@ESSOS.LOCAL.

How this technique works: Full Control of the Target Object (GenericAll), in Techniques behind these routes.

3. FULL CONTROL OF THE TARGET OBJECT (GENERICALL) THEORETICAL

GenericAll: user KHAL.DROGO@ESSOS.LOCAL has full control over user VISERY.S.TARGARYEN@ESSOS.LOCAL.

How this technique works: Full Control of the Target Object (GenericAll), in Techniques behind these routes.

4. MODIFY THE TARGET OBJECT (GENERICWRITE) THEORETICAL

GenericWrite: VISERY.S.TARGARYEN@ESSOS.LOCAL can modify most attributes of JORAH.MORMONT@ESSOS.LOCAL, enabling takeover via Shadow Credentials or SPN.

How this technique works: Modify the Target Object (GenericWrite), in Techniques behind these routes.

5. READ THE LOCAL ADMINISTRATOR PASSWORD (READLAPSPASSWORD) THEORETICAL

ReadLAPSPassword: JORAH.MORMONT@ESSOS.LOCAL can read the local administrator password of BRAAVOS\$@ESSOS.LOCAL from AD.

How this technique works: Read the Local Administrator Password (ReadLAPSPassword), in Techniques behind these routes.

6. EXTRACT LSA SECRETS (DUMPLSA) THEORETICAL

DumpLSA: With local administrator or SYSTEM access, an attacker could extract credential material from the host's protected credential stores, which would expose reusable secrets for BRAAVOS\$@ESSOS.LOCAL if this step were executed.

How this technique works: Extract LSA Secrets (DumpLSA), in Techniques behind these routes.

○ TIER 0 GROUP TAKEOVER

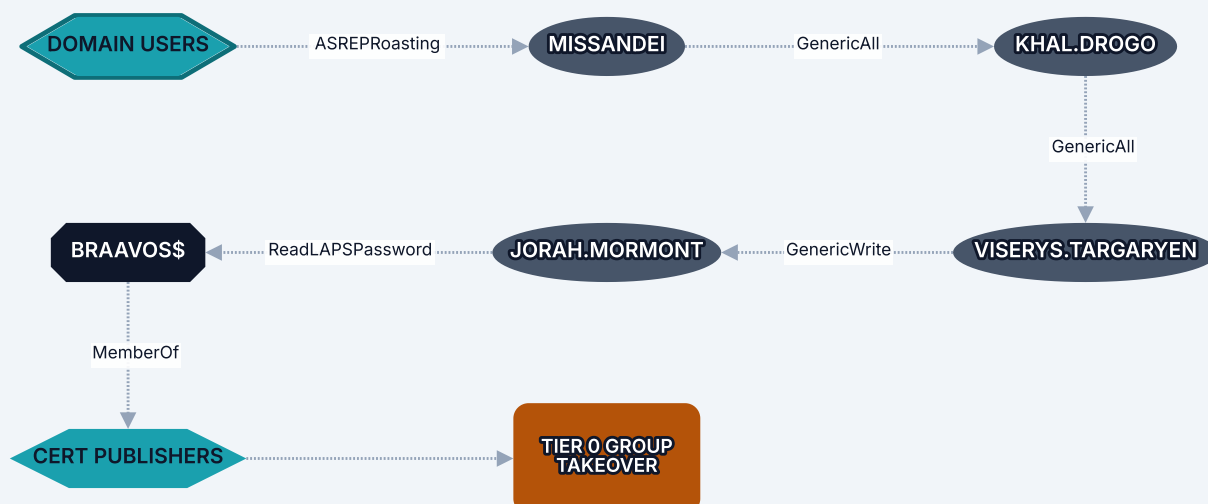
TERMINUS: REACHES A PRIVILEGED ASSET, NOT DOMAIN TAKEOVER.

DOMAIN USERS → TIER 0 GROUP TAKEOVER

TIER 0 GROUP TAKEOVER

THEORETICAL

Starting from DOMAIN USERS@ESSOS.LOCAL, an attacker can reach CERT PUBLISHERS@ESSOS.LOCAL in 6 steps. The path chains ASREProasting, GenericAll, GenericWrite, ReadLAPSPassword, and MemberOf. This attack path is a theoretical route derived from configuration analysis.



Shapes and line styles are explained under the first route diagram in this section, and again under the attack surface map.

STEP-BY-STEP BREAKDOWN

1. PRE-AUTHENTICATION-LESS CREDENTIAL THEFT (ASREPROASTING) THEORETICAL

ASREPROasting: MISSANDEI@ESSOS.LOCAL has pre-authentication disabled, so DOMAIN USERS@ESSOS.LOCAL can request an AS-REP and crack it offline.

How this technique works: Pre-Authentication-less Credential Theft (ASREPROasting), in Techniques behind these routes.

2. FULL CONTROL OF THE TARGET OBJECT (GENERICALL) THEORETICAL

GenericAll: user MISSANDEI@ESSOS.LOCAL has full control over user KHAL.DROGO@ESSOS.LOCAL.

How this technique works: Full Control of the Target Object (GenericAll), in Techniques behind these routes.

3. FULL CONTROL OF THE TARGET OBJECT (GENERICALL) THEORETICAL

GenericAll: user KHAL.DROGO@ESSOS.LOCAL has full control over user VISERY.S.TARGARYEN@ESSOS.LOCAL.

How this technique works: Full Control of the Target Object (GenericAll), in Techniques behind these routes.

4. MODIFY THE TARGET OBJECT (GENERICWRITE) THEORETICAL

GenericWrite: VISERY.S.TARGARYEN@ESSOS.LOCAL can modify most attributes of JORAH.MORMONT@ESSOS.LOCAL, enabling takeover via Shadow Credentials or SPN.

How this technique works: Modify the Target Object (GenericWrite), in Techniques behind these routes.

5. READ THE LOCAL ADMINISTRATOR PASSWORD (READLAPSPASSWORD) THEORETICAL

ReadLAPSPassword: JORAH.MORMONT@ESSOS.LOCAL can read the local administrator password of BRAAVOS\$@ESSOS.LOCAL from AD.

How this technique works: Read the Local Administrator Password (ReadLAPSPassword), in Techniques behind these routes.

6. GROUP MEMBERSHIP (MEMBEROF) STRUCTURAL

Group membership: BRAAVOS\$@ESSOS.LOCAL is a member of CERT PUBLISHERS@ESSOS.LOCAL and inherits its privileges.

REMEDIATION

- Remove BRAAVOS\$@ESSOS.LOCAL from CERT PUBLISHERS@ESSOS.LOCAL if the membership is not strictly required.

How this technique works: Group Membership (MemberOf), in Techniques behind these routes.

○ TIER 0 GROUP TAKEOVER

TERMINUS: REACHES A PRIVILEGED ASSET, NOT DOMAIN TAKEOVER.

03

Technical Findings

Detailed vulnerability breakdown with remediation guidance.

ADSCAN SCORING METHODOLOGY

Three categories, and only one of the scores is CVSS.

Each finding is classified into one of three categories, visible as a coloured badge, so the reader can separate *what kind of finding it is* from *how severe*: **VULNERABILITY** is a real exploit; **CHAIN PREREQUISITE** is a primitive that enables an attack chain (Critical only when the chain is confirmed); **POSTURE** documents the absence of a control (hygiene gap, capped at High even on Tier-0).

Every finding carries an **ADscan Priority**: our own severity model, which weighs the technique against what this assessment observed in your directory — the conditions below. It is the number the remediation roadmap and the compliance mapping rank by. The severity chip beside each title is a different measure: the finding's baseline classification, which is the same in every environment and is what the counts in this report are grouped by. The two can disagree — a technique classified High can carry a Critical priority here, because this directory supplies the conditions it needs. Where they do, the priority is the one to plan from.

A **CVSS Base** score appears in addition wherever the finding maps to a published CVSS v3.1 Base vector. The vector is printed beside it, so the score can be recomputed on the FIRST calculator. Most Active Directory exposures — a misconfigured certificate template, a readable LAPS attribute, a control that is simply absent — have no such vector; those findings show the ADscan Priority alone rather than a number dressed up as a standard.

Tier-0 exposure: affected principal or attack-path target is Domain Admin / KRBTGT / DC. **DC targeting**: at least one Domain Controller is in scope of the issue.

Relay confirmed: a vulnerable relay target (ADCS Web Enrollment without EPA, LDAP without signing/CB) was identified in this workspace.

Exploitation confirmed: concrete evidence captured (cracked hash, working PoC, full chain executed).

F-001

ADCS ESC1 - Misconfigured Certificate Template

CRITICAL

ADscan Priority 9.9 Critical ADCS **VULNERABILITY**

CWE-269 essos.local

METHODOLOGY Scored by the ADscan Priority model — no published CVSS Base vector applies to this finding.

ADSCAN ANALYSIS

ESC1 abuse confirmed: certificate enrollment with attacker-supplied SAN succeeded

DESCRIPTION

ADCS ESC1 occurs when a certificate template is configured to allow requesters to specify a Subject Alternative Name (SAN) in their certificate request, combined with an authentication-capable Extended Key Usage (EKU) such as Client Authentication, Smart Card Logon, or PKINIT. Any principal with enroll permissions on such a template can request a certificate asserting the identity of any user in the domain, including Domain Administrators, by specifying their UPN in the SAN field. Active Directory validates Kerberos authentication based on the certificate SAN rather than the requesting identity, allowing the attacker to obtain a TGT for the impersonated user without knowledge of their password.

IMPACT

Any domain user with enrollment rights on the template can obtain a certificate impersonating a Domain Administrator and authenticate to any Kerberos-capable service with full DA privileges. The resulting access bypasses password rotation, MFA tied to passwords, and most authentication monitoring, as the action uses a legitimately issued certificate. In this environment, affected template: ESC1 (Domain Users can enrol).

AFFECTED ASSETS

- Template: ESC1
- Domain Users

RECOMMENDED FIX

Stop the template from honouring a requester-supplied SAN (+1 alternative)

Full step-by-step runbook, commands and validation: [AD Hardening Playbook](#) → F-001.

F-002

noPac/sAMAccountName Spoofing (CVE-2021-42278 + CVE-2021-42287)

CRITICAL

ADscan Priority 9.8 Critical CVE

VULNERABILITY

CWE-290 essos.local

METHODOLOGY Scored by the ADscan Priority model — no published CVSS Base vector applies to this finding.

DESCRIPTION

NoPac chains two Active Directory vulnerabilities to achieve domain compromise from any standard domain user account. CVE-2021-42278 permits creating machine accounts with a sAMAccountName that does not end in the required dollar sign (\$), meaning the account name can be set to match a Domain Controller's name exactly (e.g. 'DC01' instead of the legitimate 'DC01\$'). CVE-2021-42287 exploits a Kerberos PAC validation bug: when a service ticket is requested for a principal that no longer exists, the KDC falls back to searching with a trailing '\$' appended. An attacker exploits this combination by creating a machine account named 'DC01', requesting a TGT for it, renaming the account back to its original name so 'DC01' no longer exists, and then requesting a service ticket for 'DC01'. The KDC falls back to 'DC01\$', finds the legitimate Domain Controller, and issues a service ticket with DC-level privileges. The resulting ticket can be used for a full DCSync.

IMPACT

Any domain user can escalate to Domain Controller-level privileges within minutes and perform a full DCSync to extract every domain credential including KRBTGT. The attack requires only default permissions (ms-DS-MachineAccountQuota > 0, the default value is 10) and produces a Domain Admin-equivalent Kerberos ticket without interacting with any privileged account. The low barrier makes this exploitable by any attacker with a single valid domain credential. In this environment, affected host: MEEREEN.ESSOS.LOCAL (192.168.180.12).

AFFECTED ASSETS

- MEEREEN.ESSOS.LOCAL (192.168.180.12)

RECOMMENDED FIX

Patch all Domain Controllers (the only complete fix) (+1 alternative)

Full step-by-step runbook, commands and validation: [AD Hardening Playbook](#) → F-002.

F-003

ADCS ESC9 - No Security Extension on Certificate Template

CRITICAL

ADscan Priority 9.0 Critical

ADCS

• VULNERABILITY

CWE-269 essos.local

METHODOLOGY Scored by the ADscan Priority model — no published CVSS Base vector applies to this finding.

ADSCAN ANALYSIS

ESC9 template lacks security extension on Tier-0-relevant authentication path

DESCRIPTION

ADCS ESC9 exploits the CT_FLAG_NO_SECURITY_EXTENSION flag on a certificate template. When this flag is set, the szOID_NTDS_CA_SECURITY_EXT extension — which embeds the requester's SID into the issued certificate — is omitted. Without this SID binding, certificate-to-account mapping relies on UPN matching rather than strong SID-based identity verification. An attacker with GenericWrite access to an account that can enroll in the affected template can modify that account's UPN to match a high-privilege target (e.g., a Domain Admin UPN), obtain a certificate during that window, restore the UPN, and then use the issued certificate to authenticate as the target user. This technique bypasses the KB5014754 strong mapping protections when the security extension is absent.

IMPACT

Attackers can impersonate arbitrary domain users by temporarily manipulating UPN attributes on controllable accounts. The absence of the security extension means certificates cannot be reliably bound to their true issuance context, enabling persistent authentication bypass for accounts with enrollment access. In this environment, affected template: ESC9 (Spys, Account Operators, khal.drogo (+2 more) can enrol).

AFFECTED ASSETS

- Template: ESC9
- Account Operators
- khal.drogo
- missandei
- Spys
- viserys.targaryen

RECOMMENDED FIX

Remove CT_FLAG_NO_SECURITY_EXTENSION so the SID security extension is embedded (+1 alternative)

Full step-by-step runbook, commands and validation: [AD Hardening Playbook](#) → F-003.

F-004

ADCS ESC14 - Weak Explicit Certificate Mapping Abuse

CRITICAL

ADscan Priority 9.0 Critical ADCS **VULNERABILITY**

CWE-290 essos.local

METHODOLOGY Scored by the ADscan Priority model — no published CVSS Base vector applies to this finding.

ADSCAN ANALYSIS

ESC14 explicit mapping weakness affects Tier-0 authentication

DESCRIPTION

ADCS ESC14 abuses weak explicit certificate mappings configured through the altSecurityIdentities attribute. When administrators or applications rely on explicit mappings that are not strongly bound to the certificate holder's SID, an attacker who can enroll or obtain a suitable certificate can craft a cert that matches the weak mapping format and authenticate as the mapped account. This bypasses the intended identity binding guarantees of certificate-based authentication and can expose privileged accounts if they are explicitly mapped.

IMPACT

A weak explicit mapping can turn certificate enrollment or certificate theft into immediate privileged impersonation. If the mapped account is an admin, the attacker can authenticate directly as that identity and operate with the same rights as the victim without knowing the victim's password.

AFFECTED ASSETS

- Template: KERBEROS AUTHENTICATION
- Enterprise Read-only Domain Controllers

RECOMMENDED FIX

Remove weak altSecurityIdentities explicit mappings (+1 alternative)

Full step-by-step runbook, commands and validation: [AD Hardening Playbook](#) → F-004.

F-005

ADCS ESC2 - Any Purpose Certificate Template

CRITICAL

ADscan Priority 9.0 Critical

ADCS

• VULNERABILITY

CWE-269 essos.local

METHODOLOGY Scored by the ADscan Priority model — no published CVSS Base vector applies to this finding.

ADSCAN ANALYSIS

ESC2 'Any Purpose' template usable for Tier-0 client authentication

DESCRIPTION

ADCS ESC2 occurs when a certificate template is configured with the Any Purpose ECU or with no ECU at all. A certificate with Any Purpose ECU is valid for all certificate usages including client authentication, code signing, server authentication, and email encryption. Combined with low-privilege enrollment rights, this allows an attacker to obtain a certificate that can be used to authenticate as the enrolling user against any Kerberos-capable service. Unlike ESC1, the certificate is issued with the requester's own identity, but the Any Purpose ECU makes the resulting certificate a powerful credential for lateral movement and service access that typically bypasses certificate-based access controls.

IMPACT

Attackers can obtain a maximally privileged certificate with their own identity that can be used for authentication, code signing, and other sensitive operations. Combined with ESC3 (enrollment agent), an ESC2 certificate can be used to request certificates on behalf of other users, effectively bridging to ESC1-class exploitation. In this environment, affected template: ESC2 (Domain Users can enrol).

AFFECTED ASSETS

- Template: ESC2
- Domain Users

RECOMMENDED FIX

Replace the Any Purpose / no-ECU configuration with scoped EKUs (+1 alternative)

Full step-by-step runbook, commands and validation: [AD Hardening Playbook → F-005](#).

F-006

ADCS ESC3 - Enrollment Agent Template Abuse

CRITICAL

ADscan Priority 9.0 Critical ADCS • VULNERABILITY

CWE-269 essos.local

METHODOLOGY Scored by the ADscan Priority model — no published CVSS Base vector applies to this finding.

ADSCAN ANALYSIS

ESC3 enrollment-agent template enables Tier-0 enrollment-on-behalf-of

DESCRIPTION

ADCS ESC3 exploits the Certificate Request Agent ECU, which enables a principal to request certificates on behalf of other users. When a template with the Certificate Request Agent ECU is accessible to low-privilege users, an attacker can enroll to obtain an enrollment agent certificate. Using this agent certificate, the attacker can then request certificates on behalf of any domain user — including Domain Administrators — against a second template that permits agent enrollment. This two-step abuse chain allows complete identity impersonation without requiring knowledge of the target user's credentials or any direct interaction with them.

IMPACT

An attacker can impersonate any domain user, including Domain Administrators, through a legitimate two-stage certificate issuance chain. The resulting certificate provides full authentication capability as the impersonated user against all Kerberos-enabled services in the domain. In this environment, affected template: ESC3-CRA (Domain Users can enrol).

AFFECTED ASSETS

- Template: ESC3-CRA
- Domain Users

RECOMMENDED FIX

Restrict the enrollment-agent template and enforce Enrollment Agent Restrictions on the CA (+1 alternative)

Full step-by-step runbook, commands and validation: [AD Hardening Playbook → F-006](#).

F-007

ADCS ESC8 - NTLM Relay to Web Enrollment

HIGH

ADscan Priority 9.0 Critical ADCS • VULNERABILITY

CWE-306 essos.local

METHODOLOGY Scored by the ADscan Priority model — no published CVSS Base vector applies to this finding.

ADSCAN ANALYSIS

ESC8 provides a Tier-0 certificate abuse path

DESCRIPTION

ADCS ESC8 exploits the HTTP-based Certificate Enrollment web interface (certsrv) when NTLM authentication is permitted on the endpoint. An attacker who can coerce outbound NTLM authentication from a privileged host — such as a Domain Controller — using techniques including PetitPotam, PrinterBug, or DFSCoerce can relay that authentication to the CA web enrollment interface. The relayed NTLM session authenticates as the coerced host's machine account and requests a Domain Controller certificate. This DC certificate can then be used in a Pass-the-Certificate attack to request a Kerberos TGT as the DC machine account, enabling DCSync and full domain credential extraction.

IMPACT

Successful ESC8 exploitation against a Domain Controller certificate template enables full domain compromise through a DCSync attack, without requiring any initial privileged access. The attack chain — coerce DC authentication, relay to web enrollment, obtain DC certificate, DCSync — can be executed in minutes from a standard domain user account. In this environment, certification authority: ESSOS-CA.

AFFECTED ASSETS

- CA: ESSOS-CA
- Domain Users

RECOMMENDED FIX

Enable Extended Protection for Authentication (EPA) and require HTTPS on the enrollment endpoints (+1 alternative)

Full step-by-step runbook, commands and validation: [AD Hardening Playbook → F-007](#).

F-008

ADCS ESC5 - Vulnerable CA Object ACL

CRITICAL

ADscan Priority 9.0 Critical ADCS **VULNERABILITY**

CWE-269 essos.local

METHODOLOGY Scored by the ADscan Priority model — no published CVSS Base vector applies to this finding.

ADSCAN ANALYSIS

ESC5 PKI ACL exposure affects Tier-0 trust

DESCRIPTION

ADCS ESC5 involves misconfigured access controls on CA-level objects in Active Directory beyond certificate templates — including the CA server computer object, the CA object in the NTAuthCertificates store, the Enrollment Services container, and RPC/DCOM interfaces. When non-privileged principals hold write access to these objects, they can manipulate the CA infrastructure itself. Attacks may include modifying the CA computer object to enable RBCD-based impersonation, altering the NTAuthCertificates store, or exploiting delegated CA management permissions to issue fraudulent certificates directly.

IMPACT

Compromise of CA-level objects can undermine the entire PKI trust infrastructure for the domain. An attacker may be able to issue certificates for arbitrary identities, modify CA policy, or compromise the CA server itself, resulting in complete and persistent domain compromise that survives standard remediation procedures. In this environment, certification authority: ESSOS-CA.

AFFECTED ASSETS

- BRAAVOS.ESSOS.LOCAL (192.168.180.23)
- CA: ESSOS-CA

RECOMMENDED FIX

Lock down ACLs on CA infrastructure objects (+1 alternative)

Full step-by-step runbook, commands and validation: [AD Hardening Playbook → F-008](#).

F-009

ADCS ESC7 - Certificate Authority Privilege Abuse

CRITICAL



ADscan Priority 9.0 Critical

ADCS

VULNERABILITY

CWE-269 essos.local

METHODOLOGY Scored by the ADscan Priority model — no published CVSS Base vector applies to this finding.

ADSCAN ANALYSIS

ESC7 CA management rights enable Tier-0 certificate issuance

DESCRIPTION

ADCS ESC7 occurs when non-privileged users hold the Manage CA or Manage Certificates permissions on a Certificate Authority. The Manage CA right grants control over CA configuration and security settings, including the ability to enable the EDITF_ATTRIBUTESUBJECTALTNAME2 flag (ESC6), modify CA ACLs, and add certificate officers. The Manage Certificates right allows approval of pending certificate requests, including those that were submitted with a fraudulent SAN. An attacker with Manage Certificates can submit a certificate request for a privileged user's identity, set it to a pending state requiring approval, and then approve it themselves using their own management permission.

IMPACT

CA management rights provide near-complete control over the PKI trust infrastructure. An attacker can issue certificates for Domain Admins, modify CA policy to introduce persistent vulnerabilities, or manipulate certificate lifecycle in ways that enable persistent authentication bypass across the domain. In this environment, certification authority: ESSOS-CA.

AFFECTED ASSETS

- BRAAVOS.ESSOS.LOCAL (192.168.180.23)
- CA: ESSOS-CA

RECOMMENDED FIX

Remove Manage CA / Manage Certificates from non-PKI principals and enforce separation of duties (+1 alternative)

Full step-by-step runbook, commands and validation: [AD Hardening Playbook → F-009](#).

F-010

ADCS ESC4 - Vulnerable Certificate Template ACL

CRITICAL

ADscan Priority 9.0 Critical ADCS **VULNERABILITY**

CWE-269 essos.local

METHODOLOGY Scored by the ADscan Priority model — no published CVSS Base vector applies to this finding.

ADSCAN ANALYSIS

ESC4 template ACL grants modification rights affecting Tier-0 enrollment

DESCRIPTION

ADCS ESC4 occurs when non-privileged principals hold write permissions (WriteProperty, WriteDACL, WriteOwner, or GenericWrite) on a certificate template object in Active Directory. Certificate template objects are stored in the Configuration naming context and are subject to standard AD ACL controls. With template modification rights, an attacker can alter the template configuration to introduce ESC1-class vulnerabilities — enabling SAN specification, removing EKU restrictions, or disabling manager approval — obtain a fraudulent certificate, and then optionally revert the changes to avoid detection. This technique escalates an otherwise safe template into an exploitable one without leaving persistent misconfiguration evidence.

IMPACT

An attacker with write access to any template can temporarily transform it into an ESC1-exploitable template, obtain a certificate impersonating a Domain Administrator, then revert the change. The window of exploitation is brief and may not trigger template misconfiguration monitoring, making this a stealthy path to domain compromise. In this environment, affected template: ESC4 (khal.drogo can enrol).

AFFECTED ASSETS

- Template: ESC4
- khal.drogo

RECOMMENDED FIX

Remove dangerous write ACEs from the template object (+1 alternative)

Full step-by-step runbook, commands and validation: [AD Hardening Playbook](#) → F-010.

F-011

LAPS Password Readable by Non-Admins

HIGH

ADscan Priority 8.8 High CVSS Base 6.5 LAPS VULNERABILITY
CWE-522 essos.local
CVSS 3.1 VECTOR CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

ADSCAN ANALYSIS

LAPS attributes readable for Tier-0 assets — privileged local admin credential exposure

DESCRIPTION

The Local Administrator Password Solution (LAPS) stores per-machine local administrator credentials in the ms-Mcs-AdmPwd attribute of computer objects in Active Directory. By design, only designated administrative groups should have read access to this attribute. When the ACL on computer objects grants read access to non-privileged accounts — such as broad user groups, domain users, or helpdesk tiers — any member of those groups can query the attribute and retrieve the current plaintext local administrator password for any LAPS-managed machine. This misconfiguration is commonly introduced during LAPS deployment when access delegation is overly permissive.

IMPACT

Non-privileged users can retrieve local administrator passwords for any LAPS-managed machine in the affected OUs. This enables lateral movement to those machines with full local administrative rights, bypassing the security benefit that LAPS was deployed to provide. In environments where local administrator accounts have network access, this can escalate rapidly. In this environment, the local administrator password is readable on computer BRAAVOS.ESSOS.LOCAL (192.168.180.23) by Spys and jorah.mormont.

AFFECTED ASSETS

- BRAAVOS.ESSOS.LOCAL (192.168.180.23)
- jorah.mormont
- Spys

RECOMMENDED FIX

Remove non-admin read access to the LAPS password attribute and rotate (+1 alternative)

Full step-by-step runbook, commands and validation: [AD Hardening Playbook](#) → F-011.

F-012

PrintNightmare Vulnerable Hosts Detected

HIGH



ADscan Priority 8.8 High CVSS Base 8.8 CVE **VULNERABILITY**
CWE-269 essos.local
CVSS 3.1 VECTOR CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

DESCRIPTION

PrintNightmare (CVE-2021-34527) is a critical vulnerability in the Windows Print Spooler service that allows authenticated users to load arbitrary DLLs through the AddPrinterDriverEx() RPC call by specifying a UNC path to a malicious driver package. The vulnerability exists in both a remote variant (RCE via network RPC) and a local variant (LPE via local named pipe). Remote exploitation is possible when the Print Spooler service accepts remote client connections, which is common on servers that act as print servers. The service runs as SYSTEM, meaning any loaded DLL executes with the highest privilege level on the host.

IMPACT

An authenticated domain user can remotely execute arbitrary code as SYSTEM on any vulnerable host where the Print Spooler accepts remote connections. When the affected host is a Domain Controller, this results in immediate domain-level compromise. The low authentication bar (any valid domain account) makes this vulnerability high-severity in any Active Directory environment where Print Spooler is running on critical systems. In this environment, affected hosts: MEEREEN.ESSOS.LOCAL (192.168.180.12) and BRAAVOS.ESSOS.LOCAL (192.168.180.23).

AFFECTED ASSETS

- BRAAVOS.ESSOS.LOCAL (192.168.180.23)
- MEEREEN.ESSOS.LOCAL (192.168.180.12)

RECOMMENDED FIX

Patch and disable the Print Spooler where unused (+1 alternative)

Full step-by-step runbook, commands and validation: [AD Hardening Playbook → F-012](#).

F-013

Domain Controller Accepts NTLMv1 Authentication

HIGH



ADscan Priority 8.5 High AUTHENTICATION • CHAIN PREREQUISITE

CWE-327 essos.local

METHODOLOGY Scored by the ADscan Priority model — no published CVSS Base vector applies to this finding.

ADSCAN ANALYSIS

NTLMv1 accepted by Domain Controllers — challenge/response is trivially crackable

DESCRIPTION

If the Domain Controller authenticates back using NTLMv1 during a coerced callback, the environment still permits a legacy NTLM mode with materially weaker cryptographic protections. NTLMv1 is significantly easier to relay, crack, and abuse than NTLMv2 and should be treated as deprecated in enterprise Active Directory.

IMPACT

NTLMv1 acceptance weakens the authentication posture of the domain and increases the chance that coerced or intercepted authentication can be replayed against another service or cracked offline. Where present on Domain Controllers, the resulting exposure affects the most sensitive authentication boundary in the environment. In this environment, affected host: MEEREEN.ESSOS.LOCAL (192.168.180.12).

AFFECTED ASSETS

- MEEREEN.ESSOS.LOCAL (192.168.180.12)

RECOMMENDED FIX

Refuse LM and NTLMv1 domain-wide (LmCompatibilityLevel 5) (+1 alternative)

Full step-by-step runbook, commands and validation: [AD Hardening Playbook](#) → F-013.

F-014

gMSA Password Readable by Non-Admins

HIGH

●

ADscan Priority 7.5 High

CVSS Base 6.5

GMSA

● VULNERABILITY

CWE-522 essos.local

CVSS 3.1 VECTOR CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

DESCRIPTION

Group Managed Service Accounts (gMSA) are a special account type in Active Directory that provides automatic password management for service accounts. The password is stored in the msDS-ManagedPassword attribute of the gMSA object and is only readable by principals listed in the msDS-GroupMSAMembership attribute. When this access control list is misconfigured to include non-privileged groups or overly broad membership, any member can retrieve the gMSA password blob using the DSGetPassword API. The password is returned as an MSDS-MANAGEDPASSWORD_BLOB structure that can be parsed to extract the current NT hash, enabling Pass-the-Hash attacks or Kerberos ticket requests using the gMSA's identity.

IMPACT

Compromise of a gMSA password provides full impersonation of the service account, including all associated service permissions, SPN-based access, and any delegated rights. Service accounts typically have privileged access to databases, web services, backup systems, and other critical infrastructure, making this a high-impact finding depending on the gMSA's configured permissions. In this environment, the managed-service-account password is readable for account gmsaDragon\$ by BRAAVOS.ESSOS.LOCAL (192.168.180.23).

AFFECTED ASSETS

- BRAAVOS.ESSOS.LOCAL (192.168.180.23)
- gmsaDragon\$

RECOMMENDED FIX

Restrict msDS-GroupMSAMembership to the hosts that run the service (+1 alternative)

Full step-by-step runbook, commands and validation: [AD Hardening Playbook → F-014](#).

F-015

SMBv1 Protocol Enabled

HIGH



ADscan Priority 7.5 High NETWORK SECURITY

VULNERABILITY

CWE-1104 essos.local

METHODOLOGY Scored by the ADscan Priority model — no published CVSS Base vector applies to this finding.

DESCRIPTION

One or more hosts respond to SMBv1 (NT LM 0.12) negotiate requests. SMBv1 is a legacy protocol deprecated by Microsoft since 2014. It lacks modern security features (encryption, secure negotiate, pre-auth integrity) and is directly exploited by EternalBlue (MS17-010), EternalRomance, and related NSA-derived tools that enabled WannaCry and NotPetya ransomware. Microsoft has disabled SMBv1 by default since Windows 10 1709.

IMPACT

Hosts with SMBv1 enabled are vulnerable to EternalBlue (MS17-010) and related exploits if unpatched, and remain exposed to SMBv1-specific attack primitives (NTLM downgrade, signing bypass) regardless of patch status. Domain Controllers with SMBv1 represent a critical exposure.

AFFECTED ASSETS

- BRAAVOS.ESSOS.LOCAL (192.168.180.23)
- MEEREEN.ESSOS.LOCAL (192.168.180.12)

RECOMMENDED FIX

Disable SMBv1 server and client across the estate (+1 alternative)

Full step-by-step runbook, commands and validation: [AD Hardening Playbook → F-015](#).

F-016

AS-REP Roasting

MEDIUM



ADscan Priority 6.9 Medium CVSS Base 5.3 KERBEROS **VULNERABILITY**

CWE-522 essos.local

CVSS 3.1 VECTOR CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

DESCRIPTION

Preauthentication offers protection against offline Password Cracking. When enabled, a user requesting access to a resource initiates communication with the Domain Controller (DC) by sending an Authentication Server Request (AS-REQ) message with a timestamp that is encrypted with the hash of their password. If and only if the DC is able to successfully decrypt the timestamp with the hash of the user's password, it will then send an Authentication Server Response (AS-REP) message that contains the Ticket Granting Ticket (TGT) to the user. Part of the AS-REP message is signed with the user's password. For each account found without preauthentication, an adversary may send an AS-REQ message without the encrypted timestamp and receive an AS-REP message with TGT data which may be encrypted with an insecure algorithm such as RC4. The recovered encrypted data may be vulnerable to offline Password Cracking attacks similarly to Kerberoasting and expose plaintext credentials.

IMPACT

A successful AS-REP Roasting attack along with cracked passwords could lead to lateral movement and privilege escalation in an AD environment. If a password is cracked for a Domain Administrator account or equivalent, an attacker could gain control over most, if not all, resources in the domain. In this environment, affected account: missandei.

AFFECTED ASSETS

- Domain Users
- missandei

RECOMMENDED FIX

Re-enable Kerberos pre-authentication on affected accounts (+1 alternative)

Full step-by-step runbook, commands and validation: [AD Hardening Playbook → F-016](#).

F-017

Kerberoasting

MEDIUM

●

ADscan Priority 5.3 Medium

CVSS Base 4.3

KERBEROS

VULNERABILITY

CWE-522 essos.local

CVSS 3.1 VECTOR CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N

DESCRIPTION

In an Active Directory (AD) environment, Service Principal Names (SPNs) are used to uniquely identify instances of a Windows service. Kerberos authentication requires that each SPN be associated with one service account (Active Directory user account). Any authenticated AD user can request one or more Kerberos Ticket-Granting Service (TGS) tickets from the domain controller for any SPN accounts. These tickets are encrypted with the associated AD account's NTLM password hash. They can be brute forced offline with GPU-accelerated password cracking if a weak password is used along with the RC4 encryption algorithm. If AES encryption is in use, it will take more resources to crack a ticket to reveal the account's clear-text password, but it is possible if weak passwords are in use.

IMPACT

A successful Kerberoasting attack along with cracked passwords could lead to lateral movement and privilege escalation in an AD environment. If a password is cracked for a Domain Administrator account or equivalent, an attacker could gain control over most, if not all, resources in the domain. In this environment, affected account: sql_svc.

AFFECTED ASSETS

- sql_svc
- Domain Users

RECOMMENDED FIX

Migrate the SPN to a Group Managed Service Account (gMSA) (+1 alternative)

Full step-by-step runbook, commands and validation: [AD Hardening Playbook → F-017](#).

F-018

Weak Default Domain Password Policy

MEDIUM

ADscan Priority 5.3 Medium DOMAIN CONFIGURATION VULNERABILITY

CWE-521 essos.local

METHODOLOGY Scored by the ADscan Priority model — no published CVSS Base vector applies to this finding.

DESCRIPTION

The Default Domain Password Policy fails one or more of the industry-standard controls (CIS Microsoft Windows Server Benchmark, Microsoft Security Baseline, DISA STIG): account lockout threshold, minimum password length, or the complexity requirement. Each loose control reduces the cost of credential-based attacks against the domain. Together they make password spraying, offline cracking, and low-entropy guessing trivially viable for any unprivileged principal that reaches authentication endpoints (LDAP, Kerberos, SMB, OWA, RDP, VPN front-doors).

IMPACT

Combined sub-issues compound attacker capability: account lockout disabled removes the natural ceiling on spray attempts; short minimum length brings passwords into consumer-GPU password-cracking reach (sub-8 chars: minutes per hash; 8-13 chars with dictionaries+rules: hours to days); complexity disabled allows trivially-structured passwords (seasons, company name + year, default keyboard patterns) that exhaust within the first few hundred spray candidates. Any single sub-issue raises the risk; their combination predicts initial-access compromise within a typical engagement window.

AFFECTED ASSETS

- essos.local

OBSERVED VS RECOMMENDED

SETTING	OBSERVED	RECOMMENDED	SOURCE
min pwd length	5	≥ 14	CIS Microsoft Windows Server Benchmark (L1)
complexity enabled	False	= True	Microsoft Security Baseline
pwd history length	24	≥ 24	CIS Microsoft Windows Server Benchmark
lockout threshold	5	≤ 5	CIS Microsoft Windows Server Benchmark
max pwd age days	Never expires (set to 37,201 days)	≤ 365	Microsoft Security Baseline

RECOMMENDED FIX

Harden the Default Domain Password Policy to the CIS / Microsoft baseline (+1 alternative)

Full step-by-step runbook, commands and validation: [AD Hardening Playbook → F-018](#).

F-019

SMB Signing Not Required

MEDIUM



ADscan Priority 5.0 Medium NETWORK SECURITY POSTURE

CWE-300 essos.local

METHODOLOGY Scored by the ADscan Priority model — no published CVSS Base vector applies to this finding.

DESCRIPTION

One or more domain-joined computers do not require SMB packet signing. When SMB signing is not enforced, an attacker in a man-in-the-middle position can relay NTLM authentication from these hosts to other services, authenticate as the relayed identity, and potentially execute code or access resources without knowing the credential.

IMPACT

Hosts with SMB signing disabled are viable relay targets. If the relayed credential belongs to a Domain Admin or computer account with unconstrained delegation, a single intercepted authentication can lead to full domain compromise. Domain Controllers with signing disabled are particularly severe as they represent the highest-value relay target in the environment.

AFFECTED ASSETS

- BRAAVOS.ESSOS.LOCAL (192.168.180.23)

RECOMMENDED FIX

Require SMB signing on both server and client via GPO (+1 alternative)

Full step-by-step runbook, commands and validation: [AD Hardening Playbook](#) → F-019.

F-020

Accounts with Non-Expiring Passwords

LOW

ADscan Priority 3.7 Low

POLICY

• POSTURE

CWE-521 essos.local

METHODOLOGY Scored by the ADscan Priority model — no published CVSS Base vector applies to this finding.

DESCRIPTION

Accounts configured with the DONT_EXPIRE_PASSWORD flag are exempt from the domain's password expiration policy, meaning their credentials remain valid indefinitely unless manually changed. While this configuration is sometimes necessary for service accounts running as specific identities, it is frequently applied broadly to user accounts for convenience, or inherited from legacy configurations. Long-lived credentials are statistically more likely to have been exposed through phishing, credential dumping incidents, data breaches, or pass-the-hash attacks that were not detected at the time. An attacker in possession of a non-expiring credential retains access indefinitely unless the compromise is specifically identified and the password is manually rotated.

IMPACT

Compromised non-expiring credentials provide persistent access with no natural remediation deadline. In environments where password rotation is the primary credential invalidation mechanism, these accounts create permanent persistence opportunities for attackers who have obtained the credentials through any means.

AFFECTED ASSETS

- Administrator
- sql_svc
- adscan
- daenerys.targaryen
- drogon
- jorah.mormont
- khal.drogo
- missandei
- viserys.targaryen

RECOMMENDED FIX

Remove DONT_EXPIRE_PASSWORD from standard accounts (+1 alternative)

Full step-by-step runbook, commands and validation: [AD Hardening Playbook → F-020](#).

F-021

Machine Account Quota Allows Domain Join

LOW



ADscan Priority 3.5 Low DOMAIN CONFIGURATION POSTURE

CWE-284 essos.local

METHODOLOGY Scored by the ADscan Priority model — no published CVSS Base vector applies to this finding.

DESCRIPTION

The ms-DS-MachineAccountQuota attribute is set to a value greater than 0. This allows any authenticated domain user to join computers to the domain up to the configured limit, which can be abused for RBCD attacks, DNS poisoning via fake computer objects, or Kerberos relay attack preparation.

IMPACT

An attacker with any valid domain credential can create computer objects under their control, enabling Resource-Based Constrained Delegation (RBCD) attacks, Kerberos relay setups (e.g. noPac), and persistence via machine accounts.

AFFECTED ASSETS

- essos.local

RECOMMENDED FIX

Set ms-DS-MachineAccountQuota to 0 (+1 alternative)

Full step-by-step runbook, commands and validation: [AD Hardening Playbook](#) → F-021.

F-022

Passwords Predating Current Policy

LOW

ADscan Priority 3.5 Low IDENTITY HYGIENE POSTURE

CWE-521 essos.local

METHODOLOGY Scored by the ADscan Priority model — no published CVSS Base vector applies to this finding.

DESCRIPTION

One or more enabled user accounts have a password that was last set before the most recent modification to the applicable password policy (Default Domain Policy or a Fine-Grained PSO). The current policy requirements — minimum length, complexity, or maximum age — were not in effect when the credential was created. Active Directory does not retroactively force a reset on policy changes, so these accounts may carry credentials that do not comply with the organisation's current security baseline.

IMPACT

Credentials established under a weaker policy may be shorter, simpler, or older than the current standard allows. Attackers obtaining these hashes through LDAP, Kerberoasting, or credential dumping face a reduced cracking workload. When affected accounts are Tier-0 or high-value identities, the impact escalates to potential domain compromise.

AFFECTED ASSETS

- Administrator
- daenerys.targaryen
- drogon
- jorah.mormont
- khal.drogo
- missandei
- viserys.targaryen

RECOMMENDED FIX

Force a reset on accounts whose pwdLastSet predates the policy change (+1 alternative)

Full step-by-step runbook, commands and validation: AD Hardening Playbook → F-022.

Compromised Credentials

Accounts whose credentials were recovered during the assessment, with the method used to obtain each. Secret values are never stored or reproduced in this report; only the credential type is shown. Where an account was reached by more than one technique, every route is listed — closing one of them leaves the others open.

Domain · essos.local

ACCOUNT	METHOD	ROUTES	CREDENTIAL TYPE
administrator	ADCS ESC1 · also via DCSync	2 INDEPENDENT	NT HASH
daenerys.targaryen	DCSync	1	PASSWORD
drogon	DCSync	1	PASSWORD
jorah.mormont	DCSync	1	NT HASH
khal.drogo	DCSync	1	PASSWORD
krbtgt	DCSync	1	NT HASH
missandei	DCSync	1	PASSWORD
sql_svc	DCSync	1	NT HASH
vagrant	DCSync	1	PASSWORD

ACCOUNT	METHOD	ROUTES	CREDENTIAL TYPE
viserys.targaryen	DCSync	1	PASSWORD

Recovered credentials were tested against the ADscan AD Audit Wordlist — 94 million entries, curated and frequency-ordered (most-crackable-first) for Active Directory service and user accounts.

Built on public credential-research corpora (hashmob, kerberoast_pws, kaonashi), deduplicated with order-preserving merge and tuned by ADscan for AD audit workloads. Per-domain targeted candidates are always tested first.

04

MITRE ATT&CK Coverage

Techniques exercised across the identified attack surface.

TECHNIQUE	NAME	LINKED FINDINGS
T1068	Exploitation for Privilege Escalation	PrintNightmare Vulnerable Hosts Detected, noPac/sAMAccountName Spoofing (CVE-2021-42278 + CVE-2021-42287)
T1078	Valid Accounts	Accounts with Non-Expiring Passwords, Passwords Predating Current Policy, Domain Controller Accepts NTLMv1 Authentication
T1110.002	Brute Force: Password Cracking	Weak Default Domain Password Policy
T1110.003	Brute Force: Password Spraying	Weak Default Domain Password Policy
T1210	Exploitation of Remote Services	SMBv1 Protocol Enabled
T1555	Credentials from Password Stores	LAPS Password Readable by Non-Admins, gMSA Password Readable by Non-Admins
T1557	Adversary-in-the-Middle	Domain Controller Accepts NTLMv1 Authentication
T1557.001	LLMNR/NBT-NS Poisoning and SMB Relay	SMB Signing Not Required
T1558	Steal or Forge Kerberos Tickets	noPac/sAMAccountName Spoofing (CVE-2021-42278 + CVE-2021-42287)
T1558.003	Steal or Forge Kerberos Tickets: Kerberoasting	Kerberoasting
T1558.004	Steal or Forge Kerberos Tickets: AS-REP Roasting	AS-REP Roasting
T1649	Steal or Forge Authentication Certificates	ADCS ESC9 - No Security Extension on Certificate Template, ADCS ESC14 - Weak Explicit Certificate Mapping Abuse, ADCS ESC1 - Misconfigured Certificate Template, ADCS ESC2 - Any Purpose Certificate Template, ADCS ESC3 - Enrollment Agent Template Abuse, ADCS ESC8 - NTLM Relay to Web Enrollment, ADCS ESC5 - Vulnerable CA Object ACL, ADCS ESC7 - Certificate Authority Privilege Abuse, ADCS ESC4 - Vulnerable Certificate Template ACL

12 techniques observed across 3 tactics

Density mapped to MITRE ATT&CK · darker cells indicate higher finding concentration or more severe exposure.

RECONNAISSANCE	RESOURCE DEVELOPMENT	INITIAL ACCESS	EXECUTION	PERSISTENCE	PRIVILEGE ESCALATION	DEFENSE EVASION	CREDENTIAL ACCESS	DISCOVERY	LATERAL MOVEMENT	COLLECTION	COMMAND AND CONTROL	EXFILTRATION	IMPACT
		T1133		T1098	T1134	T1027	T1003	T1018	T1021.001				T1486
		T1190		T1136	T10682	T1070	T1003.001	T1069	T1021.002				
					T10783	T1556.007	T1003.006	T1087	T12101				
					T1078.002		T1110	T1087.002	T1550.002				
							T1110.001	T1482	T1550.003				
							T1110.0021		T1570				
							T1110.0031						
							T1187						
							T1556						
							T15571						
							T1552						
							T1552.001						
							T1552.006						
							T15552						
							T1557.0011						
							T15581						
							T1558.0031						
							T1558.0041						
							T16499						

Density none → low → moderate → high

12 techniques · 3 tactics · 22 findings

How the attack chain unfolded

Earliest tactic to most recent · severity-coded · catalog-aligned to MITRE ATT&CK.

PRIVILEGE ESCALATION

	T1068	Exploitation for Privilege Escalation	2 findings	CRITICAL
	T1078	Valid Accounts	3 findings	HIGH

CREDENTIAL ACCESS

	T1558	Steal or Forge Kerberos Tickets	1 finding	CRITICAL
	T1649	Steal or Forge Authentication Certificates	9 findings	CRITICAL
	T1555	Credentials from Password Stores	2 findings	HIGH
	T1557	Adversary-in-the-Middle	1 finding	HIGH
	T1110.002	Password Cracking	1 finding	MEDIUM
	T1110.003	Password Spraying	1 finding	MEDIUM
	T1557.001	LLMNR/NBT-NS Poisoning + SMB Relay	1 finding	MEDIUM
	T1558.003	Kerberoasting	1 finding	MEDIUM
	T1558.004	AS-REP Roasting	1 finding	MEDIUM

LATERAL MOVEMENT

	T1210	Exploitation of Remote Services	1 finding	HIGH
---	-------	---------------------------------	-----------	-------------

DOMAIN COMPROMISE

	DA	Full Domain Compromise Reached	19 paths to full domain compromise	CRITICAL
---	----	--------------------------------	------------------------------------	-----------------

The assessment identified 19 routes to full domain compromise, 1 of which was validated end to end. The kill-chain spans 3 ATT&CK tactics across 12 techniques, with credential access as the primary pivot. Immediate remediation should focus on the techniques flagged below before any compensating control work.

05 DORA Compliance

DORA ICT risk management obligations affected by AD security findings.

DORA: Digital Operational Resilience Act

DORA focuses on ICT risk management and operational resilience for financial entities. Active Directory attack paths and identity control gaps indicate where compromise could disrupt critical ICT services and trigger reporting obligations.



7
NON-CONFORMANT

2
PARTIAL

0
CONFORMANT

9
CONTROLS ASSESSED

1
NOT ASSESSED

CERTIFICATION RISK · HIGH

7 major non-conformities identified. Address before the next certification or surveillance audit.

Conformance of assessed AD-relevant controls only. ADscan evaluates the Active Directory attack surface in scope for this engagement; controls outside that scope are marked **Not assessed** and are excluded from this percentage. This figure is therefore the conformance of what was tested, not an overall framework certification posture.

ICT RISK MANAGEMENT

6 controls · 4 non-conformant · 1 partial · 0 conformant · 1 not assessed

INCIDENT MANAGEMENT

2 controls · 2 non-conformant · 0 conformant

RESILIENCE & RECOVERY

1 controls · 1 non-conformant · 0 conformant

GOVERNANCE

1 controls · 1 partial · 0 conformant

Non-conformity Summary

Gaps classified by audit severity. Major non-conformities typically trigger corrective action requests (CARs) in certification audits.

MAJOR NON-CONFORMITIES			MINOR NON-CONFORMITIES / OBSERVATIONS		
art_9_4	Protection: identity & MFA	9.9	art_5	Governance and organisation	3.7
art_17	ICT-related incident management process	9.9	art_10	Detection	0.0
art_19	Reporting of major ICT-related incidents	9.9			

art_9_2	Protection: access control	9.8
art_9_3	Protection: network security	9.0
art_11	Response and recovery	8.8
art_6	ICT risk management framework	8.5

Major non-conformities: ADscan Priority ≥ 7.0. Minor non-conformities: ADscan Priority < 7.0 or attack paths only. Classification is indicative; auditor judgment may differ.

Control Assessment

Controls sorted by conformity status. Non-conformant controls carry the highest audit risk. One attack chain often bears on several obligations, so chains are counted against each control they affect and set out in full once, in the attack-path section. Each control counts the chains that bear on that obligation and still represent open exposure, which is why the figure differs between controls and is stated against the assessment total.

art_9_4

ICT RISK MANAGEMENT

NON-CONFORMANT · MAJOR

Protection: identity & MFA

Financial entities must implement strong authentication mechanisms. Per Art. 9(4) and Commission Delegated Regulation (EU) 2024/1774, this explicitly requires: ...

AFFECTED FINDINGS

ADCS ESC1 - Misconfigured Certificate Template9.9

noPac/sAMAccountName Spoofing (CVE-2021-42278 + CVE-2021-42287)9.8

ADCS ESC14 - Weak Explicit Certificate Mapping Abuse9.0

ADCS ESC2 - Any Purpose Certificate Template9.0

ADCS ESC3 - Enrollment Agent Template Abuse9.0

+12 more

ATTACK-PATH EVIDENCE

22 of the 30 attack chains identified in this assessment · 1 validated end to end · 13 partially validated · 8 identified by configuration analysis

art_17

INCIDENT MANAGEMENT

NON-CONFORMANT · MAJOR

ICT-related incident management process

Financial entities must define, establish and implement an ICT-related incident management process to detect, manage and notify ICT-related incidents. This is t...

AFFECTED FINDINGS

ADCS ESC1 - Misconfigured Certificate Template9.9

PrintNightmare Vulnerable Hosts Detected8.8

ATTACK-PATH EVIDENCE

24 of the 30 attack chains identified in this assessment · 1 validated end to end · 13 partially validated · 10 identified by configuration analysis

art_19

INCIDENT MANAGEMENT

NON-CONFORMANT · MAJOR

Reporting of major ICT-related incidents

Financial entities must report major ICT-related incidents to the relevant competent authority. Per Art. 19 and Commission Delegated Regulation (EU) 2025/301, t...

AFFECTED FINDINGS

ADCS ESC1 - Misconfigured Certificate Template9.9

PrintNightmare Vulnerable Hosts Detected8.8

ATTACK-PATH EVIDENCE

22 of the 30 attack chains identified in this assessment · 1 validated end to end · 13 partially validated · 8 identified by configuration analysis

art_9_2

ICT RISK MANAGEMENT

NON-CONFORMANT · MAJOR

Protection: access control

Financial entities must implement access control policies based on least-privilege principles, ensuring that access to systems is granted only as necessary for ...

AFFECTED FINDINGS

noPac/sAMAccountName Spoofing (CVE-2021-42278 + CVE-2021-42287)9.8

LAPS Password Readable by Non-Admins8.8

gMSA Password Readable by Non-Admins7.5

Machine Account Quota Allows Domain Join3.5

ATTACK-PATH EVIDENCE

24 of the 30 attack chains identified in this assessment · 1 validated end to end · 13 partially validated · 10 identified by configuration analysis

art_9_3

ICT RISK MANAGEMENT

NON-CONFORMANT · MAJOR

Protection: network security

Financial entities must have in place security measures against network intrusions and data misuse. This includes network segmentation, perimeter protections, a...

AFFECTED FINDINGS

ADCS ESC8 - NTLM Relay to Web Enrollment9.0

Domain Controller Accepts NTLMv1 Authentication8.5

SMBv1 Protocol Enabled7.5

SMB Signing Not Required5.0

ATTACK-PATH EVIDENCE

2 of the 30 attack chains identified in this assessment · 2 identified by configuration analysis

art_11

RESILIENCE & RECOVERY

NON-CONFORMANT · MAJOR

Response and recovery

Financial entities must implement a dedicated ICT business continuity policy that enables rapid response to, and recovery from, major ICT-related incidents. Thi...

AFFECTED FINDINGS

PrintNightmare Vulnerable Hosts Detected8.8

ATTACK-PATH EVIDENCE

22 of the 30 attack chains identified in this assessment · 1 validated end to end · 13 partially validated · 8 identified by configuration analysis

art_6

ICT RISK MANAGEMENT

NON-CONFORMANT · MAJOR

ICT risk management framework

Financial entities must have a sound, comprehensive and well-documented ICT risk management framework as part of their overall risk management system. The frame...

AFFECTED FINDINGS

Domain Controller Accepts NTLMv1 Authentication8.5

SMBv1 Protocol Enabled7.5

AS-REP Roasting6.9

Kerberoasting5.3

Weak Default Domain Password Policy5.3

+3 more

ATTACK-PATH EVIDENCE

24 of the 30 attack chains identified in this assessment · 1 validated end to end · 13 partially validated · 10 identified by configuration analysis

art_5

GOVERNANCE

PARTIALLY CONFORMANT · MINOR

Governance and organisation

The management body of the financial entity must define, approve, oversee and be accountable for the implementation of all arrangements related to the ICT risk ...

AFFECTED FINDINGS

Accounts with Non-Expiring Passwords3.7

ATTACK-PATH EVIDENCE

art_10

ICT RISK MANAGEMENT

PARTIALLY CONFORMANT · MINOR

Detection

Financial entities must have mechanisms to promptly detect anomalous activities, including ICT network performance and ICT-related incidents. Detection mechanis...

ATTACK-PATH EVIDENCE

24 of the 30 attack chains identified in this assessment · 1 validated end to end · 13 partially validated · 10 identified by configuration analysis

art_8

ICT RISK MANAGEMENT

NOT ASSESSED

Identification

Financial entities must identify, classify and adequately document all ICT supported business functions, roles and responsibilities, information assets and ICT ...

Outside the scope of this AD assessment. Not assessed.

06

Attack Path Remediation Priorities

Ranked actions that eliminate the maximum number of attack paths per remediation effort.

The following analysis identifies which attack techniques and vulnerabilities appear across the most attack paths. Addressing the top items first maximises exposure reduction per unit of remediation effort. A single fix can close multiple independent compromise routes simultaneously.

This table ranks by breadth: how many separate routes one fix closes. The remediation roadmap orders the same work by each finding's own priority score, so the two sections lead with different items and neither is wrong. Pre-Authentication-less Credential Theft (ASREPROasting) leads here and sits in the 30-90 day block of the roadmap. Closing it removes the cheapest way in to the 13 chains that share it, but not the misconfigurations those chains end at — each of which is severe on its own, which is why the roadmap puts them first. Work the roadmap's order, and use this table to decide which item inside each block buys the most.

HIGHEST-IMPACT SINGLE REMEDIATION

Eliminating **Pre-Authentication-less Credential Theft (ASREPROasting)** would directly close **13 attack paths (43%)** of all identified compromise routes. This remediation is assessed as **Low complexity**.

Attack Technique Priorities

Each row represents one attack technique type found across multiple paths. "Paths Eliminated" shows how many attack paths would be disrupted by addressing it.

#	TECHNIQUE	PATHS ELIMINATED	ACCOUNTS COVERED	REMEDiation GUIDANCE
1	Pre-Authentication-less Credential Theft (ASREPROasting) T1558.004 · Steal or Forge Kerberos Tickets: AS-REP Roasting	13 paths 43% of total	1 account	LOW Enable Kerberos pre-authentication on all accounts (UF_DONT_REQUIRE_PREAUTH must not be set). - Enable Kerberos pre-authentication for MISSANDEI@ESSOS.LOCAL (clear DONT_REQ_PREAUTH in userAccountControl). - Enforce strong passwords on accounts that must keep pre-auth disabled. - Monitor Event ID 4768 with pre-authentication type 0 for anomalous requests.
2	Full Control of the Target Object (GenericAll) T1098 · Account Manipulation	12 paths 40% of total	3 accounts	MEDIUM Remove the GenericAll ACE from the target object's ACL: inspect it with `dscls "<targetDN>"` (or `(Get-Acl "AD:\<targetDN>").Access`), then strip the offending entry with `dscls "<targetDN>" /R "<DOMAIN\principal>"`. Audit AD ACLs regularly with the native `Get-Acl`/`dscls` tooling and enforce least-privilege delegation — grant only the specific rights required (Delegation of Control wizard or scoped ACEs), never full control. Remove the GenericAll ACE that MISSANDEI@ESSOS.LOCAL holds over KHAL.DROGO@ESSOS.LOCAL. Resolve the object's distinguished name with `Get-ADObject -LDAPFilter '(sAMAccountName=<target>)'`, list what MISSANDEI@ESSOS.LOCAL currently holds on it with `(Get-Acl "AD:\<targetDN>").Access   Where-Object IdentityReference -like '*<principal>*'`, then delete those entries with `dscls "<targetDN>" /R "<DOMAIN>\<principal>"`. Before: the entry reads ActiveDirectoryRights=GenericAll, AccessControlType=Allow. After: the same query returns nothing for that principal.

#	TECHNIQUE	PATHS ELIMINATED	ACCOUNTS COVERED	REMEDiation GUIDANCE
				- Grant back only the rights the delegation actually needs, never full control. GenericAll carries password reset, key-credential write, servicePrincipalName write and script-path write in one ACE, so any one of them left in place restores the takeover — which is why narrowing it is the fix and auditing it is not. Use the Delegation of Control wizard, or a scoped ACE such as `dscls "<targetDN>" /G "<DOMAIN>\<helpdeskGroup>:CA;Reset Password"` when password reset is genuinely required. - Confirm no other principal holds equivalent control over the same object: `(Get-Acl "AD:\<targetDN>").Access   Where-Object { \$_.ActiveDirectoryRights -match 'GenericAll WriteDac WriteOwner' -and \$_.AccessControlType -eq 'Allow' }`. Anything returned other than Domain Admins, Enterprise Admins or SYSTEM is the same finding under a different principal.
3	Modify the Target Object (GenericWrite) T1098 · Account Manipulation	12 paths 40% of total	3 accounts	MEDIUM Remove the GenericWrite ACE from the target object's ACL: inspect it with `dscls "<targetDN>"` (or `(Get-Acl "AD:\<targetDN>").Access`), then strip the offending entry with `dscls "<targetDN>" /R "<DOMAIN>\principal>"`. Grant back only the specific attributes the delegation needs (`dscls ... /G "<DOMAIN>\group>:WP;<attribute>"`), never write access to the whole object — msDS-KeyCredentialLink, servicePrincipalName and msDS-AllowedToActOnBehalfOfOtherIdentity each hand over the account on their own. Clear anything already written to those three attributes before removing the ACE, or the takeover survives the fix. - Remove the GenericWrite ACE that VISERY.S.TARGARYEN@ESSOS.LOCAL holds on JORAH.MORMONT@ESSOS.LOCAL. Resolve the object's distinguished name with `Get-ADObject -LDAPFilter '(sAMAccountName=<target>)'`, list what VISERY.S.TARGARYEN@ESSOS.LOCAL currently holds on it with `(Get-Acl "AD:\<targetDN>").Access   Where-Object IdentityReference -like '*<principal>*'`, then delete those entries with `dscls "<targetDN>" /R "<DOMAIN>\<principal>"`. Before: the entry reads ActiveDirectoryRights=GenericWrite (or WriteProperty covering every attribute). After: the same query returns nothing for that principal. - Grant back only the specific attributes the delegation needs, rather than write access to the object. GenericWrite is a takeover because three of the attributes it covers each hand over the account on their own — msDS-KeyCredentialLink (a certificate the account can then authenticate with), servicePrincipalName (which exposes the account's password hash to offline cracking), and msDS-AllowedToActOnBehalfOfOtherIdentity (which lets another host impersonate any user to this one). A scoped grant such as `dscls "<targetDN>" /G "<DOMAIN>\<group>:WP;description"` gives the delegation its attribute and none of those. - Clear anything already written through the ACE before removing it, or the takeover survives the fix. Check the three attributes on JORAH.MORMONT@ESSOS.LOCAL: `Get-ADObject "<targetDN>" -Properties msDS-KeyCredentialLink, servicePrincipalName, msDS-AllowedToActOnBehalfOfOtherIdentity`. A key credential nobody deliberately enrolled, an unexpected service principal name, or a populated delegation attribute should be cleared with `Set-ADObject "<targetDN>" -Clear <attribute>`.
4	Extract LSA Secrets (DumpLSA) T1003.004 · OS Credential Dumping: LSA Secrets	11 paths 37% of total	3 accounts	MEDIUM Restrict local admin / SYSTEM access to the host — LSA secrets live in the HKLM\SECURITY registry hive, so any SYSTEM-level principal can read them and RunAsPPL/LSA Protection does NOT apply here (it guards LSASS process memory, not the registry). Devalue what is stored: use gMSA instead of privileged service accounts, lower cached logons (CachedLogonsCount), and rotate machine/service/krbtgt secrets after suspected compromise; disable Remote Registry where it is not needed. The read itself cannot be fully prevented, so detection is essential: audit reg save/export of HKLM\SECURITY and object access to HKLM\SECURITY\Policy\Secrets, and deploy EDR credential-dump detection.

#	TECHNIQUE	PATHS ELIMINATED	ACCOUNTS COVERED	REMEDIATION GUIDANCE
5	Read the Local Administrator Password (ReadLAPSPassword) T1555 · Credentials from Password Stores	10 paths 33% of total	3 accounts	LOW Restrict read access on ms-Mcs-AdmPwd (legacy LAPS) or msLAPS-Password (Windows LAPS) to authorized IT admin groups only via AD ACL. - Remove the Control Access ACE on ms-Mcs-AdmPwd / ms-LAPS-Password from JORAH.MORMONT@ESSOS.LOCAL on BRAAVOS\$@ESSOS.LOCAL. - Audit LDAP reads of ms-LAPS-Password via Event ID 4662 with the LAPS GUID.
6	Certificate Infrastructure Takeover (ADCS ESC5) T1649 · Steal or Forge Authentication Certificates	5 paths 17% of total	3 accounts	MEDIUM Restrict ACL permissions on CA objects and PKI containers in AD. Remove non-privileged write access to CA configuration objects. - Audit ACLs on the CA computer object, Certification Authority object, and the NTAuthCertificates container in AD - Restrict write access to CA infrastructure objects to only PKI administrators and Enterprise Admins - Conduct a full PKI health review to identify additional CA-level exposure
7	Certificate Authority Administration Abuse (ADCS ESC7) T1649 · Steal or Forge Authentication Certificates	5 paths 17% of total	3 accounts	HIGH Remove the ManageCA or ManageCertificates rights from non-privileged principals. Audit CA officer and manager role assignments. - Restrict Manage CA and Manage Certificates permissions to only authorised PKI administrators - Enforce separation of duties: the same account should not hold both Manage CA and Manage Certificates permissions - Regularly audit CA permission assignments using certutil -cainfo or the CA management MMC
8	Certificate Mapping Abuse (ADCS ESC9) T1649 · Steal or Forge Authentication Certificates	4 paths 13% of total	1 account	HIGH Deploy KB5014754 and set StrongCertificateBindingEnforcement=2 on all DCs. Restrict write access to UPN attributes. Requires thorough testing before full enforcement. - Remove the CT_FLAG_NO_SECURITY_EXTENSION flag from affected templates - Enforce strong certificate mapping by applying KB5014754 and configuring the CertificateMappingMethods registry key - Restrict write access to user UPN attributes to authorised administrators only
9	Group Membership (MemberOf)	3 paths 10% of total	1 account	LOW Remove the user/group from the over-privileged group. - Remove VISERY.S.TARGARYEN@ESSOS.LOCAL from TARGARYEN@ESSOS.LOCAL if the membership is not strictly required. - Audit group membership periodically and enforce tiering boundaries.
10	Local Administrator Access (AdminTo) T1021.002 · Remote Services: SMB/Windows Admin Shares	2 paths 7% of total	1 account	MEDIUM Remove local administrator rights from non-privileged accounts on target machines. Deploy LAPS for local admin password management. Implement tiered access model (PAWs for admin tasks).
11	Remote Desktop Access (CanRDP) T1021.001 · Remote Services: Remote Desktop Protocol	2 paths 7% of total	1 account	MEDIUM Remove the principal from the Remote Desktop Users group on target hosts. Restrict RDP access via GPO and firewall rules.
12	Certificate Template Privilege Escalation (ADCS ESC1) T1649 · Steal or Forge Authentication Certificates	1 path 3% of total 1 exploited	1 account	MEDIUM Disable CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT on the certificate template, or restrict enrollment to specific privileged security groups.

#	TECHNIQUE	PATHS ELIMINATED	ACCOUNTS COVERED	REMEDIALATION GUIDANCE
				• Disable 'Enrollee supplies subject' on template ESC1, or require manager approval for enrollment. • Restrict enrollment permissions on ESC1 to authorized identities only. • Apply the KB5014754 enforcement mode on the CA to block weak SAN mapping.

Vulnerability Impact on Attack Paths

Detected vulnerabilities ranked by the number of attack paths they directly enable. Patching these findings disrupts the corresponding attack chains.

VULNERABILITY	PRIORITY	PATHS ENABLED	DOMAIN(S)
AS-REP Roasting asreproast	6.9	13 paths 43% of total	essos.local
LAPS Password Readable by Non-Admins laps_readable	8.8	10 paths 33% of total	essos.local
ADCS ESC5 - Vulnerable CA Object ACL adcs_esc5	9.0	5 paths 17% of total	essos.local
ADCS ESC7 - Certificate Authority Privilege Abuse adcs_esc7	9.0	5 paths 17% of total	essos.local
ADCS ESC9 - No Security Extension on Certificate Template adcs_esc9	9.0	4 paths 13% of total	essos.local
ADCS ESC1 - Misconfigured Certificate Template adcs_esc1	9.9	1 path 3% of total	essos.local
ADCS ESC2 - Any Purpose Certificate Template adcs_esc2	9.0	1 path 3% of total	essos.local
ADCS ESC3 - Enrollment Agent Template Abuse adcs_esc3	9.0	1 path 3% of total	essos.local
ADCS ESC4 - Vulnerable Certificate Template ACL adcs_esc4	9.0	1 path 3% of total	essos.local
ADCS ESC8 - NTLM Relay to Web Enrollment adcs_esc8	9.0	1 path 3% of total	essos.local

07

Privilege Blast Radius

Single over-broad grants that place many objects under the control of one principal.

A single excessive permission can place thousands of accounts or computers under the control of one principal. Each row below collapses one such over-broad grant into a single finding: the principal that holds it, how many objects it reaches, and the privilege tier of those objects. The count is the blast radius — the number of objects exposed if that one principal is compromised. Restricting the grant closes every one of those exposures at once.

PRINCIPAL	BLAST RADIUS	OBJECT TIER	SEVERITY	REPRESENTATIVE OBJECTS
ACCOUNT OPERATORS	40 controls 40 objects via a single delegated right	Tier 2: Standard	HIGH	DNSUPDATEPROXY, TARGARYEN, DOTHRAKI, DRAGONSFRIENDS, SPYS ...and 35 more
ACCOUNT OPERATORS	13 controls 13 objects via a single delegated right	Tier 0: Escalation-capable	HIGH	DNSADMINs, ENTERPRISE READ-ONLY DOMAIN CONTROLLERS, CERT PUBLISHERS, GROUP POLICY CREATOR OWNERS, KEY ADMINs ...and 8 more

08

Remediation Roadmap

Prioritised action plan to reduce risk across the environment.

Start here. The 3 containment actions below are not findings and do not appear on the timeline. They exist because the assessment succeeded: material that authenticates against your directory is now outside your control, and only your team can take it back. Complete them first. Nothing else on this roadmap is effective while they are outstanding.

CONTAINMENT 1 OF 3

Reset the krbtgt password twice, with replication in between

This assessment recovered the krbtgt account's key material in essos.local. That key signs every Kerberos ticket the domain issues, so anyone holding it can mint a ticket for any account — including accounts that do not exist — and every domain controller will accept it.

Reset it twice. A domain controller keeps the previous krbtgt key and keeps honouring tickets signed with it, which is deliberate: it stops a single reset from cutting off every session in the domain at once. It also means one reset leaves forged tickets working. The second reset is what removes the old key from circulation, and it only works if the first one has replicated everywhere before you run it.

1. Reset the password once. The value you type is discarded — the domain replaces it with a random key — so any long random string will do.

```
Set-ADAccountPassword -Identity krbtgt -Reset -NewPassword (Read-Host -AsSecureString 'New krbtgt password')
```

2. Confirm the reset has reached every domain controller before you go further. Every controller must report the same new pwdLastSet.

```
repadmin /replsummary
```

```
Get-ADDomainController -Filter * | ForEach-Object { Get-ADUser krbtgt -Server $_.HostName -Properties pwdLastSet | Select-Object @{'n='DC';e={$_.PSComputerName}}, @{'n='pwdLastSet';e={[datetime]::FromFileTime($_.pwdLastSet)}} }
```

3. Wait out the maximum ticket lifetime — ten hours under the default Kerberos policy — so tickets issued under the old key have expired on their own. Resetting twice inside that window forces every session in the domain to re-authenticate at once, which is what turns a contained incident into an outage.

4. Reset the password a second time, exactly as in step 1.

```
Set-ADAccountPassword -Identity krbtgt -Reset -NewPassword (Read-Host -AsSecureString 'New krbtgt password')
```

5. If the forest holds read-only domain controllers, each one has its own krbtgt account (krbtgt_<number>). Reset those on the same schedule; they are separate keys and the two resets above do not touch them.

```
Get-ADUser -LDAPFilter '(samAccountName=krbtgt_*)' -Properties pwdLastSet
```

WHAT STAYS TRUE AFTERWARDS

Tickets already issued stay valid until they expire, so plan the two resets alongside the credential rotation below rather than treating either as an instant cut-off.

Treat every recovered credential as compromised and rotate it

The assessment recovered credential material for 9 accounts in `essos.local`: `administrator`, `daenerys.targaryen`, `drogon`, `jorah.mormont`, `khal.drogo`, `missandei`, `sql_svc`, `vagrant`, `viserys.targaryen`. Each is compromised, whatever was recovered for it — a password hash and a Kerberos key authenticate as the account just as a password does. A full replication of the directory database also completed in `essos.local`, which means every account's password hash in that domain was exposed, not only the accounts named above. Treat the list as the confirmed minimum.

How each account was reached is a separate question from what to do about it. Closing the route stops the next attacker; it does nothing about the credential itself, which is already outside your control and has to be replaced.

1. Reset the password on every account named above. Disabling, renaming or moving an account does not help: the recovered material is derived from the password, so only a password change invalidates it.

```
Set-ADAccountPassword -Identity <account> -Reset -NewPassword (Read-Host -AsSecureString 'New password')
```

```
Set-ADUser -Identity <account> -ChangePasswordAtLogon $true
```

2. Handle the service accounts first and separately. An account with a registered service principal name is running something, and resetting it without updating wherever that service stores the password takes the service down. Find them, schedule the change, update the service configuration and the reset together.

```
Get-ADUser -LDAPFilter '(servicePrincipalName=*)' -Properties servicePrincipalName, PasswordLastSet | Select-Object SamAccountName, PasswordLastSet, servicePrincipalName
```

3. Where a service account can move to a group managed service account, move it. The directory then rotates the password on its own every thirty days and this class of exposure stops recurring.

```
New-ADServiceAccount -Name <gmsa-name> -DNSHostName <service-host-fqdn> -PrincipalsAllowedToRetrieveManagedPassword '<HOST$>'
```

```
Install-ADServiceAccount -Identity <gmsa-name>
```

4. Check whether any of these passwords is in use anywhere else — a local administrator account, a scheduled task, an application configuration file, a second directory. A recovered password is compromised everywhere it was ever used, not only where it was found.

WHAT STAYS TRUE AFTERWARDS

Rotate in order of privilege, not alphabetically: an account that can reach a domain controller matters more than one that cannot, and a partial rotation that leaves the privileged accounts for last leaves the compromise intact.

Revoke the certificate your CA issued during the assessment

Your certification authority issued 2 certificates during this assessment, authenticating as `administrator@essos.local`, valid until 2027-08-02 09:58 UTC. A certificate outlives the engagement by design: it keeps authenticating until it expires or is revoked, and nothing in the directory takes it out of service.

Revoking needs certificate-manager rights on the issuing CA, which this assessment did not hold, so it is the one action only your team can complete.

1. Revoke each certificate on the issuing CA, as a member of its Certificate Managers group: locate the record by request ID, revoke it with reason code 1 (key compromise) — the private key was generated outside your control — publish a fresh revocation list, then confirm the record's disposition reads 21.
2. Close the template that allowed the certificate to be requested with someone else's identity. Revoking one certificate without fixing the template means the next request succeeds the same way.

Section 09 carries the request ID, the serial number and the exact command sequence for each one.

WHAT STAYS TRUE AFTERWARDS

Revocation only stops future authentication. A Kerberos ticket already obtained with the certificate stays valid for its lifetime, and if the certificate carried a privileged identity, that account's password has to be reset once the revocation is confirmed.

Contain critical exposure

Complete the 3 containment actions above first, then work through the findings below.

- **Attack Path: DOMAIN USERS@ESSOS.LOCAL → ESSOS.LOCAL** · essos.local · ADscan Priority 9.8
- **ADCS ESC1 - Misconfigured Certificate Template** · essos.local · ADscan Priority 9.9
- **noPac/sAMAccountName Spoofing (CVE-2021-42278 + CVE-2021-42287)** · essos.local · ADscan Priority 9.8
- **ADCS ESC9 - No Security Extension on Certificate Template** · essos.local · ADscan Priority 9.0
- **ADCS ESC14 - Weak Explicit Certificate Mapping Abuse** · essos.local · ADscan Priority 9.0
- **ADCS ESC2 - Any Purpose Certificate Template** · essos.local · ADscan Priority 9.0
- **ADCS ESC3 - Enrollment Agent Template Abuse** · essos.local · ADscan Priority 9.0
- **ADCS ESC8 - NTLM Relay to Web Enrollment** · essos.local · ADscan Priority 9.0
- **ADCS ESC5 - Vulnerable CA Object ACL** · essos.local · ADscan Priority 9.0
- **ADCS ESC7 - Certificate Authority Privilege Abuse** · essos.local · ADscan Priority 9.0
- **ADCS ESC4 - Vulnerable Certificate Template ACL** · essos.local · ADscan Priority 9.0
- **LAPS Password Readable by Non-Admins** · essos.local · ADscan Priority 8.8
- **PrintNightmare Vulnerable Hosts Detected** · essos.local · ADscan Priority 8.8
- **Domain Controller Accepts NTLMv1 Authentication** · essos.local · ADscan Priority 8.5
- **gMSA Password Readable by Non-Admins** · essos.local · ADscan Priority 7.5
- **SMBv1 Protocol Enabled** · essos.local · ADscan Priority 7.5

Reduce attack surface

- **AS-REP Roasting** · essos.local · ADscan Priority 6.9
- **Kerberoasting** · essos.local · ADscan Priority 5.3
- **Weak Default Domain Password Policy** · essos.local · ADscan Priority 5.3
- **SMB Signing Not Required** · essos.local · ADscan Priority 5.0

Harden baseline

- **Accounts with Non-Expiring Passwords** · essos.local
- **Machine Account Quota Allows Domain Join** · essos.local
- **Passwords Predating Current Policy** · essos.local

09

Environment Modifications & Cleanup

A complete record of the changes this assessment made to the directory and the state each was left in.

Testing some attack paths requires changing live directory objects. Each change below was logged as it was made. Where a change could be undone, the assessment reverted it and then re-read the object to confirm the change was gone. Any change that could not be confirmed as reverted is listed under **Requires manual cleanup** with the exact object and the command to run.

0

REVERTED & CONFIRMED

2

REQUIRES MANUAL CLEANUP

Changes the assessment made and reverted

The assessment created these changes and then confirmed, by re-reading the object, that each was removed. No further action is needed for the items below.

No changes were automatically reverted during this assessment.

Requires manual cleanup

The assessment could not confirm these changes were reverted. Complete the actions below before closing the engagement. Each entry names the affected object and carries the native procedure that restores it, ready to run.

1 Certificate issued by your CA **No automatic rollback is possible**

CA ESSOS-CA on braavos.essos.local · Request ID 16

THE PROCEDURE, WITH THIS ENGAGEMENT'S VALUES

Certificate authenticates as administrator@essos.local, issued from template ESC1, by ESSOS-CA, valid until 2027-08-02 09:45 UTC. Your certification authority issued this certificate during the assessment. It stays valid for authentication until it expires or is revoked, and revoking it requires certificate-manager rights on the CA, so your team has to complete this step.

Run the commands below on the CA server, or on any host with the Certification Authority tools installed, as a member of the CA's Certificate Managers group (or the CA host's local Administrators):

1. Locate the record and confirm it is still live
`certutil -config "braavos.essos.local\ESSOS-CA" -view -restrict "RequestId=16" -out "RequestId,Request.RequesterName,Certificate.SerialNumber,Certificate.NotAfter,Request.Disposition"`
 A Disposition of 20 means the certificate is issued and usable.
2. Revoke it. Reason code 1 is key compromise, which is the accurate reason here: the private key was generated outside your control.
`certutil -config "braavos.essos.local\ESSOS-CA" -revoke 33000000105351CB9FFED7616100000000010 1`
3. Publish a fresh CRL so domain members learn of the revocation
`certutil -config "braavos.essos.local\ESSOS-CA" -CRL`
4. Verify the change took effect
`certutil -config "braavos.essos.local\ESSOS-CA" -view -restrict "SerialNumber=33000000105351CB9FFED7616100000000010" -out "Request.Disposition,Request.RevokedReason"`
 Disposition must now read 21 (revoked).

Two caveats worth planning for. The certificate keeps working until the new CRL has replicated to every CRL distribution point published in it, so confirm distribution with `certutil -verify -urlfetch` against a copy of the certificate. And revocation only stops future authentication: any Kerberos ticket already obtained with the certificate remains valid until it expires under Default Domain Policy > Computer Configuration > Policies > Windows Settings > Security Settings > Account Policies > Kerberos Policy. If the certificate carried the identity of a privileged or machine account, reset that account's password once the revocation is confirmed.

2 Certificate issued by your CA **No automatic rollback is possible**

CA ESSOS-CA on braavos.essos.local · Request ID 17

THE PROCEDURE, WITH THIS ENGAGEMENT'S VALUES

Certificate authenticates as administrator@essos.local, issued from template ESC1, by ESSOS-CA, valid until 2027-08-02 09:58 UTC. Your certification authority issued this certificate during the assessment. It stays valid for authentication until it expires or is revoked, and revoking it requires certificate-manager rights on the CA, so your team has to complete this step.

Run the commands below on the CA server, or on any host with the Certification Authority tools installed, as a member of the CA's Certificate Managers group (or the CA host's local Administrators):

1. Locate the record and confirm it is still live
certutil -config "braavos.essos.local\ESSOS-CA" -view -restrict "RequestId=17" -out
"RequestId,Request.RequesterName,Certificate.SerialNumber,Certificate.NotAfter,Request.Disposition"
A Disposition of 20 means the certificate is issued and usable.
 2. Revoke it. Reason code 1 is key compromise, which is the accurate reason here: the private key was generated outside your control.
certutil -config "braavos.essos.local\ESSOS-CA" -revoke 3300000011FB687872BA4896D0000000000011 1
 3. Publish a fresh CRL so domain members learn of the revocation
certutil -config "braavos.essos.local\ESSOS-CA" -CRL
 4. Verify the change took effect
certutil -config "braavos.essos.local\ESSOS-CA" -view -restrict "SerialNumber=3300000011FB687872BA4896D0000000000011" -out
"Request.Disposition,Request.RevokedReason"
Disposition must now read 21 (revoked).
- Two caveats worth planning for. The certificate keeps working until the new CRL has replicated to every CRL distribution point published in it, so confirm distribution with certutil -verify -urlfetch against a copy of the certificate. And revocation only stops future authentication: any Kerberos ticket already obtained with the certificate remains valid until it expires under Default Domain Policy > Computer Configuration > Policies > Windows Settings > Security Settings > Account Policies > Kerberos Policy. If the certificate carried the identity of a privileged or machine account, reset that account's password once the revocation is confirmed.